

Fondamenti Social

simi

March 2022

Contents

1	Intro parte 1	9
2	Storia e definizioni	11
2.1	Ed alla fine arriva internet	12
2.2	Sociologia	12
2.3	Social Network	13
2.3.1	Six Degres.com	13
2.3.2	MySpace:	13
2.3.3	Linkedin:	13
2.3.4	Facebook:	14
2.3.5	Twitter	14
2.3.6	Google +	14
2.3.7	Instagram	14
2.3.8	Social network monotematici	14
2.3.9	Geo-social Network	14
2.3.10	Caratteristiche SNS (social network site)	14
2.3.11	Social network: adozione	15
2.4	Terminologia	15
2.5	Funzionalità peculiari dei social network	16
2.6	classificazione social media	16
2.7	Deriva social dei siti	17
3	Social media ed impresa	19
3.1	Social media e impresa	20
3.2	Social media analytics	20
3.2.1	Bisogni analitici	21
3.3	Framework per la misurazione	22
3.3.1	Counting metrics	22
3.3.2	Business Value	22
3.3.3	Fundamendational metrics	23
3.3.4	Outcome metrics	23
3.4	Social Media Listening	27
3.4.1	Definire gli obiettivi	28
3.4.2	Selezionare le fonti	28
3.4.3	Recuperare i dati	28
3.4.4	Analisi dei dati	29
3.4.5	Reporting	29
3.4.6	Proposte di azioni	29

4	Social media API	31
4.1	RESTFULL API	32
4.2	Vantaggi	32
4.3	Svantaggi	33
4.4	Connessione a API	33
4.5	Esempio API Twitter	33
4.6	OAUTH 2.0	34
4.6.1	Ruoli	34
4.6.2	Access Token	34
4.6.3	Authorization Grant	35
4.6.4	Client	35
4.6.5	Endpoints	35
4.6.6	Authorization grant code	35
4.6.7	Client Credential Grant	36
4.6.8	Accesso ad una risorsa protetta	37
5	Web Scraping	39
5.1	HTTP	40
5.2	HTML e CSS per il Web Scraping	40
5.3	Utilizzo del browser per il web scraping	41
5.4	CSS	41
5.5	Modificare header HTTP	41
5.6	JavaScript e Selenium	42
5.7	XPATH	42
6	Misinformation	43
6.1	Tipi di Mininformation	44
6.2	Metodi di contrasto ai diffusori di misinformation	45
6.2.1	Identificazione Content-Base	46
6.3	Metodi di identificazione della misinformation	46
6.4	Fake News	47
6.4.1	Definizione	47
6.4.2	Fake news su media tradizionali	47
6.4.3	Fake news detection	48
6.5	Social Bot	50
6.5.1	Social bot pandemic	50
7	Intro modulo 2	51
7.1	CyberSecurity	52
7.2	Privacy Protection	52
7.3	Sistema sicuro	52
7.3.1	Confidenzialita'	52
7.3.2	Integrita'	52
7.3.3	Disponibilita'	53
7.4	Sistemi non sicuri	53
7.4.1	Errori nel software	53
7.5	Terminologia	54
7.6	Attacco	54
7.6.1	Passivi	54
7.6.2	Attivi	54
7.6.3	Conseguenze degli attacchi	54
7.7	Asset	54
7.8	Minacce	55
7.8.1	Motivi degli attacchi	55

7.9	Strategie di difesa	55
7.10	Contromisure	55
7.11	Riassunto	55
7.12	Nascita cyber security	55
7.13	Perche siamo interessati	55
7.13.1	Social Network	56
7.13.2	Architettura dei un social network	56
7.13.3	Motivazioni dietro un attacco social	56
7.13.4	SN e Cybersecurity	56
8	Cybersecurity	59
8.1	Crittografia	60
8.1.1	Cybersecurity e Crittografia	60
8.1.2	In SN	60
8.1.3	Modello di riferimento	60
8.1.4	Categorie algoritmi	61
8.2	Crittografia a chiave privata	62
8.2.1	Encryption	62
8.2.2	Decryption	62
8.2.3	Crittografia simmetrica	62
8.2.4	Data Encryption Standard DES	63
8.2.5	AES	63
8.2.6	Encryption Modes	63
8.3	Crittografia a chiave pubblica	65
8.3.1	Cifratura/De-cifratura	65
8.3.2	Funzionamento	65
8.3.3	Firma digitale	66
8.3.4	Protocolli	66
8.3.5	Secret vs. Public	67
8.3.6	Scambio di chiavi	67
8.4	One-way hash functions	67
8.4.1	Proprieta' delle funzioni one-way	67
8.4.2	Verifica di integrita'	67
8.4.3	Hash application	68
8.4.4	Firma digitale più efficiente	68
8.4.5	Funzioni hash famose	68
8.4.6	Funzione di hash con chiave (HMAC)	69
8.5	Certification authority	69
8.5.1	Man in the middle attack	69
8.5.2	x509 and PKI (publik key infrastructure)	69
8.6	GNU Privacy Guard	70
8.6.1	Web of trust	70
9	Laboratorio GPG	71
9.1	Encrypt Data	72
9.2	Revocare una chaive	72
10	Identificazione ed autenticazione	73
10.1	Identita'	74
10.2	Autentiaczione	74
10.2.1	What you know	74
10.2.2	Vulnerabilita' delle password	76
10.3	Something you are: biometria	78
10.3.1	Something you have	78

10.4 Strong authentication	79
10.5 SSO (single sign one)	79
10.5.1 OpenID	79
10.5.2 OAuth	79
11 Controllo degli accessi	81
11.1 Policy	82
11.2 Access Control	82
11.3 Chi definisce la security policy	83
11.4 Definire il controllo degli accessi	83
11.5 Access Control List	84
11.6 Capability	85
11.7 REFERENCE MONITOR	85
11.8 Auditing	86
11.8.1 Log management system	87
11.9 Unix file system	87
11.9.1 Superuser	87
11.9.2 Groups	87
11.9.3 I soggetti	87
11.9.4 Oggetti	87
11.9.5 Unix ACLs	88
11.9.6 CHMOD	88
11.9.7 SetUID	89
11.10 UNIX authorization mechanism	89
12 Computer Attacks	91
12.1 Attack Life Cycle	92
12.2 Ingegneria sociale	93
12.2.1 Tecniche	93
12.2.2 Intercettazioni	94
12.2.3 Phishing	94
12.3 Intelligenza artificiale	94
12.4 Malware	95
12.4.1 Logic Bomb	95
12.4.2 Computer Virus	95
12.4.3 Computer worm	96
12.4.4 Trojan Horse	96
12.4.5 Rootkit	96
12.4.6 Bomba logica	96
12.4.7 Botnet	97
12.4.8 Stuxnet	97
12.4.9 Wannacry	97
12.5 Antivirus	97
12.5.1 Virus total	97
12.6 Program flaws (bug)	97
12.6.1 Buffer Overflow	98
12.6.2 Contromisure	98
12.6.3 Randomizzazione	99
12.6.4 Stack guard	99
12.6.5 Non-executable stack	99
12.6.6 Data execution prevent	99

13 Web Security	101
13.1 HTTP	102
13.2 HTTPS	103
13.3 Contenuto dinamico	103
13.4 JavaScript	103
13.5 Web 1.0	103
13.6 Cookie	104
13.7 Attacchi al browser	104
13.7.1 Man in the browser	104
13.7.2 Click-Jacking	105
13.7.3 IE Image Crash	105
13.7.4 Vulnerabilità	105
13.7.5 CSRF, Cross Site Requests Forgery	105
13.7.6 Cross-Site Scripting	106
13.8 Laboratorio	108
14 Network Security	109
14.1 Cos'è una rete	110
14.2 Network attack	113
14.3 Attacco di intercettazione	114
14.3.1 Spoofing	114
14.4 Attacchi all'integrità	115
14.4.1 Esempio	115
14.5 DoS-DDoS	116
14.5.1 Smurf Attack	116
14.5.2 Syn Flood	116
14.6 Mitigare gli attacchi alla confidenzialità	119
14.6.1 IP SEC	120
14.6.2 TCP TLS	120
14.7 Firewall	120
14.7.1 IDS	123
14.7.2 Intrusion Prevention System IPS	123
14.7.3 Unified Threat Management Product	123
15 Privacy	125
15.1 Data Breach	126
15.2 Il futuro	127
15.3 GDPR	127
15.3.1 Dato personale	127
15.3.2 Informazione e consenso	127

Chapter 1

Intro parte 1

Il primo dato interessante e' il fatto che + del 60% utilizza un mobile device. Addirittura abbiamo una percentuale inferiore di persone che utilizzano internet. Questo giustifica che in un percorso di comunicazione digitale fare mobile computing, abbiamo 4.6 miliardi di persone registrate sui social media (piu' della meta' usa un social media). In piu' abbiamo la percentuale di crescita rispetto a gennaio 2021, gli utenti attivi sui social sono aumentate del 10%, piu' del doppio rispetto agli altri dati.

Circa questi fenomeni i due report (weAreSocial) danno anche una previsione di trend. Secondo weAreSocial, si spende piu' tempo online (per vincoli da lockdown) e questa fruizione dei mezzi online in realta' ha alcune implicazioni di tipo sociale perche' gioca insieme al digital divide, amplifica il digital inequality (distribuzione diversa delle risorse digitali nel mondo). I servizi orientati al social non sono uniformemente distribuiti ma solo in pochi li usano o li usano con sistemi adeguati.

Abbiamo altri tipi di trend orientati al marketing.

Stiamo in media 7 ore online e 2.5 ore sui social e fruiamo i social principalmente mobile

Chapter 2

Storia e definizioni

Da cosa nasce l'idea di social media? la parte social e' intrinseca nella natura umana ma la rappresentazione della struttura delle reti sociali nasce come disciplina negli anni 30-50, il primo esempio di utilizzo del concetto di rete (connessione tra persone) e' degli anni 30 e sono esperimenti di Moreno (puntini alla finestra, esempio di prima rete sociale, elementi connessi da righe che indicano una relazione, sociometria = misurazione dei fenomeni sociali). La rappresentazione di cio' che consideriamo social network risale ad Eulero, in particolare una rete sociale viene rappresentata attraverso il concetto di grafo, nella sua definizione base un grafo e' un insieme di coppie in cui abbiamo un insieme di nodi che graficamente se vogliamo fare un parallelo con l'esperimento sono dei pallini (delle persone nella sociometria), i pallini corrispondono a V . Ed abbiamo un secondo insieme (degli archi) che e' un sottoinsieme del prodotto cartesiano $V \times V$, gli archi sono coppie non ordinate dei punti. Ogni elemento dell'insieme E corrisponde ad una connessione tra i punti. Questa modellazione e' alla base di ogni studio di reti sociali, una rete sociale e' un insieme di persone connesse tra loro attraverso legami di varia natura:

- Sociologia
- Epidemiologia
- Politica

lo zakari club e' una rete sociale relativa a degli atleti che praticano il karate che ad un certo punto della vita del club si e' spezzato e viene utilizzata come esempio di una applicazione di rete sociale perche' gia' analizzando graficamente la rete, si ha un'idea che prima della scissione si ha una struttura che avrebbe supportato la scissione stessa.

Un'altra rappresentazione e' una rete di contatti del personale medico di un ospedale, e ci permette di dimostrare che i contatti sono pericolosi per la trasmissione di malattie.

l'ultimo esempio sono dati ottenuti da blog politici americani in cui quelli blu sono i democratici (autori di blog/giornalisti che supportano il partito democratico) e quelli rossi sono i repubblicani. facendo un'analisi di citazioni o che sono collegati ad altri blog, la struttura che si crea e' quella di due gruppi che corrispondono alla suddivisione dei due partiti negli stati uniti. C'e' una componente centrale che rappresenta la via di mezza ma e' di pochi commentatori.

2.1 Ed alla fine arriva internet

L'altra componente fondamentale per lo sviluppo dei social media e' Internet, tutti usiamo Internet

2.2 Sociologia

Sociologicamente abbiamo il concetto dei 6 gradi di separazione (tutti siamo connessi con tutto il mondo) nasce da una semplice domanda: se prendo due persone A e B, quante relazioni intermedie sono necessarie affinché A e B siano direttamente o indirettamente connesse? Questa idea introduce il concetto di 6 gradi di separazione (esperimento). Innanzitutto abbiamo a sinistra una serie di persone che sono le persone sorgenti che sono situate in due città del centro degli stati uniti, a queste persone viene data una busta con fogli e cartoline con due nomi target dell'esperimento (quelle persone a cui va recapitata la busta), uno e' un pastore, l'altra broker. Nel primo foglio chi riceve la busta deve segnare il nome e la data in cui ha ricevuto la busta delle cartoline che vanno compilate e spedite allo sperimentatore. Quando ricevo la busta devo inoltrare la busta ad una persona che ritengo vicina all'obiettivo, devo sfruttare la rete di conoscenze in modo che la busta venga recapitata. Dopo un paio di giorni la busta raggiunge la persona, dopo un po' anche il pastore riceve la busta. I risultati: il numero di intermediari per consegnare la busta e' di 5 persone,

il risultato negativo e' che tra tutte le catene di trasmissione solo 44 sono quelle arrivate, il resto e' stato perso (mai giunte all'obbiettivo). Dopo l'introduzione delle reti social, due sono gli studi importanti su larga scala, il primo su messenger, l'altro su facebook che hanno stimato essere 3.74 gradi di separazione su facebook

2.3 Social Network

Formalizzano quello che consideriamo rete sociale e ne identificano 3 elementi costituenti necessari affinché un servizio web possa essere una rete sociale:

- Possibilita' di creare un profilo pubblico o quasi pubblico
- Creazione e la gestione di una lista di contatti
- Offrono la possibilita' di scorrere la lista degli amici dei propri contatti, permette anche un certo livello di navigabilita' della rete creata tra i contatti delle persone

Nel caso di messaggistica non stiamo parlando di social network ma genericamente parleremo di social media.

2.3.1 Six Degres.com

e' il primo servizio di social networking con tutte e tre le caratteristiche. Cerca di essere una mappa 1 a 1 delle relazioni sociali che ognuno ha esternamente alla piattaforma. Dev'esserci una veridicità del profilo, una descrizione di se stessi che dev'essere coincidente con la realtà, tuttavia il problema principale e' che e' chiara agli autori della rete ma non e' chiara agli utenti lo scopo del servizio. Tuttavia gli utenti scambiano questa applicazione come una rete di dating, questa confusione crea una necessita' di avere una piattaforma con un obbiettivo piu' chiaro ed e' per questo che nascono due piattaforme.

- Ryze: e' un social network di tipo professionale, espongono solo le informazioni di tipo professionale e mi collego solo a miei colleghi, capi dipartimento fra aziende. Va a riproporre una sorta di relazioni economico/sociale.
- Friendster: e' considerato simile a Facebook, c'e' un'ulteriore stress verso la veridicità. iniziano ad essere introdotte delle caratteristiche che rivedremo all'inizio di Facebook. La foto profilo dev'essere vera, il nome autentico. Con la possibilita' di amici degli amici, abbiamo anche una sorta di localizzazione (data dalle informazioni del profilo).

Si crea una community di fakester, ed un altro problema infrastrutturale, cioè questa rete sociale ha avuto un'esplosione ma non e' stata supportata dall'hardware.

2.3.2 MySpace:

e' molto simile a friendster con dei bug che ne hanno permesso il successo, ovvero permetteva la customizzazione delle pagine HTML dei vari profili, c'era anche la possibilita' di integrare un video player. Mole band migrarono verso mySpace perche' permetteva una maggiore liberta' di pubblicazione e grazie al contributo di queste band molte persone entrarono nella piattaforma in quanto fan delle band.

2.3.3 LinkedIn:

nasce dall'idea di ryze, e' una rete sociale orientata al business ed al mondo professionale, in questo caso il profilo personale diventa solamente una descrizione professionale (CV online) le relazioni non sono piu' di amicizia tra persone ma ti tipo personale

2.3.4 Facebook:

viene applicato un preciso modello di business, che e' quello che ha permesso di bruciare la concorrenza, in piu' c'e' anche un aspetto di innovazione, data dalla possibilita' di estendere le funzionalita' base attraverso applicazioni sviluppate dalla piattaforma sia da terzi. Le foto (social tagging), un nuovo canale di costruzione di relazioni, dopo di che viene introdotto il concetto di news feed (wall) la possibilita' di vedere cos'ha scritto l'altra persona. L'idea e' di non uscire mai da Facebook per trovare qualcosa (libra, foto, video, gruppi). Quest'idea di non uscire mai e' alla base del concetto che ha facebook di metaverso.

2.3.5 Twitter

Creare una rete sociale asimmetrica, ovvero la possibilita' di seguire qualcuno con la possibilita' che quello che seguo non mi segua. L'altra idea e' sulla creazione del contenuto, messaggi brevi 480 caratteri, ovviamente poi partendo dal prototipo viene introdotto il concetto di hashtag che ci permette di organizzare semanticamente il contenuto che stiamo scrivendo. Viene anche considerato un information network perche' permette il broadcasting, perche' esistono star all'interno di Twitter ed ogni volta che un utente cosi' pubblica qualcosa raggiunge una grossa fetta di utenti. Tante' che solo il 29% dei twit genera una reazione, viene introdotta una passivita' di reazione. L'altro aspetto e' di promuovere alcuni profili che sono celebrity fuori e dentro la piattaforma

2.3.6 Google +

Google tenta di entrare nel mondo dei social network perche' aveva un sacco di account esterni alla rete sociale (gmail, youtube). Fallimento

2.3.7 Instagram

Originariamente era un applicazione di geo-socialNetwork che ha questa funzionalita' di foto sharing che e' l'unica cosa utilizzata dall'applicazione. Oltre a questo c'era la possibilita' di modificare le foto. Utenti business, tag

2.3.8 Social network monotematici

Tutte le reti che abbiamo visto fin'ora si rivolgono ad un pubblico ampio in questo caso invece si progettano spazi di relazioni verticali, ossia servizi costruiti attorno ad un tema ben specifico.

2.3.9 Geo-social Network

Social network basati sulla localizzazione del telefono e la gamification

2.3.10 Caratteristiche SNS (social network site)

Vediamo le caratteristiche più astratte che derivano dall SNS:

- la persistenza: le nostre azioni su queste reti sociali persistono (tranne snapchat). Non solo nelle relazioni ma anche nel contenuto
- Tutto ciò che facciamo è trovabile, perchè è reso persistente
- Replicabilità: del contenuto anche decontestualizzato, le mie azioni possono essere preso e diffuse in modo benigno o in modo maligno, quindi privando del contesto il contenuto che voglio condividere in modo da cambiare il messaggio originale.

- Pubblico invisibile: quando parliamo di social network generalisti è la difficoltà di identificare a chi ci si rivolge. Perché c'è troppo pubblico per andare a categorizzarlo, oppure perché la spinta iniziale verso la veridicità dei profili è andata scemando nel tempo.

2.3.11 Social network: adozione

Secondo un modello (diffusion of innovation), viene analizzato il processo di diffusione di un innovazione (non legata ad un social media) e nel libro che ha utilizzato è stata applicata ai social network. Il modello di diffusion of innovation adotta sostanzialmente 5 elementi chiave per descrivere come un'innovazione si diffonde. Gli elementi che caratterizzano l'adozione di un innovazione:

- Nella prima fase ci sono gli innovators poi early adopter, che sono leggermente meno propensi a rischiare infine ci sono gli early majority in cui c'è già uno zoccolo duro di innovators e di early adopters ed in questa fase si ha quello che viene definito il burrone, cioè se riesco a passare alla fase di early majority è molto probabile che la mia piattaforma si diffonda in modo ampio. Ci sono poi i late adopter e per ultima fase ci sono quelli che non vogliono rischiare niente (laggards).
- C'è tutto un'altro discorso anche sul canale di comunicazione su cui la mia piattaforma si diffonde. (Facebook usava le mail dall'università)
- Un'innovazione non si diffonde nell'aria, ha bisogno di un sistema sociale per potersi diffondere
- l'ultimo elemento è l'innovazione stessa che deve avere alcune caratteristiche, in generale si considera il concetto stesso di innovazione.

2.4 Terminologia

- Friends: qualsiasi azione che rende pubblico che due utenti hanno una relazione reciproca o asimmetrica
- bacheca: spazio dove il sistema pubblica le notizie che riguardano noi: quello che noi creiamo più quello che creano i nostri amici
- Pagina dei feed: non è necessario che l'utente possessore della pagina dei feed sia taggato (la timeline di twitter)
- Follower: relazione asimetrica in cui io divento subscriber di un account
- Status: Messaggio in cui si condivide lo stato d'animo
- Post: qualsiasi cosa che viene comunicato online
- Thread: nasce prima delle reti sociali, è una sequenza di contenuti relativi ad un determinato post radice
- Like: segnali di apprezzamento verso un contenuto
- Direct message(DM): comunicazione one to one tra due account che possono essere amici oppure no

2.5 Funzionalità peculiari dei social network

- Wall
- messaggi privati
- Chattare
- Organizzazione contenuti multimediali
- Possibilità di creare gruppi
- Creare eventi
- Thread
- Meccanismi di ricerca
- Ricondividere il contenuto

Dobbiamo sottolineare la differenza tra social network (le tre caratteristiche di prima, profilo pubblico, lista di contatti, vedere i contatti e navigarli) e social media è invece più generale in cui può non esserci una di queste tre componenti ma c'è una certa tendenza alla creazione di network tra utenti e come viene prodotto il contenuto. Nei social media abbiamo il concetto di user generated content, l'utente è il creatore del contenuto veicolato sulla piattaforma attraverso gli strumenti messi a disposizione dall'idea di network però non è detto che il contenuto sia veicolato solo attraverso questi collegamenti (il retweet potrebbe interessare non solo persone che sono nella mia cerchia di relazioni). Sostanzialmente social media diventa un insieme che include anche i social network, i quali diventano un sottoinsieme proprio dei social media.

2.6 classificazione social media

- Social media generalisti: sono quelli main stream, non c'è un unico argomento ma l'unico scopo è quello di far socializzare tra di loro gli utenti, solitamente si usa il nome di spazio virtuale. Dato l'ampio pubblico questi sono gli spazi in cui le aziende si muovono per pubblicizzare i prodotti/brand.
- Tematici: come vedevamo prima ruotano attorno ad un particolare tema. Sono importanti perché c'è un contenuto specifico e l'audience è interessata solo a quel contenuto e se è dal punto di vista semantico prossimo al mio brand sarà un ottimo terreno per le aziende.
- Social media funzionali: abbiamo un tipo specifico di contenuto e tutto ruota affinché quel contenuto venga fruito al massimo delle sue possibilità, ad esempio YouTube, Twitch in quanto sono solo video.
- Social network generati da un servizio (user generated network): un servizio che fornisce una serie di funzionalità per supportare l'interazione sociale di un determinato gruppo. Ad esempio tramite NING o buddypress mi permettono di creare delle piccole reti sociali, che sono community simili a dei forum ma organizzati secondo il paradigma delle reti sociali.

2.7 Deriva social dei siti

E' un fenomeno tutt'ora in atto ma che ha riguardato principalmente il periodo iniziale delle reti sociali. Dato l'enorme successo tutte le applicazioni web hanno cercato di introdurre delle funzionalità social, a volte ha avuto senso altre volte no. L'esempio più eclatante è Amazon, il quale ha una scarsa interazione sociale tra gli utenti. Inoltre c'è anche una componente virtuosa, circolo virtuoso tra il contenuto prodotto sulle piattaforme out of social ed il social stesso, che in alcuni casi è utile, come nei giornali online in cui il contenuto viene prodotto dal sito out of social, molto facilmente il contenuto passa sulla rete sociale, qui si innescano delle dinamiche tipiche della diffusione sociale ed in alcuni casi può ritornare al sito, perchè è prassi comune fare l'embedded dei contenuti out of social con i social media. In questo caso il circolo è virtuoso perchè in tutto il meccanismo di condivisione si generano delle interazioni con il contenuto stesso (commenti, interazioni istantanee etc). Questo tipo di circolo virtuoso fa sì che il contenuto sulle piattaforme e fuori dalle piattaforme inizia ad avere un determinato impatto sull'utente, ha portato alla consapevolezza ed all'utilizzo di queste piattaforme come monitoraggio per la diffusione di brand contenuto o fenomeni sociali in generale, ha inoltre fatto sì che i dati di diffusione visti all'inizio (tutti telefono e social), i contenuti arrivano a tantissime persone che vengono influenzate ed è più facile che il messaggio relativo al mio business li vada a catturare.

Chapter 3

Social media ed impresa

3.1 Social media e impresa

Visto che i dati di diffusione dei social media sono molto alti, le aziende cercano di veicolare l'informazione tramite i social network perchè arrivano queste informazioni a tantissime persone ed è facile che vengano influenzate. Tutte le aziende applicano strumenti di monitoraggio dei social media perchè risultano ambienti più misurabili rispetto ad altri ambienti. Si cerca di attirare l'attenzione di un utente in un social media per portarlo a fare determinate azioni che comportano dei vantaggi lato business, quindi capire questi processi è fondamentale per definire delle strategie di miglioramento delle attuali strategie in modo da massimizzare la possibilità di catturare l'attenzione dell'utente.

3.2 Social media analytics

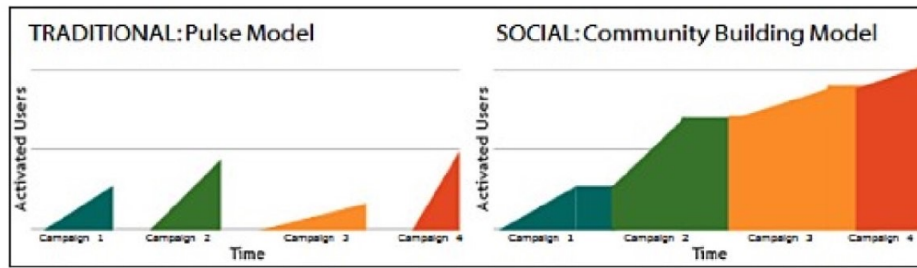
Siamo in un contesto di alta misurabilità e di scarsa standardizzazione di cosa possiamo misurare (non sappiamo bene cosa misurare) ma con scarse metriche per valutare le iniziative di marketing. L'idea iniziale è sempre di riciclare quello che ho già, infatti i primi sistemi di monitoraggio erano quelli classici di web analytics, consideravano la piattaforma social come un classico sistema web (quante volte vedo una pagina, quante volte clicca sul link...), questo però non tiene conto di alcuni trend supportati dalle caratteristiche social:

- Lo spostamento da misure centrate sulla pagina (quante volte l'utente fa qualcosa) a quanto tempo l'utente rimane su quella pagina (metriche di durata). Perchè la singola interazione non è una quantità sufficiente per misurare l'attenzione di un utente riguardo un contenuto. E' tecnologico perchè considera è dato dalla dinamicità della pagina creata con tecnologie come JavaScript (o Ajax).
- Da misurazione click-based a event-based. Se noi pensiamo a come fruiamo del contenuto su una piattaforma (social o no) difficilmente abbiamo un processo one shot, ci sono una sequenza di eventi che mi mantengono ancorato alla piattaforma, posso quindi descrivere le interazioni come sequenza di eventi (clicco su qualcosa di correlato). Si intuisce che conviene usare un approccio event-based per misurare gli eventi e per avere una descrizione più completa del processo di interazione.
- Passaggio da conversion a conversation rate: l'approccio iniziale era quello del conversion rate, ovvero cercare di fargli comprare qualcosa, con l'approccio social in cui abbiamo interazione tra le persone posso creare un contenuto ed una volta che questo arriva sul social questo ha vita propria perchè gli utenti sfruttano le relazioni sociali per mantenere in vita il contenuto. Quanto il mio contenuto genera conversazione ed il fatto che le persone ne parlino mantiene vivo il contenuto stesso ha implicazione su come vengono progettate le campagne di marketing. Questo trend è influenzato dalla parte social.

I primi due sono trend tecnologici, dati dalla modalità di come le pagine web vengono create. Economia dell'attenzione, devo trovare delle metriche che mi permettono di calcolare quanto so catturare l'attenzione di un utente, se ad esempio sto tanto tempo sul video vuol dire che effettivamente è interessato a quel video. La parte social influenza il terzo trend, l'approccio iniziale era quello basato sul conversion rate (ovvero portare l'utente a fare qualcosa). Con l'approccio social in cui abbiamo interazione tra le persone io posso creare un contenuto ed una volta che arriva sul social quello ha vita propria, perchè c'è qualcuno che sfrutta le interazioni sociali per mantenere in vita il contenuto.

Queste caratteristiche cambiano anche il modello di marketing, cambiando dal modello ad impulsi, ogni tanto arriva la pubblicità in televisione, veniamo inondati da quel contenuto, c'è un aumento delle vendite di quel prodotto e non crea nessuna community. Se invece introduciamo delle campagne social rafforziamo il gruppo di supporto in modo tale da mantenere vivo lo zoccolo duro prima della nuova campagna di marketing ed utilizzare la nuova

campagna di marketing per allargare il gruppo di persone che discutono di un determinato brand, il che vuol dire creare uno spazio con quel gruppo e mantenere attiva la discussione in quel gruppo (in alcuni casi la discussione di autoalimenta, in altri c'è bisogno di un social media manager che la spinga). Non è più necessario se costruisco una buona community continuare ad usare tantissime campagne di marketing in media tradizionali.



D'altra parte bisogna stare attenti a non farsi prendere troppo dal social stesso, i dati provenienti dal social media devono essere analizzati con attenzione per non fossilizzarsi troppo sul dato stesso ed in particolare al dato grezzo, quando si sviluppano campagne non bisogna fossilizzarsi sulla metrica interna della piattaforma ma usare i dati estratti dalle piattaforme per usare delle strategie di social intelligence per avere delle raccomandazioni intelligenti invece che massimizzare il numero dei subscriber o delle visualizzazioni, cosa che potrei anche farlo senza avere poi un ritorno economico. Ration per cui nel 2010 Lowet introduce il concetto di social media analytics, cioè analizzare i dati prodotti dai social media all'interno di dinamiche di business ma con un occhio rivolto agli obiettivi del business stesso, non misuro a caso, ma misuro con un obiettivo, quindi sfrutto i dati generati dalle interazioni per migliorare le strategie e raggiungere il 100% degli obiettivi che mi ero prefissato. Quindi l'idea di social media analytics è di analizzare i dati in un contesto di obiettivi di business.

3.2.1 Bisogni analitici

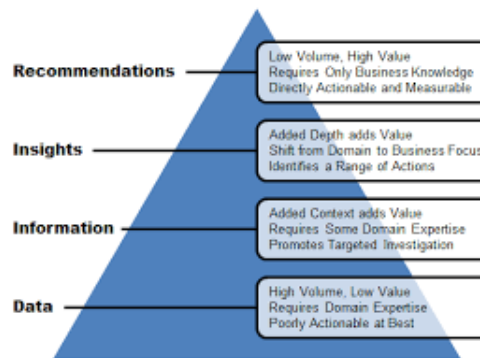
Viene proposta una classificazione dei dati prodotti dai social media, in cui abbiamo una piramide che si sviluppa su due dimensioni:

- Orizzontale: il volume, tantissimi dati a disposizione per i social sia che li vediamo dall'interno o dall'esterno.
- Verticale: chiamata lo sforzo concettuale o analitico, cioè quanto sforzo devo impiegare dal punto di vista analitico concettuale intellettuale per produrre un certo tipo di dato

Partendo dal basso:

- Dati: unità informative grezze, numero di like, retweet etc., tutto ciò che è restituito dalla piattaforma. per questo non si fa un grande sforzo concettuale.
- Informazioni: dei dati a cui aggiungiamo un minimo di contesto, dato dall'analista, da chi fa social media analytics
- Insight: Possiamo introdurre un ulteriore contesto dato dagli obiettivi di business
- Raccomandazioni: in cui diciamo che il volume è risicato però sono frutto di uno sforzo concettuale molto più intenso, in questo caso si forniscono raccomandazioni che costituiscono dei miglioramenti della strategia rispetto agli obiettivi che ci eravamo posti.

Questo dal punto di vista concettuale sono le definizioni date alla piramide dei bisogni.



3.3 Framework per la misurazione

Dobbiamo categorizzare le tipologie di misurazione che si possono utilizzare in un processo di social media analysis.

- Counting metrics: metriche (e dati) specifiche e generate per una singola piattaforma sociale
- Business value metrics: sono metriche comprensibili dagli stakeholder che non sono esperti del dominio, che dicono quanto è stato raggiunto l'obiettivo ma usando un lessico capibili dagli altri responsabili.
- Outcome metrics: ci danno un indicazione quantitativa di quanto abbiamo raggiunto l'obiettivo. Si ispirano alle foundational ma se dobbiamo esprimere un numero lo diamo tramite le outcome (sono quasi le uniche che usiamo). Sono misure che ci forniscono in maniera quantitativa quanto abbiamo raggiunto l'obiettivo (tra 0 e 100 quanto l'ho raggiunto).
- Foundational measures: sono trasversali a tutti i componenti del mio business (marketing, public relation...) che vanno ad ispirare le outcome metrics.

3.3.1 Counting metrics

Non c'è nessuno sforzo concettuale è la piattaforma che ci da un numero e ci teniamo quello. Il vantaggio è che ne abbiamo tanti e tutto quello che c'è sopra si basa su queste metriche. Il principale difetto è che possono cambiare nel tempo e noi dobbiamo adattarci.

3.3.2 Business Value

Un esempio è quanto una campagna social impatta sul fatturato, in questo caso sembra semplice in realtà non è così semplice perchè i fattori confondenti sono molti, per questo quando si imposta una campagna e l'obiettivo è verificare l'impatto sul fatturato va impostata per avere delle condizioni che ne verifichino l'effettivo funzionamento. Un esempio banale è quello di mettere dei coupon all'interno del post, per verificare la provenienza dell'acquisto stesso. L'impatto sulla soddisfazione, si da un sondaggio chiedendo quanto è piaciuta una determinata cosa. Il market share: quant'è la fetta di mercato che ho guadagnato/perso con questa campagna pubblicitaria, mi permette di valutare il trade off di quanto ho investito e quanto ho guadagnato in vantaggio competitivo.

- Impatto sul fatturato: sembra semplice ma in realtà non è così semplice perchè i fattori confondenti sono tanti e dobbiamo avere la sicurezza che una determinata campagna impatti sul fatturato. Va impostata una campagna in modo che possiamo verificare questa cosa, l'esempio è mettere dei coupon all'interno di un post per capire qual'è la provenienza dell'acquisto.

- Impatto sulla soddisfazione: si da un sondaggio in cui si chiede quanto siamo soddisfatti.
- Market share: quant'è la fetta di mercato che ho guadagnato o perso attraverso questa campagna pubblicitaria. E' una misura del vantaggio competitivo che ho guadagnato con una determinata campagna.

3.3.3 Fundamendational metrics

Ricordiamo che stiamo sempre in un contesto in cui c'è un obiettivo di business, ma queste metriche possono essere anche traslate a campagne di social media analytics senza obiettivi di business.

Sono delle metriche generali che valgono per tutte le attività del business e sono quelle metriche che andranno ad ispirare le outcome metrics (quelle più specifiche per il nostro contesto e quelle a cui posso associare un numero).

Sono le metriche fondanti utili a costruire KPI.

- Inteactions: misura della risposta ottenuta a determinati stimoli (commenti, condivisione, link, compilazione modulo), lo stimolo può essere il post o tutto quello che ha la funzione di catturare l'attenzione dell'utente. Qui si misura istantanea l'attenzione.
- Engagement: misura dell'attenzione a partecipazione individuale e' il gradi di coinvolgimento nel compiere un'azione. Si misura sempre l'attenzione ma lo si fa in modo continuativo, cerchiamo di mantenere l'attenzione sul contenuto. Si misura quanto l'utente è coinvolto in un determinato contenuto (la lunghezza dei commenti, il tempo di visualizzazione di un video...), quanto l'utente ha mantenuto l'attenzione.
- Influence: potere di un'azienda o persona di determinare le azioni degli altri. E' difficile la misurazione univoca per come è definita. Questo tipo di proprietà a volte si confonde con l'assortatività della rete sociale, ovvero la tendenza di formare connessioni con persone che hanno gusti simili (una squadra sportiva), dinamiche all'interno di questi gruppi non hanno niente a che fare con l'influenza (ad esempio tutti usano lo stesso paio di scarpe).
- Advocacy: misura la capacita' di un brand di essere così amato ad indurre utenti a creare buzz, promuovere iniziative o prendere le difese. Capacità di un brand di essere così amato fino a tal punto da indurre gli utenti a promuovere il brand.
- Impact: abilita' di una persona di determinare il risultato desiderato di un'attività'. Misurare quanto una persona e' centrale in un progetto di marketing, senza di lui una campagna avrebbe avuto un risultato meno eclatante.

Quelle che ci interessano di più sono i primi 4, mentre l'impatto è poco utilizzato.

3.3.4 Outcome metrics

Dobbiamo quantificare quanto siamo vicini all'obiettivo di marketing. Nel contesto di social media analytics gli obiettivi più comuni sono:

- Incrementare visibilità: è un obiettivo base
- Incoraggiare il dialogo: si rifà ai trend specifici dei social media, creare interazioni tra utenti toccati dal messaggio che sto veicolando attraverso i social, creare la community tipica del community building model
- Generare Interazioni: se genero interazioni si ripercuotono sul generare dialogo, cerco di mantenere l'attenzione della mia community sul brand.

- Facilitare il supporto: ci serviranno una serie di metriche per capire dove supportiamo gli utenti
- Promuovere l'advocacy: dobbiamo misurare e quantificare quanto riusciamo a promuovere l'advocacy
- Stimolare l'innovazione: è un obiettivo fumoso in se, dobbiamo capire cosa significa innovazione.

Incrementare la visibilità

L'obiettivo è che dato un momento iniziale, devo avere dei dati iniziali, devo aumentare il numero di persone che vengono a conoscenza del messaggio, iniziativa, prodotto o brand. Quindi nel concetto di incremento di visibilità abbiamo sempre un istante t_0 in cui inizio la misurazione. Significa che gli strumenti a supporto devono essere progettati prima di fare la misurazione. Dobbiamo avere omogeneità della metrica utilizzata, dobbiamo usare sempre la stessa metrica con lo stesso strumento di analisi. C'è una difficoltà nel caso dei SM perchè entrano in gioco meccanismi non deterministici dati dalla natura stessa dei SM, un messaggio ad un certo punto si riproponga senza che chi ha gestito il messaggio all'inizio faccia qualcosa, sono effetti definiti di ECO, vengono riproposti dei messaggi.

Il primo KPI (la prima misura) che utilizziamo per misurare l'incremento di visibilità (è lo strumento che usiamo per misurare effettivamente), la REAHC che indica il pubblico esposto ad un messaggio o attività (pubblico inteso come utenti unici), l'obiettivo quindi è misurare l'unicità degli utenti, è difficile perchè è un casino confrontare due account di due SM diversi per capire se sono della stessa persona o no. La reach usa i dati di diverse piattaforme, perchè la reach di un SM solo è fornita direttamente dal social. Si può fare un'approssimazione, dato un contenuto sommiamo i visitatori unici nel caso il nostro messaggio parta da un applicazione esterna dal social network poi quante volte il contenuto è stato pubblicato (condiviso) su una piattaforma (nel nostro caso lo share su facebook) per 180 che è il numero di amici medi su Facebook, lo stesso lo facciamo su Twitter ma gli amici medi sono 126 (ha senso fare questa moltiplicazione perchè facciamo una stima di quante persone possono essere esposte dal contenuto).

I limiti sono:

- Gli algoritmi moderni dei social network non rendono visibile il nostro post a tutti i nostri amici, ma fa una selezione.
- Si assume che i nostri amici siano attivi al momento della condivisione, perchè per come è gestita la timeline non è detto che tutti gli amici vedano il contenuto.
- Problema del matching, essendo additiva sto assumendo che le persone visitatori unici non si sovrappongono con la cerchia di amici in Twitter e Facebook, in realtà per la questione di affinità è probabile che due amici su Facebook vedano gli stessi contenuti anche fuori da Facebook.

Quindi questa formula della reach è un limite superiore a quella che può essere una reach reale.

Un'altra metrica utilizzata per valutare l'incremento di visibilità (in realtà non è collegata ad una variazione, ma è una componente che entra in gioco se la pensiamo collegata ad un aggiornamento simultaneo è una proprietà detta **Half-life time**, è legata al social e determina qual'è la velocità di diffusione di un contenuto, in particolare è il periodo di tempo in cui un contenuto ottiene la metà dei click. E' difficile da misurare, dobbiamo usare bit.ly (url shortner), dato che il provider del servizio riceve l'url da far tornare lungo noi possiamo vedere il numero dei click, possiamo quindi misurare il tempo in cui ottengo la metà dei click. Sappiamo che l'half-life time è di circa 2 ore per Twitter e Facebook, per quanto riguarda YouTube è di circa 7 ore, vuol dire che su YouTube ci metto di più ad arrivare a metà dei

click (ha un tempo di diffusione più lento). Questo ha impatto sulla modalità con cui dovrei creare del contenuto, avendo un tempo di vita più corto posso pensare di rimandare lo stesso messaggio per rinnovare lo stimolo, su YouTube invece non ha senso farlo perchè il tempo di diffusione è più lento.

Un ulteriore metrica che riguarda l'aumento di visibilità viene definita come **share of voice**, viene definito come misurazione del volume di citazioni di un brand rispetto alle citazioni dei brand concorrenti. Come per le altre misure posso sia mantenere l'informazione aggregata (combinare le varie piattaforme) oppure fare un'analisi per ogni piattaforma che sto usando. Passi essenziali per restituire lo share of voice:

- Identificare i competitor, può farlo il social media analyst oppure è la stessa società che ce li propone
- Utilizzo di determinate piattaforme o strumenti per calcolare il volume di citazioni di un brand
- Associare il brand ed i concorrenti su keyword sulla stessa piattaforma che mi permettono di misurare effettivamente il numero di citazioni. Devo reare delle 'Query' per catturare effettivamente il volume di citazioni.

$$\frac{MenzioniBrand}{MenzioniBrand + MenzioniCompetitor1 + \dots + MenzioniCompetitorN}$$

Questo è utile all'inizio se fare una campagna oppure quale campagna fare (oppure copiare la campagna di altri che hanno avuto successo). Posso fare lo share of voice istantaneo oppure continuare a farlo, quest'ultima opzione mi permette di costruire un trend degli share of voice dei competitor e del mio. Sapere lo share of voice periodico dei competitor mi permette di capire qual'è il periodo in cui inserirmi per fare pubblicità.

Può anche essere applicato in un contesto di meccanismi di alerting, mi focalizzo sul mio share of voice ed in particolare si mette un valore di soglia sotto la quale implementiamo delle strategie per farla risalire. Esiste un'altra reciproca funzione che è quello di monitorare una crescita improvvisa dello share of voice, in questo caso il meccanismo di alerting si può relazionare ad una crisi del brand, o meglio merita un'analisi più approfondita il picco.

Incoraggiare il dialogo

Per misurare questo obiettivo abbiamo due KPI: **l'engagement**: misura la capacità di coinvolgimento generata da attività specifica in un periodo Δt . Abbiamo il numero di commenti più il numero di condivisioni più il numero di menzioni di blog (o web) fratto le visualizzazioni totali.

$$\frac{commenti(\Delta t) + condivisioni(\Delta t) + menzioniDaBlog(\Delta)}{visualizzazioniTotali(\Delta t)}$$

Se è basso vuol dire che in tutte le azioni in cui è richiesta interazione del utente (potrei anche fare una somma pesata) vuol dire che tutti hanno visto il contenuto ma quel contenuto non ha generato nessun meccanismo di dialogo. Questa formula è modificabile cambiando le azioni che vogliamo considerare, ad esempio potremmo considerare la lunghezza di un thread.

Ampiezza delle conversazioni è una moltiplicazione tra reach ed engagement (come se prendessi l'engagement e togliessi il denominatore).

$$reach \cdot engagement = ampiezzaConversazioni$$

L'engagement mi serve per fare una targhettizzazione della audience, posso identificare le persone che creano engagement che può essere l'heater, mi serve per identificare le persone che agiscono da diffusori e promotori di dialogo nella community.

Generare interazioni

Dobbiamo misurare l'attenzione, creare contenuto che catturi l'attenzione dell'utente. Uno dei meccanismi è esporre l'utente ad una call to action (contenuto che lo spinge a fare qualcosa) un esempio classico è la registrazione ad un sito, trasformare gli utenti passivi in utenti attivi che interagiscono con la piattaforma. La prima metrica **tasso di interazione** viene valutata come persone che iniziano il processo fratto persone esposte alla call to action.

$$\frac{\text{persone Che Iniziano Il Processo}}{\text{persone Esposte Alla Call To Action}}$$

E' un KPI piuttosto old style, tipico dei meccanismi click base.

Più informativa è il **conversion rate**:

$$\frac{\text{Persone che completano il processo}}{\text{Persone esposte alla call to action}}$$

Facilitare il supporto

Ci sono una serie di misure che sono proprie del customer care che valgono a prescindere dai social: **Tasso di risoluzione dei problemi**

$$\frac{\text{problemi risolti con successo}}{\text{totale problemi sottoposti}}$$

Tasso di non risposta, la percentuale di domande a cui non si risponde

$$\frac{\text{domande a cui non si risponde}}{\text{totale domande ricevute}}$$

tempo di risposta alle richieste, nel caso di social media è importante, perchè con il fatto di essere il luogo in cui si interagisce (immediati) genera un'aspettativa sul tempo di risposta per le richieste sui social, quindi abbassare il tempo medio tra richiesta di aiuto ed aiuto rappresenta una cosa da misurare. Si può fare anche da esterni calcolando il tempo medio di risposta attraverso le API delle varie piattaforme.

net promoter score è una modalità di valutazione del supporto dato, è il classico score utilizzato dai call center che ci chiedono di dare una valutazione da 1 a 10 se siamo stati soddisfatti del servizio. Si fa un rapporto tra ciò che sono i promotori (le persone che danno 9 o 10) meno i detrattori (le persone che danno un voto da 1 a 6) i neutrali (voti 7 o 8) non vengono calcolati. Anche in questo caso l'analisi può essere fatta stratificata (per persona, per team, per singola piattaforma...).

Promuovere l'advocacy

In questo caso è difficile misurare quanto un elemento contribuisca alla promozione dell'advocacy di un brand e si può implementare qualcosa di quantitativo quando ci sono programmi di ambasciatori o di fidelità (Microsoft evangelist) in questo caso posso verificare quanto i vari programmi di ambasciatori funzionano facendo un rapporto tra i membri ed il numero di partecipanti al programma

$$\frac{\text{\#membri attivi}}{\text{\#partecipanti al programma}}$$

Oppure si può definire un indice di influenza.

Stimolare l'innovazione

In questo caso si devono creare delle situazioni misurabili in cui posso dare delle quantità ai vari elementi che compongono le varie formule, solitamente questo tipo di obiettivi hanno un relativo strumento di supporto (esempio dei lego, innovazione è utente che propone un nuovo lego set, all'interno di un sito ho una serie di meccanismi per valutare i vari set).

Valutazione esterna ai clienti è chi gestisce lo spazio che valuta la pertinenza delle idee (o il brand):

$$\frac{\#idee\ pertinenti}{\#idee\ totali}$$

Valutazione dei clienti, possono essere gli utenti a valutare le idee nuove:

$$\frac{\#idee\ più\ apprezzate}{\#idee\ totali}$$

3.4 Social Media Listening

Ci mettiamo in un'ottica diversa rispetto al social media analytics, perchè nel caso precedente avevamo già una campagna in atto ed andavamo a misurarne gli effetti, in questo caso è un passo precedente alla creazione della campagna in cui vado ad affrontare una serie di attività preliminari che mi permettono di avere un'idea di qual'è lo scenario su cui progettare la campagna di social media. Implementiamo quindi una serie di strategie che sono di identificazione di qualcosa:

- Mappatura dei territori: quali sono le piattaforme più consone al messaggio o al brand di cui mi occupo
- Identificare gli influencer nei territori
- Relazioni che si instaurano tra le persone che vivono nei territori

In queste piattaforme implementare diverse strategie di comunicazione per il brand. Questi concetti vengono utilizzati anche in altri approcci riguardanti l'uso dei social media che non utilizzeremo, che sono quelli di computational social science, cioè utilizzare tutto quello che c'è nei social per quantificare i problemi o contenuti della società in generale, è un approccio che utilizzeremo nell'ultima parte relativa a bot e misinformation. Vogliamo definire questa attività di monitoraggio (preliminare alla definizione di una strategia marketing su un SM), l'obiettivo è dare delle raccomandazioni (indicazioni) in modo tale da definire una strategia efficace.

Dal punto di vista delle definizioni per social media listening si intende una serie di processi per il monitoraggio che ci permettono di implementare i quattro punti visti prima:

- Comprendere i territori in cui ci sono delle interazioni con il brand, i territori sono i social media o i forum e blog. Dobbiamo anche capire le dinamiche della piattaforma, ovvero cosa la piattaforma mette a disposizione e cosa gli utenti usano veramente.
- Individuare le persone che discutono di prodotti e servizi, dei concorrenti e dei bisogni legati al prodotto. Bisogna anche capire che caratteristiche demografiche hanno, è una sorta di analisi del possibile pubblico che riceverà il messaggio.
- Fase di misurazione delle conversazioni

Tutto questo mi porta ad avere delle raccomandazioni per identificare degli obiettivi. Nel processo di social media listening esistono delle fasi comuni che vanno ad identificare una serie di passi che devo implementare per avere una procedura di listening efficace.

3.4.1 Definire gli obiettivi

E' una fase preliminare e c'è una forte correlazione con gli obiettivi di business del brand. Quali sono gli obiettivi:

- Scoperta dei territori: dove c'è interesse nel brand
- Analisi delle conversazioni relative ad un brand ed i competitor
- Valutazione delle iniziative di marketing
- Migliorare il servizio di customer care

Il concetto fondamentale è che il social media listening viene applicato prima di definire una strategia sul social stesso.

3.4.2 Selezionare le fonti

Nel caso di social media listening è una parte complessa perchè la tipologia di social cambiano molto spesso così come l'audience di riferimento nei social. La scelta più dispendiosa è quella di fare monitoraggio completo di tutte le piattaforme perchè devo usare dei volumi di dati enormi in più devo continuamente aggiornare le fonti che voglio monitorare, in più se faccio analisi di tipo massivo la maggior parte dei dati sono molto numerosi. Quindi in questa fase rientrano in gioco la classificazione vista all'inizio dei social media e la storia dei social media perchè rientrano quelle forme di web 1.0 che erano dati dai forum, blog e siti web, infatti in questa fase posso considerare anche loro come elemento da monitorare (perdendo tutto il discorso di interazioni). Se mi accorgo che tutte le tipologie di fonti sono poco social tanto vale abbandonare l'idea di utilizzare una strategia orientata sui social media.

Altre fonti:

- Social network generalista: c'è tanto rumore nei dati
- Social network tematici o funzionali: la differenza è che qui c'è poco rumore nei dati
- Wikipedia: per vedere se il nostro brand è diventato citato anche in altre situazioni in cui solitamente non troverebbe spazio
- Q&A: Yahoo Answer, Quora

Nella fase di selezioni quali sono i criteri da utilizzare:

- Tematico: seleziono in base al tema del mio business
- Rilevanza: quanto è rilevante una fonte rispetto al mio tema
- Lingua: qual'è la lingua da monitorare
- Temporale: il range temporale su cui applicare la procedura di listening

3.4.3 Recuperare i dati

E' quella che ha ripercussioni pratiche, qua si inizia a scrivere codice di interfaccia con altri servizi. Come faccio a recuperare i dati che mi servono:

- Data scraping: metodologie che non richiedono il permesso della piattaforma per collezionare dati, ma sfruttano il fatto che le piattaforme usano HTML, CSS, JS. Estraggo le informazioni dalla pagina web.
- Accesso API: interfacce definite dalla piattaforma con delle risorse che mettono a disposizione per ottenere i dati

- Acquisizione di feed RSS: formato XML like del dato, poco usato
- Esportare i dati: nel caso si ha profilo di analytics possiamo avere le counting metrics di tutti i contenuti che produco. I dati sono limitati a quello che la piattaforma mi vuole rilasciare.

3.4.4 Analisi dei dati

Ho una serie di approcci che sono di tipo:

- Quantitativo: prendo le metriche di conteggio e costruisco delle informazioni per dare insight. Valuto il trend delle dinamiche che sto valutando (inserisco il tempo) e le confronto con i trend dei competitor in modo da capire quando fare una determinata campagna
- Qualitative: circa il sentiment che ha chi dialoga con il brand e posso utilizzare degli strumenti di sentiment analysis che possono essere manuali (è l'analista che fa le sue valutazioni), automatici o semi-automatici

Ci permette di dare anche una prima indicazione di quali sono i luoghi in cui si parla del nostro brand e quali sono le persone che possiamo considerare opinion leader circa le interazioni che coinvolgono il nostro brand.

3.4.5 Reporting

Creare un report che sia comprensibile anche da chi non è un esperto e possono essere utilizzati anche per task paralleli: sistemi di alerting, reportistica giornalieri (rassegna dei tweet che parlano del brand)

3.4.6 Proposte di azioni

C'è sempre la parte di proposta delle azioni, cosa poter migliorare in modo da aumentare il raggiungimento dell'obiettivo oppure proporre delle innovazioni. Abbiamo obiettivi di tipo data driven.

Chapter 4

Social media API

La maggior parte dei social media online utilizzano il concetto di API (application programming interface), rappresenta l'idea attraverso cui due entità si scambiano informazioni. E' un concetto che viene definito nell'ingegneria del software, qualsiasi metodo di una funzione è un API perchè espone dei dati per l'architettura del software. Anche in mobile computing usiamo delle API che permettono di interagire con l'OS del device ed anche con altri servizi web in modo da integrare le informazioni che abbiamo sul device con informazioni esterne, l'esempio è la geolocalizzazione. La piattaforma mette a disposizione delle risorse, che diventano degli URL i quali permettono di chiedere delle risorse e l'applicazione (se rispetto le condizioni esposte dall'API) mi restituisce dei dati. Una volta che ho il dato posso fare monitoring, listening, mining etc. Ovviamente anche in termini di computational social science (teorie sociologiche con dati social).

4.1 RESTFULL API

Quando ci si interfaccia con le API ci si scontra con una serie di problemi, perchè ogni piattaforma rilascia risorse specifiche per quella piattaforma (non posso chiedere a Facebook i tweet di una persona), tuttavia come ci si approccia alle API e le fasi preliminari sono abbastanza standard, questo perchè in realtà la maggior parte delle piattaforme social utilizza delle API RESTFUL, ovvero associano ai metodi del protocollo HTTP a delle operazioni di creazione, lettura, aggiornamento e cancellazione (CRUD). In sostanza, a parte la concettualizzazione di restful, si tratta di fare richieste HTTP e poi sarà la documentazione della piattaforma a specificare quali sono le richieste ed i metodi HTTP.

Quindi la classica interazione è: ho l'applicazione che richiede ad una piattaforma i dati, la quale mette a disposizione una serie di endpoint (URL) richiedibili attraverso HTTP (get nome dell'endpoint versione del protocollo), quello che ottengo è una risposta HTTP, il cui formato può variare (JSON, HTML, XML..), questa risposta è la formattazione della risorsa che ho richiesto. Il nostro scopo :

- Capire quali sono le risorse
- Capire quali sono gli URL per richiedere le risorse
- Capire qual'è il formato con cui la piattaforma mi ritorna la risorsa

Le due caratteristiche principali dell'informazione che ottengo:

- E' statica: è una fotografia della risorsa nel momento in cui sto facendo la richiesta
- Posso avere l'evoluzione della risorsa fino al momento della richiesta

I due metodi di riferimento sono:

- Get per ottenere informazione
- Post per inserire o modificare le risorse nella piattaforma

STREAM è una modalità di implementazione diversa delle API in cui si può usare il protocollo HTTP mantenendo aperta la connessione (nell'header c'è il valore `connection keep alive`) oppure utilizzando web socket (veniva usata da Twitch per gestire la chat). Restful api ho una visione sul passato, stream api ho una visione sul futuro (nel senso che quando faccio una richiesta ricevo tutti i dati che verranno emessi).

4.2 Vantaggi

- Ottengo i dati social degli elementi della piattaforma

- Meno problemi di privacy, perchè i dati sono frutto di un patto tra gli utenti e la piattaforma stessa, ci sono termini di servizio che ne regolano l'accesso (tra utenti e piattaforma, tra piattaforma ed utilizzatori di api)
- Facilmente integrabile per lo sviluppo delle applicazioni, rispetto al data scraping
- Posso integrare in soluzione di analitic che sono attive, postare qualcosa sulle piattaforme stesse per automatizzare le attività di marketing

4.3 Svantaggi

Ci sono una serie di vincoli:

- Rate Limit: vengono imposti dei limiti riguardanti quanto dato posso accedere e quanto frequentemente posso accedervi
- Cambiamenti API: gli endpoint e le modalità di accesso cambiano quasi ogni anno
- Aspetti Legali: ci sono regolamentazioni stringenti dati dai termini di servizio della piattaforma e regolamentazioni sulla privacy. Siamo soggetti al GDPR.

4.4 Connessione a API

Abbiamo detto che il panorama delle social media API è ampio e vario, però ci sono alcuni processi che sono comuni a tutte le API, in particolare riguardano il processo di attivazione dell'utilizzo delle API:

- Registrazione dell'applicazione: è il software che stiamo scrivendo che ci serve per implementare un processo di social media analytics che ci serve per ottenere del dato. E' la piattaforma che definisce un processo per creare un'applicazione. Durante la fase di registrazione la piattaforma ci restituisce due chiavi: authentication e consumer keys (come se fossero user name e password dell'applicazione).
- Autenticazione: uso le chiavi per fare l'accesso
- Caccia agli endpoint: ci obbliga ad interagire con la documentazione della piattaforma

Una volta fatto questo si può sviluppare un processo di social media analytics passando da un elemento centrale nello sviluppo implementativo che è il protocollo OAuth 1.0 e 2.0.

4.5 Esempio API Twitter

Abbiamo due stringhe pseudocasuali:

- Client id: user name
- Client secret: password

Che otteniamo creando un'applicazione sulla piattaforma di Twitter.

4.6 OAUTH 2.0

La maggior parte delle piattaforme utilizza il protocollo OAUTH per regolamentare l'accesso ai dati. Noi abbiamo un dato questo si riferisce ad un utente che ha salvato il suo dato sulla piattaforma social, la modalità più stupida per accedere al dato dell'utente è chiedere l'accesso all'account dell'utente, è stupida dal punto di vista dell'utente perchè non va condivisa la password per questioni di impersonificazione. Per ovviare a questa modalità (consegnare le credenziali ad un applicazione terza) viene implementato il protocollo OAUTH. Ragion per cui OAUTH viene considerato un framework di **autorizzazione** (non autenticazione) che permette ad un applicazione di terze parti ad una risorsa posseduta dal proprietario e depositata presso un servizio HTTP. Ci posso accedere come se fossi il proprietario quando questo mi da il permesso di farlo, ma ho uno spazio di azione in base alle concessioni che mi ha dato l'utente. Esiste un ulteriore modalità in cui non è necessaria l'autorizzazione esplicita da parte del possessore delle risorse ma è l'applicazione che può accedere a delle risorse perchè l'utente ha accettato i termini di servizio in cui da il permesso ad accedere alle sue informazioni pubbliche.

Un altro motivo per cui non si utilizza la consegna della password è perchè si divide il flusso del possessore delle risorse con quello dell'applicazione. Se ad esempio l'utente cambia tante volte la password l'applicazione deve ogni volta richiedere la password.

4.6.1 Ruoli

In OAUTH ci sono dei ruoli ben specifici:

- Proprietario della risorsa - PR: è l'utente che concede l'accesso ad una risorsa in suo possesso. Ovviamente l'ha creata e depositata (il tweet è una risorsa e l'account che l'ha creato è il proprietario).
- Server delle risorse - SR: il server che memorizza le risorse (i tweet)
- Server di autorizzazione - SA: il server che gestisce il processo di autorizzazione. Quando abbiamo bisogno di autorizzazioni dobbiamo per forza passare da qui. E' anche il cancello di ingresso che usiamo quando dobbiamo chiedere qualcosa, va a verificare che abbiamo i permessi per accedere alla risorsa che vogliamo
- Client - C: è l'applicazione che richiede l'accesso a risorse protette per conto del proprietario della risorsa da cui ha ottenuto l'autorizzazione

Il ruolo centrale lo hanno il server delle risorse ed il server di autorizzazioni, tant'è che molto spesso coincidono.

4.6.2 Access Token

Tutto il protocollo si risolve nell'ottenere questa entità, è una stringa (che può sembrare casuale) e contiene in sé le autorizzazioni che il proprietario delle risorse ha dato al client, per quanto tempo il client può avere accesso alle risorse ed i permessi che SA ed SR devono garantire. Ovviamente non ho una modalità per cui data la stringa ottengo queste informazioni è un'astrazione, quando il server di autorizzazione riceve questa stringa diventa una specie di matricola, quando il client si presenta al server di autorizzazione questo prende l'access token, verifica che sia associato al proprietario dei dati che l'applicazione sta richiedendo e che l'access token non sia scaduto.

Una volta che abbiamo l'access token il client può fare quello che vuole nei limiti dei permessi che il proprietario ci ha dato (scope dei permessi).

4.6.3 Authorization Grant

Come faccio ad ottenere l'accesso token. Il protocollo definisce 4 modalità con cui ottenere l'access token:

- Authorization Code
- Implicit: in questo caso l'access token è contenuto nel client (nell'applicazione di Twitter ad esempio), non è necessario il fatto che l'applicazione si autentichi presso il server di autorizzazione. Esiste ma non è utilizzato.
- Resource Owner Password Credentials: questo flusso chiede che l'utente inserisce user name e password. Non viene utilizzato.
- Client Credentials: in questo caso non c'è il proprietario delle risorse (il ruolo che manca), viene verificato il fatto la mia applicazione sia effettivamente della piattaforma, c'è un meccanismo di autenticazione dell'applicazione, poi posso accedere ad alcune risorse (le risorse pubbliche). Evito il proprietario delle risorse, nel senso che non devo ottenere le sue autorizzazioni, perchè le ha già esplicitate nell'accettazione dei termini di servizio del social.

4.6.4 Client

Diamo qualche dettaglio sull'applicazione. Innanzitutto c'è una fase di registrazione (come abbiamo visto per Twitter), esistono due tipi di client:

- Confidenziale: le informazioni, le credenziali, sono mantenute in un luogo sicuro. L'applicazione si fa garante che il client ID ed il client secret non sono accedibili pubblicamente
- Pubblico: le credenziali dell'applicazione sono accessibili a tutti

Il client è sicuramente definito da un client ID che è un informazione pubblica e quindi può essere esposta al proprietario delle risorse. Ovviamente essendo pubblico non dev'essere l'unica modalità per autenticare l'applicazione, si accompagna quindi al client secret (la password). Ultimo aspetto è il fatto che se il client è confidenziale (credenziali non accessibili pubblicamente), il protocollo, il server di autorizzazione, può richiedere l'autenticazione dell'applicazione usando HTTP basic authentication.

4.6.5 Endpoints

Qui si sta parlando di URL:

- Authorization endpoint, reso disponibile dal server di autorizzazione
- Token endpoint, reso disponibile dal server di autorizzazione
- Redirection endpoint, reso disponibile dal server dal client

4.6.6 Authorization grant code

Analizziamo questo flusso di autorizzazione, l'obiettivo finale di implementare un flusso di autorizzazione è ottenere l'access token. Lo dividiamo in due fasi:

- Il mio utente clicca su un bottone che fa una richiesta get analyze, viene implementata sulla mia applicazione che ne fa un redirect, l'applicazione genera come risposta un http redirect. Quando abbiamo una redirect l'elemento fondamentale nell'header per capire qual'è la prossima pagina da richiedere è l'elemento **location**. Il browser estrae l'url associato al location e fa una richiesta di tipo GET, mettendoci dei parametri richiesti:

- Response type: obbligatorio, = code implica che sto seguendo un flusso di tipo authorization grant code
- Client ID: obbligatorio, devo comunicare al server di autenticazione chi sono
- Redirect URI: opzionale, è un URL che troveremo più avanti
- State: consigliato, meccanismo di verifica

Attraverso questa richiesta sto chiedendo all'utente di accedere i suoi dati. Adesso il server mostra all'utente un form di login ed un form di autorizzazione perchè l'utente deve accettare di concedere i permessi che l'applicazione ha richiesto. Il server invia una richiesta di redirect al browser e questa richiesta contiene:

- URL scritto nel redirect URI associata al campo location

In sostanza l'applicazione ha reso disponibile un URL che sfrutterà per ricevere dell'informazione inviata dal server di autorizzazione, che va comunicato al server di autorizzazione perchè poi lì deve dirci che l'utente ha accettato. Quest'ultima redirect contiene come parametro code, il valore associato a questa stringa code viene chiamato authorization grant code che è l'elemento che utilizzeremo nella seconda fase. Quindi lo scopo della prima fase è ottenere un authorization grant code che non è l'access token, che l'applicazione usa come merce di scambio per ottenere nella fase numero 2 l'access token.

- Una volta che ho l'authorization grant code lo devo scambiare per ottenere l'access token. Lo chiedo al token endpoint, che è un URL che mi permette di scambiare l'authorization grant code con l'access token, in questo caso il metodo POST è obbligatorio. Quando faccio questo tipo di richiesta devo fare HTTP basic authentication, passo:
 - Grant type = authorization code, è sempre cos'
 - Code, che è l'authorization grant code che ho ottenuto al passo precedente

L'autentication server prende la parte relativa all'autenticazione e fa l'autenticazione dell'applicazione, eventualmente controlla che il redirect URI sia uguale al redirect URI sia uguale a quello comunicato nella fase precedente (ulteriore processo di verifica dell'identità del client), poi verifica che il code che ha ricevuto è stato effettivamente assegnato a quell'applicazione. Se tutti le condizioni sono vere ottengo una risposta in formato JSON con dei campi obbligatori:

- Access token
- Token type: stringa bearer
- Quanto dura l'access token
- Refresh token che posso usare per ottenere un nuovo access token quando scade

L'essenza sono le due fasi, nella prima ottengo un codice temporaneo che mi serve come merce di scambio per ottenere nella fase numero due l'access token.

Se voglio implementare HTTP basic authentication (autenticarmi tramite HTTP), devo prendere user name concatenarlo con i due punti e concatenarlo con la password e codificare le chiavi secondo base64. Tutta questa stringa deve essere comunicata al server di autenticazione concatenandola con la stringa basic, associato all'header http authorization.

4.6.7 Client Credential Grant

E' il secondo flusso che vediamo. L'elemento distintivo è che non abbiamo il proprietario delle risorse, dobbiamo sempre ottenere l'access token. Abbiamo sempre la HTTP basic authentication obbligatorio e grant type dev'essere uguale a client credential perchè è l'unico

modo per capire che stiamo seguendo un flusso client credential. Questo è il modo con cui l'applicazione comunica che tipo di flusso vuole istanziare con il server di autorizzazione. Dobbiamo autenticarci sul server di autenticazione, dopo ottengo direttamente l'access token che contiene i vari permessi ed in particolare notiamo che contiene solo i permessi di lettura.

4.6.8 Accesso ad una risorsa protetta

Il punto di unione è come andare a fare una richiesta una volta che abbiamo l'access token. Facciamo una richiesta GET mettendo nell'header HTTP come valore di authorization : bearer + access token (l'access token che abbiamo ottenuto).

Chapter 5

Web Scraping

E' l'alternativa all'accesso ai dati rispetto alle social API e prevede la costruzione di un agente software che si occupa del download, parsing e strutturazione delle pagine web. Solitamente le pagine web vengono considerate dati non strutturati, quindi dobbiamo dare una struttura al dato. Ovviamente rispetto alle social media API non avendo il concetto di documentazione è più un'arte, il che richiede un po' di training e creatività, perchè sostanzialmente si fa reverse engineering quando si fa web scraping e dato che si usano pagine dinamiche questa operazione può essere complicata. Quando si usa:

- Quando non ci sono le API
- API non sono gratuite
- API hanno un basso rate limit, anche se dobbiamo ricordarci che hanno implementato un rate limit anche per IP
- API non rendono disponibile tutti i dati necessari allo scopo

Se decido di usare metodologia di web scraping devo avere in mente dei protocolli alla base:

5.1 HTTP

HTTP, perchè tutte le richieste fatte dalle piattaforme passano da HTTP. Devo capire quali sono le richieste HTTP che mi permettono di ottenere del dato. In una richiesta HTTP devo mettere per forza la riga di intestazione e mettere solo l'header host, tutto il resto non è obbligatorio. Ci sono dei campi che però sono sempre utilizzati quindi rientrano anche nelle librerie di alcuni linguaggi di programmazione:

- Connection
- User agent
- accept

La replay: riga di intestazione, header, spazio vuoto, risposta.

In python usiamo la libreria requests per fare richieste HTTP, lo facciamo per ottenere il codice sorgente di una pagina, che è sempre il primo processo da fare durante il web scraping. Nel processo di scraping ho la necessità di accedere a tutte le informazioni della richiesta e della risposta, perchè mi possono aiutare per identificare ad esempio meccanismo di accesso limitato alle risorse. Le prime informazioni da utilizzare sono, dato una risposta lo stato di quella risposta, noi lo facciamo accedendo alle proprietà con notazione puntata `status_code`. Posso accedere al messaggio ed agli header della risposta con `.headers`. Ricordiamoci che è importante far sembrare che lo user agent sia un browser web classico, altrimenti molti filtri ci bloccano.

5.2 HTML e CSS per il Web Scraping

CSS viene utilizzato solamente come linguaggio di selezione. Un altro elemento fondamentale è HTML che definisce una struttura del documento utilizzando dei tag, quando un documento HTML è formattato nella maniera corretta (tutti i tag vengono chiusi) viene usata una struttura ad albero per rappresentare il documento in cui ho il tag `html` come radice, dopo di che una serie di figli (solitamente `head` e `body`). I linguaggi che andremo a vedere (CSS ed `xpath`) sono per definire percorsi all'interno di un albero HTML.

5.3 Utilizzo del browser per il web scraping

Ci interessa andare ad utilizzare gli strumenti di sviluppo del browser perchè ci forniscono i dettagli da sfruttare per generare del codice che automaticamente fa richieste. Processo:

- Analizzare struttura della pagine e richieste della pagine
- Analizzare richieste http
- Quali elementi vengono usati nelle richieste http
- Identificare tutte le informazioni necessarie per fare una richiesta al server ed ottenere il dato che mi interessa

Il dato mi può arrivare in due modi:

- JSON, se sono fortunato, verrà utilizzato da javascript e viene visualizzato nella pagina
- Il server restituisce un documento HTML, che ha una certa struttura ma non ha l'informazione immediatamente accedibile come un JSON, quindi avrò bisogno di una serie di linguaggi di selezione per selezionare dei tag e da questi tag prendere il dato.

Noi utilizzeremo i developer tool del browser per:

- Analisi della struttura della pagina in termini di tag html
- Vedere quali sono le richieste HTTP che vengono generate dal browser e dovremmo replicare noi
- Utilizzeremo la console per fare un po' di testing sui linguaggi di selezione

5.4 CSS

Seleziono un tag scrivendo il nome del tag. Molti dei tag contengono degli attributi, se voglio selezionare un attributo di una classe è `.nomeclasse`, se voglio selezionare un tag identificato da id è `#id`. Posso combinare i selettori, se voglio selezionare una cosa o un'altra si usa la virgola, se ad esempio voglio selezionare il div con classe footer si fa con `div.footer`. Se voglio selezionare tutti i li dentro un tag div si fa `div li`. Più specifico è `div > li`, in questo caso applico la selezione solo sul figlio restituito dalla prima selezione di div.

`li + li`, seleziono il tag li ed il secondo li è il fratello successivo.

`li tilde li`, ricerco in tutti i fratelli successivi (a destra del livello) identificati dal selettore 1.

Posso anche utilizzare ulteriori filtri sugli attributi. la sintassi è del tipo `tagname[nomeAttributo]` ed eventuali operatori, che controllano che l'attributo selezionato abbia uno specifico valore.

5.5 Modificare header HTTP

Uno dei primi vincoli implementati dai server per limitare gli accessi è accettare richieste ricevute solo da client molto utilizzati, è semplice baipassarlo, si sovrascrive l'header `http` relativo allo user agent.

Bisogna anche verificare se c'è un controllo sul campo `referer`, perchè ci sono dei siti in cui devo fare un percorso forzato per arrivare ad una certa pagina, il controllo si fa con il campo `referer` dell'header `http`. Dobbiamo quindi andare a sovrascrivere il campo `referer`.

5.6 JavaScript e Selenium

La dinamicità delle pagine è una criticità per chi fa webscraping perchè oltre a modificare la struttura di un documento può anche fare richieste HTTP. E' difficile fare il processo di reverse engineering, soprattutto quando il codice viene offuscato, quando è troppo difficile fare questo processo si utilizza selenium, è una funzione di web automation e testing perchè posso usarlo per verificare che le sequenze di azioni previste per la pagina web siano effettivamente valide. Noi possiamo utilizzare lo stesso concetto nel webscraping, perchè stiamo replicando il comportamento di un utente circa la sua interazione con una piattaforma social. Per usare selenium serve un driver tra libreria ed il web browser.

5.7 XPATH

E' un linguaggio di specifica di un percorso all'interno di un documento XML. Un documento XML se formattato correttamente può essere rappresentato come un albero, quindi anche xpath è una sintassi per navigare nell'albero dei tag. E' applicabile se il documento è XHTML (HTML ben formattato). Definisce una serie di tipi diversi di nodi, quello che interessa a noi sono:

- Elementi: tag
- Attributi: attributi dei tag
- Testo: il contributo testuale messo tra un tag di apertura e di chiusura

Dobbiamo ricordarci che xpath è sempre una sintassi per specificare dei percorsi o sottoalberi nell'albero HTML. La sintassi è simile a quella che si usa per navigare nei sistemi operativi.

Per specificare un tag uso il nome del tag, restituisce tutti i tag a partire da quello il cui nome è uguale a quello dell'operatore selezionato. Se voglio partire dalla radice per la ricerca divento /. Posso dire di partire dalla definizione di percorso da un nodo specifico, uso //. . seleziona il nodo corrente. .. seleziona il genitore del nodo corrente @ seleziona gli attributi.

Ci sono delle wildcard che indicano tutti i nodi *, e la @* che indica qualsiasi tipo di attributo. Se voglio fare l'unione posso mettere la —

Chapter 6

Misinformation

Il problema di misinformation è centrale nei social media e va definito, perchè quando si affrontano dei problemi in cui si applicano strumenti automatici è necessario dare una definizione condivisa che va poi resa quantitativa, in modo che posso esprimere in modo quantitativo delle caratteristiche che si avvicinano alla definizione stessa. Non è questo il caso, perchè ogni parola che c'è nella definizione non è quantificabile. Definizione misinformation: è un'informazione inaccurata o falsa, deliberatamente creata e intenzionalmente o non intenzionalmente diffusa o propagata. Notiamo che non è solo una fake news, ci dev'essere qualcuno che ne verifichi la falsità o verità, può essere totalmente falsa o parzialmente falsa. Poi c'è un processo di creazione che è il fatto di essere creata deliberatamente, cioè il creatore di questa informazione ha uno scopo doloso, perchè questa informazione viene propagata per nuocere a qualcuno. Per quanto riguarda la diffusione di questa informazione abbiamo due comportamenti diametralmente opposti, intenzionalità (diffusa intenzionalmente per nuocere a qualcuno) o non intenzionalità (è il classico sessantenne che fa lo share su Facebook), alcuni si fanno influenzare da comportamenti sociologici e si lasciano trasportare condividendo misinformation.

Il Pizza Gate è iniziato con una serie di informazioni o contenuti falsi in cui veniva affermato che la catena Comet veniva utilizzata come luogo di atteggiamenti sessuali verso minorenni ed aveva relazioni con un partito democratico americano. In un'esclamazione di diffusione ed influenza verso determinati soggetti che ha portato una persona influenzata da questa informazione falsa da presentarsi munito di armi in uno di questi locali convinto che quello fosse un covo di pedofili. Ovviamente è finta in tragedia perchè quella persona ha sparato, comunque è un classico esempio portato come contenuti che circolano online classificati sotto l'etichetta di misinformation. Di conseguenza uno degli obiettivi è andare a mitigare questo genere di fenomeno con una serie di strumenti.

6.1 Tipi di Mininformation

Partendo dalla definizione generale esistono dei concetti molto affini in cui alcune parti della definizione sono più deboli:

- Misinformation non diffusa intenzionalmente: in questo caso manca la parte di dolo nel processo di misinformation. Gli utenti regolari possono contribuire alla misinformation.
- Misinformation diffusa intenzionalmente: in questo caso la diffusione è fatta in modo intenzionale. A volte gli autori si nascondono sotto il cappello della satira.
- Leggende metropolitane: misinformation diffusa intenzionalmente riferibili a storie finte relative ad eventi locali. Il fattore discriminante è lo scopo, non c'è scopo doloso, ma è un discorso prettamente legato ad intrattenimento.
- Fake news: misinformation diffusa intenzionalmente nel formato di una notizia. E' una specializzazione che approfondiremo poi, in questo caso il contenuto è specifico, si parla di notizie, la falsità è sulla notizia.
- Informazione non verificata: in questo caso ci focalizziamo sulla parte di inaccuratezza, è un passo prima dal dire che un contenuto è falso o non accurato perchè non è ancora stata verificata. In questo caso abbiamo due strade, se è vera non è misinformation al contrario cade sotto il concetto generale di misinformation.
- Rumor: tipo di informazione che può essere vera o falsa. In questo caso manca ancora il fatto che un'informazione venga verificata o no.
- Crowdturfing: dal punto di vista della costruzione della notizia falsa c'è sotto un grosso processo e strategie che risalgono a 60 anni fa come idea. In particolare vengono uniti due concetti:

- Astroturfing: deriva da uno stadio in Texas in cui per la prima volta viene usato il prato artificiale, il nome di questa erba finta viene chiamata così. Si crea una storia con tanto di persone che supportano questa informazione che in realtà è falsa (non ci sono i supporter e la storia viene creata), la storia viene creata in modo convincente quindi ci si crede. E' stata utilizzata nella lobby del tabacco in america o per supportare alcune teorie che smontavano il riscaldamento globale, si creavano degli opinion leader per supportare la falsità del riscaldamento globale, veniva anche finanziato un pubblico creato ad hoc per dimostrare che il contenuto veicolato fosse vero. L'idea è sostanzialmente di creare una realtà alternativa, falsa, mediante degli strumenti e persone di supporto, quali opinion leader ed audience pagata.
- Crowdsourcing: si danno delle piccole ricompense per supportare una causa che voglio io.

E' un fenomeno piuttosto complesso perchè richiede una strategia di selezione dei worker (le persone che creano il consenso costruito) ed in più il messaggio deve essere sufficientemente convincente per quando verrà veicolato su un pubblico più ampio. Strategia per creare consenso verso una determinata idea.

- Spam: informazione non richiesta e massiva
- Troll: possono utilizzare contenuti il cui obiettivo è aumentare la tensione all'interno di gruppo. Si fa per creare separazione nei gruppi, e la separazione è un terreno fertile per influenzare il gruppo veicolando del contenuto. Più separo e meglio posso diffondere informazione falsa o inaccurata.
- Hate Speech: veicolare contenuti violenti che hanno l'obiettivo di colpire determinati gruppi o persone. Il contenuto falso e violento ha un obiettivo specifico. Targhettizzazione della diffusione.
- Cyber-Bullismo: hanno dei tratti particolari e non li considereremo nella trattazione.

6.2 Metodi di contrasto ai diffusori di misinformation

Non è facile andare ad identificare i diffusori perchè questi si adattano alle strategie di identificazione, ad esempio inizialmente si poteva capire dalla discrepanza tra persone seguite e follower, questo sbilanciamento negli anni è diminuito sempre di più. L'altro elemento può essere quello di vedere comportamenti di connessione con altri account strani, l'esempio più eclatante è che formiamo all'interno della rete di gruppi, una strategia poteva essere quella di identificare utenti isolati, tuttavia è facile aggirare questa strategia creando dei gruppi finti composto solo da diffusori di misinformation. In più vedremo un'altra modalità che è quella di copiare gli utenti regolari ed ogni tanto comportarsi da diffusori. In generale quali sono i metodi di identificazione:

- Content-Base: l'identità di un account è dettato principalmente dal contenuto che esso produce. Quindi analizzando quello che un account produce posso verificare che quell'account diffonde o meno misinformation.
- Network-Base: viene definito un account all'interno della rete sociale in base alle sue relazioni ed alle relazioni che lo circondano. Vado a definire un nodo in base a come è connesso nella rete.

Si tratta di due definizioni che vanno a cogliere le peculiarità di un account nella rete.

6.2.1 Identificazione Content-Base

Quello che faccio è identificare pattern che distinguono i diffusori dagli utenti regolari, ci saranno delle caratteristiche che all'interno del contenuto prodotto da un profilo mi faranno sospettare che quell'account è un diffusore di misinformation. Come faccio ad avere i dati relativi agli account che possono essere degli spreader? uno degli approcci è mettere delle trappole, si chiama honey pot, cioè cerchiamo di mettere delle trappole per fare manifestare gli utenti spreader in modo da prendere le loro informazioni ed identificare comportamenti tipici solo dei diffusori.

Viene utilizzato principalmente un approccio ispirato al machine learning, in particolare un approccio supervisionato. Si parte da un insieme di account con determinate proprietà e questi account hanno un etichetta (assegnata ad esempio dai sistemi di honey pot o da etichettatori umani), quindi parto da una tabella in cui ogni riga corrisponde ad un account ed ogni colonna corrisponde a delle caratteristiche dell'account (numero di follower, quanti post al giorno...), in più c'è un'ulteriore etichetta che mi dice se un account è spreader o regolare. Un algoritmo di apprendimento supervisionato, in base alle etichette (1 o 0), impara una funzione che è in grado di discriminare un generico account che ha determinate caratteristiche da un account che è di uno spreader. Quanto lo fa bene, è possibile misurarlo attraverso caratteristiche di performance. Ovviamente esistono degli svantaggi in questo approccio (a parte come imparare la funzione), in particolare è etichettare. Esiste anche un altro problema di feature engineering, quali informazioni e come manipolo l'informazione di un account in modo da ottenere delle performance migliori, quali tipo di informazioni tengo. Posso iniziare prendendo le informazioni di un contenuto diffuso ed integrarlo anche con proprietà delle relazioni che questo account ha con gli altri (quanti amici ha, ha solo amici che non si connettono tra di loro...). Posso estrarre informazioni dal profilo, ad esempio il nome utente. Informazioni sempre sul profilo e sulla longevità dello stesso sulla piattaforma, è stato creato prima che succedesse un evento ed il contenuto che veicola è relativo all'evento successo dopo la sua creazione. Sono informazioni che possono essere usate insieme a strumenti di sentiment analysis (cercano di capire l'umore del profilo) posso addestrare il classificatore che mi restituisce la funzione che mi discrimina gli spreader da quelli che non lo sono.

Una delle modalità per fregare questi sistemi è usare un **modello di copia**. Prendo un utente normale, lo copio quasi sempre nel suo contenuto (basta retwittarlo) ed ogni tanto agisco in modo doloso inserendo del contenuto di tipo misinformation. Nel calcolo delle caratteristiche di tipo content base (sia contenutistiche sia temporali) nella media il comportamento da spreader si perde. Come si tenta di contrattaccare a questo attacco? usando sempre approcci di tipo supervisionato non sullo spreader ma sul contenuto, oppure usare approcci non supervisionati (no etichette) ma calcolo degli indici di similarità per capire quanto sono simili i contenuti di due account.

6.3 Metodi di identificazione della misinformation

E' praticamente uguale a quello che si fa per identificare un account, si usano sempre delle proprietà, in questo caso del contenuto. Ho tre tipi di proprietà:

- Content-Based: valuto il contenuto, e ci sarà o un meccanismo di matching per capire se è già stato classificato come misinformation (text matching) o di approccio supervisionato.
- Context-Based: posso arricchire il contenuto dal contesto, prendendo le date, il tempo e dove è stata fatta la foto. Oppure sappiamo che i contenuti di misinformation vengono pubblicati a raffica. Sono una serie di informazioni di contesto.
- Propagation-Based: possiamo anche analizzare come il contenuto si è diffuso sulla rete. E' un approccio potente, perchè contenuto misinformation si diffonde più velocemente ed in maniera diversa di un contenuto regolare. Lo svantaggio è che mi accorgo troppo

tardi se il contenuto è di misinformation, perchè devo aspettare che si diffonda. Si tentano di identificare i primi segnali di propagazione tipici di contenuto misinformante in modo da sfruttare la rete di propagazione ed avere un early detection analizzando qual'è la struttura iniziale della rete di propagazione per stopparne la diffusione.

6.4 Fake News

Come abbiamo visto è un tipo specifico di misinformation. Uno dei fenomeni di supporto alla diffusione di fake news è che è in crescita la percentuale di persone che utilizza il social media come fonte di informazione. Questo si accompagna anche alla produzione di contenuti come news, questo comporta la fruizione di notizie real time, velocità che è supportata dagli strumenti di condivisione, il feed propaga le informazioni. E' ovvio per le caratteristiche dei social media che il fenomeno, già presente, di notizie fake sfrutti queste caratteristiche per diffondersi. A ciò si accompagna il meccanismo dello user generated content che in media ha reso peggiore la qualità delle notizie rispetto ai media tradizionali. In questo si aggiungono fenomeni di monetizzazione, il diffondere un contenuto può essere facilmente monetizzato. Oltre ad ottenere vantaggi politici, perchè i social mi permettono di raggiungere velocemente chi è indeciso e modificarne il comportamento. In generale è un problema importante ed impattante e un problema che non è solo relativo alla sfera tecnologica dei social media ma è un fenomeno trasversale che tocca diversi ambiti.

6.4.1 Definizione

Se approcciamo questo problema dal punto di vista tecnologico, cioè identificare strumenti automatici di supporto per identificare fake news dobbiamo dare una definizione adatta. In particolare modo ci sono due definizioni che possiamo dare al concetto di fake news:

- La più stringente (usata negli approcci di identificazione automatica): una fake news è una notizia intenzionalmente creata che è possibile verificare essere falsa. L'articolo è contenuto principalmente testuale (eventualmente accompagnato multimediale) che riporta una notizia o fatto, la notizia può essere verificata. In questo caso dobbiamo agire su due dimensioni:
 - Autenticità: la fake news contiene informazioni false, e dobbiamo verificarne la falsità
 - Intenzionalità: consideriamo fake news una notizia creata con un intento malevolo, che può essere colpire un obiettivo o un gruppo oppure ingannare il fruitore della notizia
- Una versione più generale in cui una delle due dimensioni può mancare

Usiamo la prima definizione in modo da non considerare fake news le notizie satiriche.

6.4.2 Fake news su media tradizionali

Prima di andare a vedere come identificare un contenuto fake, notiamo che il fenomeno non è nuovo, ma è un fenomeno che caratterizza l'uomo nelle dimensioni psicologiche e sociologiche. E' amplificato molto in volumi dal rendere tecnologica la parte social dell'uomo (creare social media) però in realtà la presenza ha delle radici che sono preesistenti rispetto ai social media. In particolare sono state identificate delle caratteristiche dell'uomo che vengono sfruttate da chi genera fake news per amplificarne la diffusione. Partiamo dalla **psicologia** di una persona e partiamo da un'incapacità generale di non identificare in modo corretto quando una notizia è falsa oppure no, perchè entrano in gioco due comportamenti psicologici:

- Naive realism: è quello che penso è la migliore rappresentazione che esista. Si tende a credere che il nostro modello di mondo sia il migliore rispetto a tutti gli altri, questo fa sì che una volta che mi creo il modello della realtà, che può essere supportato da fatti falsi, tutto quello che lo supporta, dal momento che si adatta all'egocentrismo, rafforza il modello.
- Confirmation bias: noi teniamo informazioni che confermano ciò che sappiamo già, siamo poco inclini al cambiamento ed alla modifica del nostro modello di mondo. Significa che se le fake news ci arrivano prima di una visione più accurata della realtà queste creano una convinzione che poi difficilmente riusciremo a scalzare. Questo è uno dei motivi per cui è difficile che una volta che una persona ha creato un modello basato su fake news convincerla che sia il contrario.

Il secondo aspetto è di tipo **sociologico** che vedremo avere ripercussioni anche su un altro tipo di fenomeno. Esistono delle dinamiche sociali di supporto alle fake news, ed in particolare una di queste viene modellata sulla prospect theory, è una teoria in cui si definisce un modello di decisione, fruisco una fake news accettandola, decido una determinata azione in base ad un guadagno o una perdita relativo al mio stato sociale. In ambito sociale il guadagno è una comfort zone dato da un adeguamento della mie identità a quella del gruppo in cui sono inserito, perchè mi riduce il numero di attriti con il gruppo, ho quindi un guadagno in termini di conflitti con il gruppo stesso. Il guadagno si ripercuote anche nella sicurezza sociale, perchè riducendo i conflitti vivo in armonia nel gruppo che mi da un senso di protezione, mi adeguo quindi alle norme della community, il problema è che se sono inserito in un gruppo in cui si diffondono fake news anche io applicherò lo stesso comportamento del gruppo. Questo vale prima e durante gli online social media, ma durante questo tipo di fenomeno è ulteriormente amplificato perchè il gruppo agisce in modo continuo, siamo costantemente esposti ai feed degli elementi del gruppo.

Questi fenomeni hanno portato all'amplificazione di fenomeni definiti come **echo chambers**, ovvero gruppi in cui le notizie fake risuona e viene amplificato ulteriormente all'interno di questi gruppi. A maggior ragione se il gruppo è isolato (posso usare troll per far isolare il gruppo) posso inserire particolari fake news che trovano cassa di risonanza in alcuni membri che a loro volta influenzano altri membri del gruppo. Le echo chambers si generano anche perchè esistono ulteriori meccanismi di tipo cognitivo e sociologico:

- Social credibility: le persone percepiscono come attendibile quello che le persone fidate ritengono attendibile
- Frequency heuristic: le persone preferiscono informazioni che sentono di frequente. Più sono esposto ad un particolare contenuto, quello conforme all'echo chamber, più sono portato a ritenerlo vero.

6.4.3 Fake news detection

Come sviluppare metodi per identificare un contenuto, che è una notizia riportata in un articolo, e capire se è una fake news o meno. L'approccio generale è lo stesso che abbiamo visto per la misinformation (sia spreader che singolo contenuto), nel caso delle fake news abbiamo alcune informazioni in più, perchè viene modellato in una maniera più raffinata. In particolare gli elementi in gioco nella formalizzazione del problema:

- Articolo che riporta una notizia: A (article) e N (news). L'articolo è composto da due elementi:
 - Il publisher p_a della notizia, l'autore della notizia
 - Un insieme di proprietà derivate dal contenuto dell'articolo c_a . Una proprietà può essere quante volte occorre una parola.

- Social News engagement: in ambito social media abbiamo una serie di proprietà derivanti dalla rete che diffonde una notizia. E' un insieme di triplette così composte:
 - utente u che diffonde l'articolo A
 - il post p che accompagna l'articolo condiviso. Ad esempio un testo che accompagna la ricondivisione.
 - il tempo t , quando l'utente u ha condiviso l'articolo riportante la notizia

Questo lo faccio per ogni persona che ha condiviso l'articolo

Per andare ad identificare se un articolo riportante una notizia è una fake news uso tutte le informazioni che abbiamo appena visto. Estraggo delle proprietà che mi servono per estrarre delle quantità da passare all'algoritmo di apprendimento che imparerà una funzione F tale per cui se darò a quella funzione un articolo con le sue caratteristiche mi dice se quella è una fake news oppure no.

Estrazione delle proprietà

Sono di due tipi:

1. Proprietà del contenuto:

- Autore, titolo, testo principale (quanti puntini di sospensione...). Mi serve per trasformare il testo in numero (frequenza delle parole)
- Immagini e video

Si usano proprietà di tipo linguistiche o visuali, si usa l'approccio linguistico perchè è più facile.

2. Proprietà del contesto sociale: vengono create partendo dal social news engagement.

- User-Based: analizzo le persone che hanno condiviso una news e qua' posso vedere quali account sono degli spreader, perchè se vedo che ci sono tanti spreader molto probabilmente anche il contenuto sarà falso. Guardo anche se le persone che condividono appartengono ad una determinata echo chambers allora molto probabilmente sarà una fake news.
- Post-Based: posso analizzare le proprietà dei post accompagnati alla notizia condivisa, posso valutare l'opinione degli utenti verso una determinata notizia (per esempio misurare il sentimento degli utenti verso quella notizia)
- Network-Based: Ricostruire le relazioni che ci sono tra gli utenti che hanno condiviso una determinata notizia. Posso usare stance network valutando come gli utenti hanno reagito rispetto ai post che hanno condiviso, se due utenti reagiscono sempre uguale li considero simili. Posso crearmi reti di co-occorrenza in cui due utenti sono connessi se condividono la stessa notizia. Posso ricostruire la rete di amicizia fra gli utenti coinvolti. Ed infine posso ricostruire (più o meno precisamente) la traiettoria di diffusione di una notizia, questo è un problema complessi di network inference, ovvero ricostruire avendo solo il tempo di condivisione.

Comunque date queste proprietà, posso misurarle e darle come input alla mia funzione di discriminazione.

6.5 Social Bot

Si parla di social bot di tipo malevolo perchè il concetto di social bot è connaturato al concetto di social media perchè gli strumenti automatici usano le API di un social media. Anche in questo caso non esiste una definizione condivisa di cosa si intende con social bot, noi useremo la definizione classica dell'informatica, noi abbiamo il livello di automazione come componente dell'account che deve usare un'automazione parziale o completa. Una delle caratteristiche discriminanti è quella di social bot malevoli e benevoli, noi ci soffermeremo su quelli malevoli. Quelli benigni sono i classici social bot di aggregazione di notizie etc. Le due dimensioni su cui lo valutiamo sono:

- Intento
- Capacity: capacità di replicare dei comportamenti umani

Identificare un bot malevolo è più difficile perchè cerca di bypassare gli strumenti di identificazione automatica. E' un fenomeno massivo che sappiamo che ha avuto una certa influenza su certe elezioni politiche ed anche in ambienti finanziari.

Non coinvolge solamente le piattaforme ma è mondiale.

6.5.1 Social bot pandemic

C'è un aumento nel tempo del numero di bot per determinati motivi, non solo extra social networ, ma di tipo anche tecnologico. In particolare abbiamo un aumento di repository che mettono a disposizione codice sorgente per creare social bot. Le piattaforme vanno a chiudere molti account di social bot di tipo malevolo perchè segnalati dagli utenti regolari.

Si parla anche di evolution dei bot, perchè c'è stata un'evoluzione per adattarsi alle metodologie di identificazione:

- Bot semplicissimi e facilmente identificabili tramite strumenti come botometer, in cui non c'è foto profilo, poca attività
- Maggiore attenzione verso le caratteristiche discriminanti usate da sistemi come botometer, bilanciamento follower following (gruppi di bot), la foto del profilo è un simbolo ma è stata settata, c'è un'immagine di background ed una buona attività
- Attualmente in uso in cui non c'è differenza tra l'aspetto e le informazioni degli account regolari e quelli dei bot. Tant'è che si parla di account cyborg

Questo ha portato attualmente ad una capacità di superare filtri di bot detection, tant'è che solo il 5% dei bot di nuova generazione vengono rimossi dalle piattaforme. Quello che fa più specie è che anche gli umani faticano ad identificare il bot, si perde l'efficacia di avere un dataset etichettato, questo succede perchè da una parte c'è il fenomeno dei cyber account (in cui c'è anche una componente umana) ed in più gli ultimi modelli di open IA permette di creare del testo ed immagini che sono indistinguibile da un umano.

Un approccio per riuscire a mitigare questo tipo di bot è quello di analizzare le interazioni tra i bot, perchè c'è sempre una componente umana che li coordina e queste caratteristiche umane si ripercuotono sui bot stessi. Oppure si può imparare a generare automaticamente dei bot che ingannino il meccanismo automatico di identificazione dei bot ed addestrare il sistema di identificazione dai fallimenti con i bot che ho generato io, questo si chiama approccio avversariale ed è un circolo virtuoso in cui aumenta la capacità di creare nuovi bot non identificabili ma dall'altro lato addestrano una funzione che dovrebbe riuscire ad identificare questi bot inidentificabili. L'ultimo approccio è interessante dal punto di vista della ricerca ma non sta portando i frutti desiderati, rimane un problema aperto.

Chapter 7

Intro modulo 2

7.1 CyberSecurity

E' una disciplina giovane e particolarmente articolata perche' coinvolge diversi aspetti dell'informatica. Non e' legata solo alle tecnologie ma coinvolge tecnologie persone e processi, per questo e' particolarmente complessa. In quanto non basta mettere in sicurezza da un punto di vista tecnologico ma e' necessario anche che le persone usino i programmi in modo corretto e che ci siano meccanismi di controllo per garantire il corretto uso dei sistemi. Siccome attraverso l'uso inappropriato di questi strumenti e' possibile commettere reati, la cybersecurity e' considerata anche dal punto di vista legale. La conoscenza di security bug non noti in questo momento da' un vantaggio forte ai paesi che hanno questa conoscenza perche' possono attaccare e mettere in crisi infrastrutture nemiche.

7.2 Privacy Protection

Una parte consistente dei sistemi di protezione e' legata al problema della privacy, ma e' un problema ortogonale rispetto alla cybersecurity. La privacy e' stata definita come il diritto di essere lasciati soli. Le tecnologie dell'informazione sono viste come minaccia alla privacy perche' se abusate fanno si che la privacy degli utenti possa essere facilmente violata, sia perche' chi usa gli strumenti non e' consapevole del rischio che corre, ma anche perche' con l'evoluzione della tecnologia e degli strumenti di IA e' facile partendo da pochi elementi profilare le persone, i gusti e le tendenze delle persone. Ovviamente questo fa si che il diritto di essere lasciati soli (l'intimita') possa essere facilmente violata. Ecco che la privacy protection e' una branca della cybersecurity che si occupa di fornire agli utenti degli strumenti per proteggersi dalle minacce e studia le nuove minacce che arrivano quando vengono inseriti nuovi strumenti.

7.3 Sistema sicuro

Un sistema informatico non e' sicuro quando viene attaccato e l'hacker riesce ad entrare. La nozione di sistema sicuro non e' geniale, ma e' contestuale, quindi un sistema e' sicuro in relazione ad un certo tipo di contesto ed in relazione ad una serie di attivita' che fa. Esiste un sistema sicuro per una specifica azienda o applicazione. Detto questo in generale si parla di sistema sicuro quando il sistema informatico e' in grado di garantire il soddisfacimento di 3 proprieta' TRIADE CIA:

- Confidenzialita'
- Integrita'
- Disponibilita'

7.3.1 Confidenzialita'

Un sistema informatico soddisfa la proprieta' di confidenzialita' se e' in grado di garantire che gli accessi alle informazioni che sono conservate all'interno del sistema sono effettuabili solo da persone autorizzate. Ad esempio il nostro computer non e' in grado di garantire la proprieta' di confidenzialita', anche guardare il dispositivo privato di una persona e' accesso abusivo, quindi e' un reato (come se qualcuno ci entra in casa).

7.3.2 Integrita'

E' ortogonale alla confidenzialita', un sistema garantisce la proprieta' di integrita' solo se chi opportunamente autorizzato puo' modificare le informazioni all'interno del sistema. Quindi mentre la confidenzialita' e' legata al diritto di poter accedere in lettura a delle informazioni,

l'integrita' e' un ulteriore passo legato al fatto che uno puo' accedere anche in scrittura alle informazioni. L'attacco piu' famoso per corrompere e' ransomware che e' un virus che cifra tutti i dati dell'hard disk con una chiave che conosce solo lui e ci chiede un riscatto. Degli strumenti per evitare problemi di integrita' sono:

- Backups: se facciamo tanti backup possiamo ripristinare i dati, nonostante cio' circa il 98% delle societa' pagano i riscatti
- Checksum: una funzione che mappa il contenuto di un file ad un valore numerico.
- Data correcting codes: metodi per archiviare i dati in modo che un piccolo cambiamento possa essere facilmente individuato e corretto automaticamente.

7.3.3 Disponibilita'

La terza proprieta' e' quella della disponibilita', che e' quella piu' difficile da garantire. Un sistema e' disponibile vuol dire che quando abbiamo bisogno di accedere l'informazione e/o i servizi sono disponibili. E' un'attacco che si fa spesso ai server web per fare in modo che non rispondano, si chiamano attacchi di tipo deny of service e mirano al fatto di rendere una risorsa o un servizio non disponibili per un utente. Gli strumenti che si usano:

- Protezioni fisiche: infrastrutture che sono in grado di far rimanere le informazioni disponibili anche se ci sono degli eventi fisici
- Computational redundancies: ridondiamo i dati in altri computer in modo che siano disponibili in caso di attacco

7.4 Sistemi non sicuri

Perche' i sistemi informatici non sono sicuri? Quali sono i motivi per cui non siamo in grado di far fronte ad attacchi? essenzialmente perche' i sistemi informatici contengono degli errori, che in alcuni casi possono essere sfruttati per bypassare meccanismi di protezione dei sistemi. Esistono degli attacchi con cui e' possibile autenticarsi ad un sistema utilizzando una sessione attiva di un utente registrato.

Errori che vengono fatti in fasi di progettazione, implementazione e configurazione del software. Gli hacker fanno uno studio approfondito del codice dei programmi e poi una volta che hanno trovato il pertugio passano. Questi errori sono chiamati vulnerabilita' che consentono a chi li sfrutta di scavalcare i meccanismi di protezione nel sistema.

Ci sono errori legati a chi usa questi sistemi, umana vulnerability, ad esempio usare password estremamente deboli, esiste una disciplina che e' mirata alla truffa delle persone, social engineering che studia come ottenere le password da informazioni delle persone. Inoltre possono esserci utenti insoddisfatti dell'azienda che fanno casini.

Quindi i sistemi informatici per definizione non sono sicuri.

7.4.1 Errori nel software

Il software e' uno delle principali fonti di bug, uno studio fatto 20 anni fa analizzando grossi progetti fatti per la pubblica amministrazione USA e hanno stimato che quando il numero di istruzioni nel programma supera le centinaia di migliaia e' facile avere tra i 20 e i 30 errori all'interno del codice. Allora se pensiamo che windows10 e' fatto da 50 milioni di righe di codice ci rendiamo conto di quanti possono essere i bug all'interno. Un'altra statistica e' che per ogni errore tolto se ne immettono due nuovi. Il problema che la programmazione e' un'attivita' tipicamente umana e non puo' essere scevra da errori.

7.5 Terminologia

Vulnerabilita' e' una debolezza all'interno di un sistema, che puo' essere sfruttata dagli attaccanti. La minaccia e' un'agente che puo' provocare dei danni (ed e interessato a farlo), che non e' necessariamente un'agente umano. I controlli sono gli strumenti di varia natura che vengono presi per cercare di bloccare o ridurre la probabilita' di essere attaccati.

7.6 Attacco

E' lo sfruttamento di una vulnerabilita' da parte di una minaccia. Ovviamente puo' avere successo cosi' come no. Gli attacchi ci sono, soprattutto sulla rete (all'universita' circa 10k al giorno).

7.6.1 Passivi

Nelle forme di attacco passivo non richiedono risorse all'interno del sistema ma sfruttano risorse esterne. Il classico e' l'intercettazione del traffico di rete, che non modifica nessuna risorsa all'interno del sistema attaccato e per questo e' estremamente difficile da rilevare.

7.6.2 Attivi

Usano le risorse del sistema per fare l'attacco. Siccome usano le risorse del sistema, quindi abbiamo o lo sfruttamento di CPU, memoria o zone di disco, sono piu' facilmente individuabili.

7.6.3 Conseguenze degli attacchi

Quali sono gli obiettivi principali di chi attacca un calcolatore:

- Accedere all'informazione presente all'interno del sistema
- Distruggere componenti del computer, gli attacchi di prima generazione
- Modificare l'informazione presente, questi sono attacchi abbastanza difficili e brutti
- Creazione di profili finti per cercare di adescare persone

L'obbiettivo quindi e' impossessarsi di qualche componente all'interno del sistema. Un altro attacco molto usato e' un virus che sfrutta la CPU per fare mining di crypto valute.

7.7 Asset

E' il bene che viene attaccato, nell'ambito informatico sono costituiti da :

- Hardware: la CPU, il disco quando un hacker riesce a raggiungere la risorsa di un'utente e ruba le informazioni difficilmente le cartelle le deposita in un PC suo, ma le mette nel Pc di qualcun'altro.
- Software
- Dati: quelli principalmente sfruttati
- Networking: gli apparati attivi di rete
- Persone

Questi sono i targeht che vanno opportunamente protetti.

7.8 Minacce

- Ambientali: incendi, terremoti, inondazioni. Anche questi compromettono il buon funzionamento del sistema. Minacciano la proprieta' della disponibilita'
- Minacce umane: hackers di diversa natura, i recreational hackers sono degli hacker che lo fanno per divertimento. Zerodium e' una societa' che compra gli attacchi informatici (ci sono le varie quotazioni, e pagano milioni di dollari), di conseguenza gli hacker recreational non esistono piu'. Ma ci sono i professionisti. Ci sono bande mafiose che controllano i ransomware. Ci sono spionaggi governativi

7.8.1 Motivi degli attacchi

- Soldi
- Spionaggio
- Divertimento o ideologia

7.9 Strategie di difesa

Gli attacchi si possono in qualche modo prevenire, ad esempio tramite la crittografia. Altrimenti si possono rendere piu' difficili, nel senso che non tutti gli attacchi possono essere prevenuti. Un'altra strategia puo' essere quella di deviare gli attacchi honey pot, si tratta di costruire dei siti civetta che sembrano piu' interessanti di quello vero in modo che l'attaccante vada su quello. L'ultima spiaggia e' quella di accorgersi quando un attacco e' in corso e poi ripristinare la situazione.

7.10 Contromisure

Chi fa sicurezza in azienda si deve preoccupare di individuare le contromisure, che sono strumenti che vengono adottati per reggere ad eventuali attacchi. La cyber security si divide in defensive ed offensive, chi fa defensive deve preoccuparsi di trovare le contromisure. Non esiste il sistema sicuro in assoluto, qualche errore lo commettiamo quindi prima o poi qualcuno riuscirà ad entrare nel sistema.

7.11 Riassunto

Abbiamo l'owner che possiede l'asset, a cui e' interessato anche un'agente che prova attraverso le vulnerabilita' di accedere all'asset ed il proprietario cerca attraverso le contromisure di impedire all'agent di attaccare l'asset. Ricordiamoci che l'asset e' quasi sempre attaccabile

7.12 Nascita cyber security

Nasce negli USA con l'avvento dei sistemi multi-utente. Il primo documento ufficiale che pone all'attenzione questo tipo di problema e' questo Underson Report che nel 1972 aveva visto i problemi legati alla diffusione dei computer e la possibilita' di accedere ai dati protetti.

7.13 Perche siamo interessati

La cyber security e' molto presente nei social network, ad esempio un'anno fa e' stato fatto un attacco a Facebook a cui sono stati portati via i dati personali di 533 milioni di utenti tramite i quali sono state fatte delle truffe (enjoy milano).

7.13.1 Social Network

Sono un terreno fertile perché permettono di fare attacchi in modo più facile, perché partono dal presupposto di comunità e condivisione. Nascono negli anni 2000 per favorire la personalizzazione di Internet.

Abbiamo vari tipi di social network ed ognuno copre una parte della vita di una persona. Qual'è la cosa che rende particolarmente attraenti i social network da chi attacca? È la quantità di informazioni presenti. Informazioni estremamente interessanti per tutta una fascia di attori in particolare agenzie di marketing e agenzie che sono interessate a vendere prodotti. Ad un certo punto queste entità individuano i social network come repository principale per fare business.

Il mondo occidentale usa Facebook, la Cina usa Wechat e la Russia usa VK. Facebook è presente nel 93% di paesi.

È più facile attaccare all'interno dei social network, in quanto facendo parte di una comunità rende più facile agli attaccanti di superare una prima barriera. Gli attacchi sono solo per rubare informazioni che poi vengono rivendute (ad esempio a società di marketing).

7.13.2 Architettura dei un social network

Facebook usa le stesse componenti di una qualsiasi pagina web ma con componenti customizzate e chiuse all'interno del social network. Questo fa sì che di fatto all'interno dei social network ci sono gli stessi attacchi che ci sono anche in Internet (web).

La tipologia di rete sociale più tartassata dagli attacchi è quella delle piattaforme social, mentre nelle altre tipi di rete le forme di attacco sono più contenute.

7.13.3 Motivazioni dietro un attacco social

Lo scopo principale di accesso alle informazioni è lo spionaggio. Teniamo conto che quasi tutte le società di assunzione accedono ai profili Facebook.

7.13.4 SN e Cybersecurity

Alcuni tipi di attacchi che sono stati fatti sfruttando le SN. È un attacco che viene assegnato ai servizi Russi (ma è difficile fare questo genere di affermazioni) in cui attraverso un SN sono stati mandati dei messaggi di phishing hanno installato dei JS che controllava i PC.

Il caso di Mia Ash, è un profilo finto legato a questa fotografia che contattava impiegati di aziende di varia natura diceva che doveva fare degli stage ed era interessata ad intrattenere un rapporto con loro e gli chiedeva di essere aggiunta come amica a Facebook, poi la corrispondenza continuava finché mandava un foglio Excel alle persone coinvolte, una volta che uno apriva un foglio Excel faceva partire della macro che aprivano un remote access terminal che prendeva il controllo delle persone interessate. Questo è un attacco fatto creando profili finti e poi lavorando sulla fiducia delle persone.

Attacco a Slack, che è un prodotto usato nelle aziende per fare un social network aziendale. Succede che c'è una società che acquista Slack e crea questo social network tra i soci e le persone che vogliono sottoscrivere per fondare una startup. La sottoscrizione viene fatta tramite Ethereum, all'interno di questa community Slack c'era l'amministratore delegato della società, il quale si collega e mette l'indirizzo dell'account a cui fare i finanziamenti, se non che due giorni dopo arriva di nuovo il messaggio dell'amministratore delegato e dice che il messaggio precedente era finto. Quindi era successo che l'account dell'amministratore delegato della società era stato compromesso due mesi prima, e l'account e la password erano apparsi su dei siti (siti in cui se uno attacca la macchina scarica il file delle password e fa password guessing e poi pubblica il nome delle utenti e le password)

Attacco Cambridge Analytica, è l'attacco che è stato portato a Facebook, consiste nel fatto che durante la campagna elettorale di Trump (e per la Brexit) sono stati profilati 80 milioni di utenti Facebook, e queste persone hanno ricevuto dei messaggi elettorali mirati ad

personam che solleticavano le tendenze e le aspirazioni di queste persone inducendole a votare in favore di Trump. La cosa e' partita da un app thisisyourdigitallife che era stata pensata da un ricercatore come un sondaggio, se non che l'app non si limitava a fare il sondaggio ma recuperava anche le informazioni dal profilo dell'utente e recuperava i profili degli amici dell'utente e degli amici degli amici e si e' costruita in questo modo 79 milioni di utenti all'insaputa degli utenti. I dati raccolti sono quelli dei profili pubblico, i likes, il compleanno e la citta' in cui abitavano e questo ha consentito alla realizzazione di profili psicologici degli utenti. Si e' dimostrato che questa cosa ha molto influenzato i risultati elettorali.

Chapter 8

Cybersecurity

Quello di cui abbiamo parlato nell'introduzione ci ha fatto cogliere il classico schema guardie e ladri, nel mondo esistono persone che posseggono delle cose e delle altre persone che vorrebbero possedere le stesse cose, quindi c'è chi attacca e chi difende. Nel corso dei secoli sono cambiati i meccanismi di difesa, nel mondo della cybersecurity i meccanismi di difesa principali sono:

- Autenticazione
- Controllo degli accessi
- Crittografia

8.1 Crittografia

La crittografia è una scienza che si preoccupa di identificare dei metodi che sono in grado di trasformare un documento (stringa di bit) in modo tale che il suo significato sia comprensibile solo ad alcune persone. Metodi e operazioni di operare sul documento in modo che il contenuto sia accessibile a determinate persone. La crittoanalisi è la scienza che cerca di rompere i protocolli crittografici, cerca di decriptare un documento senza conoscere le chiavi di lettura. La crittologia è la crittografia più la crittoanalisi. L'obiettivo della crittografia è nascondere l'informazione rispetto a chi prova ad accedere senza avere le credenziali.

8.1.1 Cybersecurity e Crittografia

La crittografia ci aiuta a garantire la proprietà di:

- Confidenzialità
- Integrità
- Autenticazione
- Non Repudability

Più precisamente usiamo la crittografia per rendere le comunicazioni sulla rete private, in modo che se anche qualcuno le intercetta non può capire cosa ci stiamo dicendo. Possiamo fare lo stesso con i messaggi di posta elettronica. Possiamo cifrare il contenuto dei file del nostro hard disk. Possiamo sapere quando scarichiamo un file da Internet se è originale o tarocco. Possiamo firmare digitalmente dei documenti e rendere confidenziali i nostri dati.

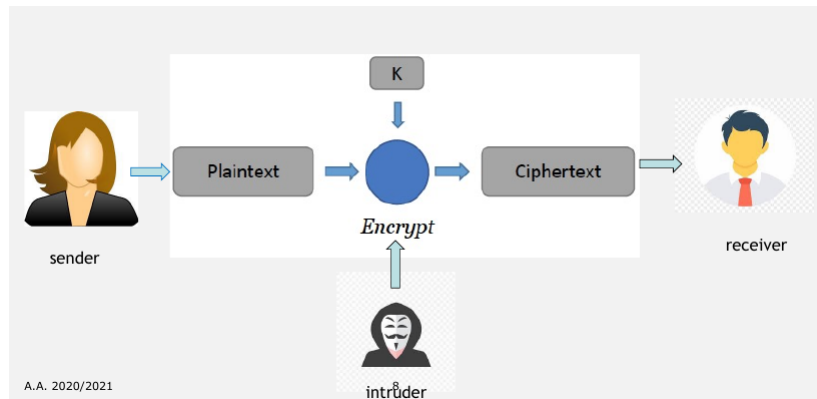
8.1.2 In SN

Whatsapp usa end to end encryption, vuol dire che il messaggio è cifrato dalla sorgente fino alla destinazione.

8.1.3 Modello di riferimento

Abbiamo un mittente ed un destinatario, il mittente vuole comunicare con il destinatario in maniera riservata, prende il messaggio che vuole inviare, il messaggio entra in un algoritmo crittografico con in input anche una chiave, si ottiene un testo cifrato che viene inviato all'utente. Nel mezzo c'è qualcuno che prova ad intercettare il messaggio e cifrarne il contenuto originale.

Formalmente abbiamo un insieme finito di messaggi M che vogliamo comunicare in chiaro ed un altro insieme finito di messaggi cifrati C . Inoltre abbiamo un insieme di chiavi K . Una funzione di encryption è biettiva, così come una funzione di decryption.



8.1.4 Categorie algoritmi

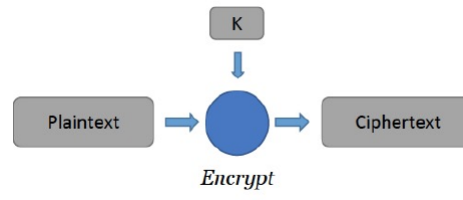
Abbiamo due categorie di algoritmi per effettuare la cifratura:

- A chiave pubblica
- A chiave privata o simmetriche

8.2 Crittografia a chiave privata

8.2.1 Encryption

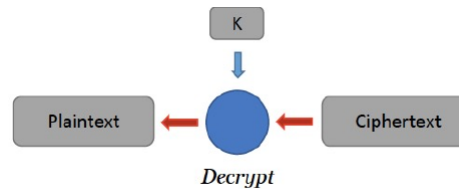
Applico la chiave K al messaggio P ed ottengo il messaggio cifrato C.



$$C = \{P\}_k$$

8.2.2 Decryption

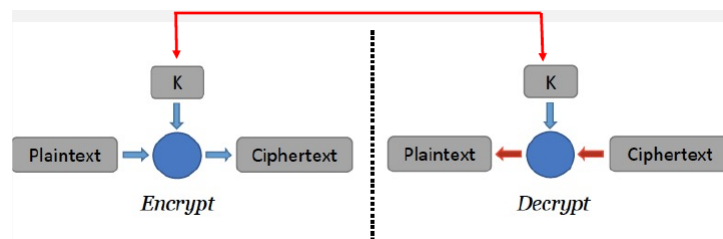
Prende in input il testo cifrato C e la stessa chiave k che avevamo usato per cifrare e restituisce il testo decifrato P (plain text).



$$P = \{C\}_k^{-1}$$

8.2.3 Crittografia simmetrica

Nella crittografia simmetrica gli algoritmi di encryption e decryption usano la stessa chiave, rispettivamente per criptare il plain text e decryptare il testo cifrato. La crittografia simmetrica può usare o gli stream chipers o i block chipers.

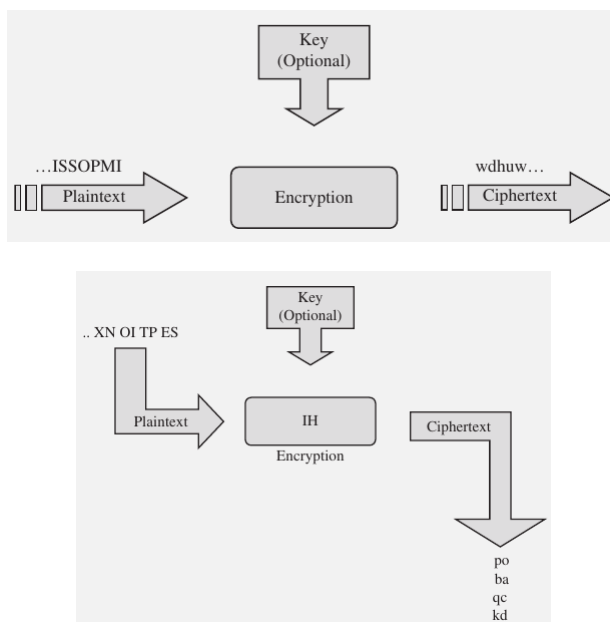


Stream chipers

Modificano il messaggio di partenza carattere per carattere. Il più usato è basato sull'uso dello XOR.

Block chipers

Modificano il messaggio a blocchi (un numero fissato di bits), criptando il blocco come una singola unità data una chiave fissata.



	Stream	Block
Vantaggi	Velocità, bassa propagazione errori	diffusione, posso inserire simboli
Svantaggi	poca diffusione	lento, padding, propagazione errori

Table 8.1: Stream VS Block

8.2.4 Data Encryption Standard DES

E' l'algoritmo di cifratura simmetrica piu' diffuso, viene ancora usato per cifrare il pin sul bancomat, ma e' in fase di decadenza. E' un block chipers, spezza il messaggio 8 caratteri per volta e vengono cifrati con una chiave di 64 bit. Esistono piu' versioni perche' le chiavi possibili sono 10^{15} chiavi e se le proviamo tutte per forza la troviamo, quando e' stato inventato nel 1977 era impossibile provare tutte le chiavi, attualmente con dei super calcolatori si puo' rompere un messaggio single DES. Quindi a seguito di questo attacco non e' stato piu' ritenuto sicuro sufficientemente.

8.2.5 AES

E' l'algoritmo che e' stato introdotto in alternativa al DES, anche questo è un block chipers, i blocchi sono di 128 bit e possiamo usare tre chiavi con diverse dimensioni: 128, 192 e 256 bits.

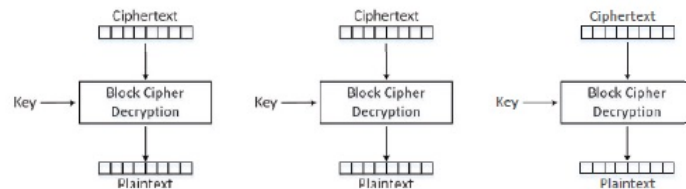
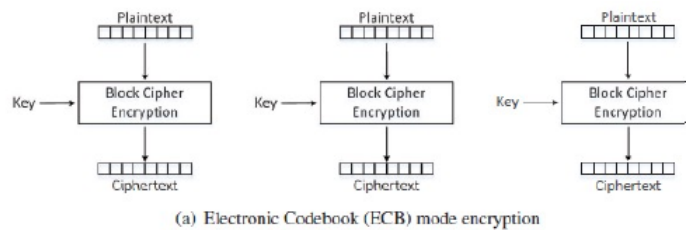
8.2.6 Encryption Modes

Vediamo i modi in cui mettiamo in input un testo ad un algoritmo di encryption:

- Electronic Codebook (ECB)
- Chiper Block Chaining (CBC)
- Propagating CBC (PCBC)
- Chiper Feedback (CFB)
- Output Feedback (OFB)
- Counter (CTR)

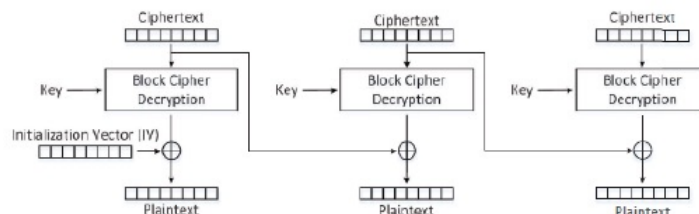
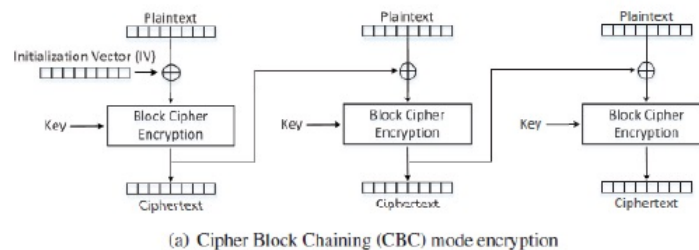
Electronic Codebook (ECB)

Prendiamo il testo e lo dividiamo a blocchi, successivamente i blocchi li mettiamo in ingresso all'algoritmo e ci esce il blocco codificato.



Chiper Block Codebook

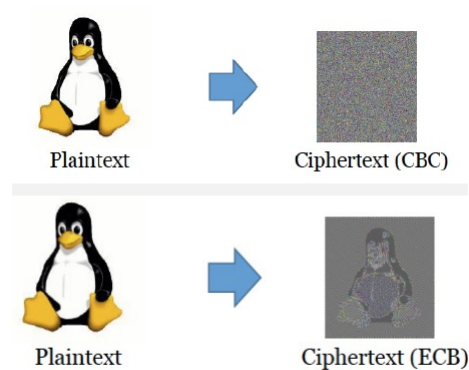
In questo caso un blocco dopo essere stato cifrato viene messo in coda ad un altro blocco, e richiede l'uso di un vettore di inizializzazione. Lo scopo del vettore di inizializzazione è che se anche se due blocchi sono identici, la loro cifratura risulta diversa, perchè vengono usati dei vettori di inizializzazione diversi. La decifratura può essere PARALLELIZZATA, mentre la cifratura non può esserlo.



Vantaggi e svantaggi

Sono algoritmi molto efficienti, hanno la chiave relativamente piccola.

Il problema principale della crittografia simmetrica: come facciamo a condividere la chiave di cifratura dei messaggi? Il secret sharing. Devo condividere una chiave con un utente che sta in rete. Mentre i vantaggi sono che è un protocollo molto efficiente sia per il tempo di esecuzione sia per lo spazio occupato e che la lunghezza della chiave è piccola.



8.3 Crittografia a chiave pubblica

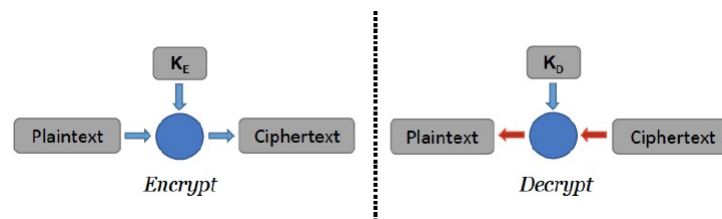
Il problema del secret sharing era noto, ma in ambito aziendale esistono dei canali sicuri in modo di comunicare senza essere intercettati. Nel momento in cui si affaccia la necessita' della comunicazione in rete il canale sicuro viene meno. Il problema viene risolto da Diffie ed Hellman in un articolo che gli e' valso il premio Turing. Che non ha risolto solo il problema del secret sharing tra due persone che non si conoscono ma introduce una nuova forma di crittografia, a chiave pubblica. Nella crittografia a chiave pubblica gli algoritmi di cifratura e de-cifratura usano DUE chiavi:

- PUBLIC KEY
- SECRET KEY

. Ogni coppia di chiavi e' strettamente correlata, una chiave pubblica deve avere una corrispondente segreta.

8.3.1 Cifratura/De-cifratura

Abbiamo una chiave che viene usata come chiave di cifratura, prendo il testo in chiaro e lo do all'algoritmo di cifratura con la chiave di encryption e lo passo, per decifrare il testo devo usare la chiave di de-cifratura. Le due chiavi sono quindi interscambiabili, cifro con una e decifro con l'altra. La cosa importante e' che ogni testo cifrato da una chiave puo' essere decifrato dalla chiave che e' stata generata insieme, questo e' il motivo per cui le chiavi devono essere generate insieme.



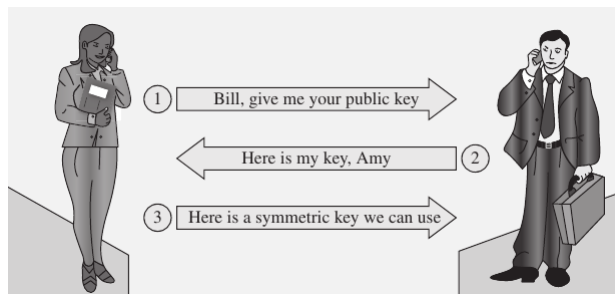
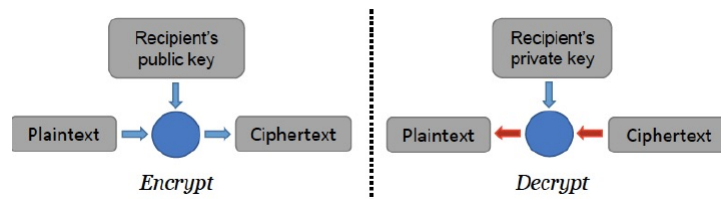
K_E può essere usata per criptare un testo e K_D è l'unica chiave che può essere usata per decriptarlo (vale anche il viceversa).

8.3.2 Funzionamento

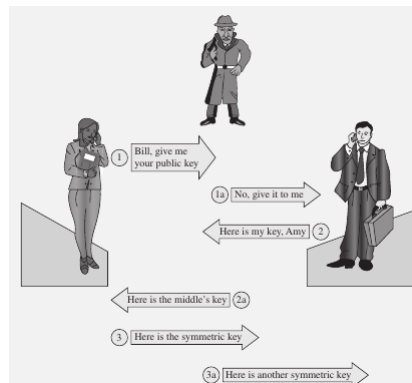
Come funziona, ogni utente deve avere due chiavi, una di queste chiavi deve essere resa pubblica, chiunque vuole comunicare con me usi la chiave pubblica e cifra con quella chiave il messaggio che deve inviare, sapendo che solo noi con la chiave privata possiamo decifrare

il messaggio. Quindi se un utente vuole comunicare con noi ci deve mandare la sua chiave pubblica e poi si comunica in maniera privata.

A questo punto possiamo usare algoritmi di cifratura a chiavi privata per scambiare le chiavi pubbliche che saranno usate poi per fare la comunicazione con chiave simmetrica.



Anche in questo caso potremmo riscontrare un attacco di Man in the middle, in quanto se un persona intercetta il messaggio e manda la sua chiave pubblica per far cifare il messaggio a questo punto solo lui può decifrare il messaggio inviato da Billy cifrato con la chiave pubblica del man in the middle.



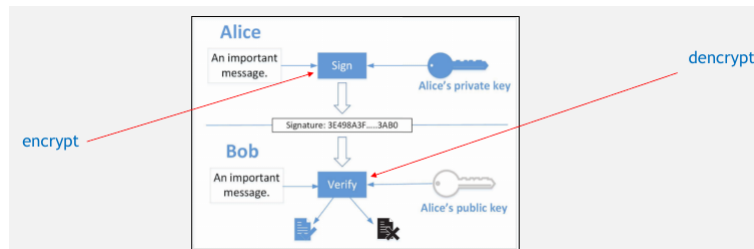
8.3.3 Firma digitale

Modificando un messaggio con la chiave privata garantiamo il fatto che quel messaggio l'abbiamo generato noi, perché solo noi abbiamo la chiave privata, quindi è l'equivalente della firma. La firma digitale si ottiene facendo firmare ad un utente il documento con la propria chiave privata e garantisce l'autenticità di quel documento.

8.3.4 Protocolli

Gli algoritmi usati nell'ambito della crittografia a chiave pubblica:

- RSA: la chiave privata viaggia sulla dimensione dei 2024 byte



- El Gamal
- DSS: algoritmo di firma digitale in USA
- Elliptic Curves (ECC)

8.3.5 Secret vs. Public

Le chiavi sono grosse per la crittografia asimmetrica che e' anche molto piu' lenta.

8.3.6 Scambio di chiavi

Supponiamo di voler scambiare una chiave con un collega (crittografia simmetrica) entrambi abbiamo una coppia di chiavi asimmetriche, quindi si inviano le chiavi pubbliche.

Se c'e' un man in the middle che ascolta la conversazione manda la sua chiave pubblica, in questo modo gli utenti cripteranno i messaggi con la sua chiave pubblica e lui potra' leggere tutti i loro messaggi. Per risolvere questo problema sono state istituiti degli enti che verificano la veridicit  delle chiavi pubbliche (certification authority).

8.4 One-way hash functions

Una funzione hash e' una funzione che prende in input una stringa e restituisce un numero, solitamente nel contesto degli algoritmi vengono usate per fare ricerche tabellari. Nel contesto della crittografia sono un po' piu' complicate. E' una funzione matematica che mappa qualunque stringa di bits in maniera arbitraria e genera una stringa di output di una certa dimensione, anche chiamata impronta digitale.

Una funzione di hash e' perfetta se e' a senso unico (one way), ovvero che e' facile da calcolare ma e' difficile da invertire, se dato l'elemento del codominio non riusciamo a risalire all'elemento del dominio che l'ha generato.

8.4.1 Proprieta' delle funzioni one-way

Non esistono praticamente funzioni one-way. Alle funzioni one-way che usiamo in crittografia chiediamo che siano collision resistant, le collisioni si verificano quando pi  elementi del dominio vengono mappati sullo stesso elemento del codominio, vuol dire che avvengono poche collisioni.

8.4.2 Verifica di integrita'

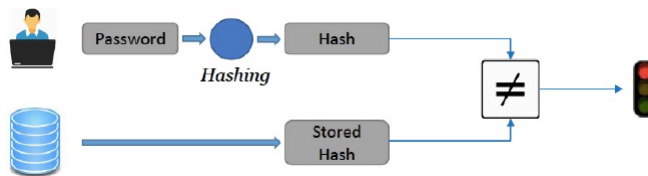
Le funzioni di hash servono per verificare che un documento non sia stato modificato ma sia ancora nella sua forma originale. Quello che si fa e' che vengono rilasciati i valori di hash e quando scarichiamo un documento verifichiamo che i valori coincidano. Nell'esempio vediamo che cambiando un singolo valore della stringa il risultato della funzione di hash cambia completamente.

```
$ echo -n "Hello World" | sha256sum
a591a6d40bf420404a011733cfb7b190d62c65bf0bcda32b57b277d9ad9f146e

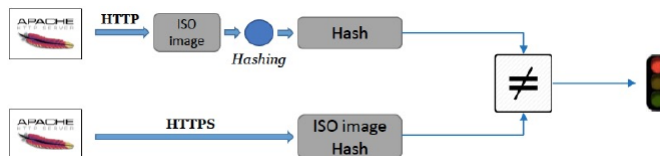
$ echo -n "Hallo World" | sha256sum
d87774ec4a1052afb269355d6151cbd39946d3fe16716ff5bec4a7a631c6a7a8
```

8.4.3 Hash application

Quando dobbiamo digitare una password la password viene memorizzata usando una funzione di hash.



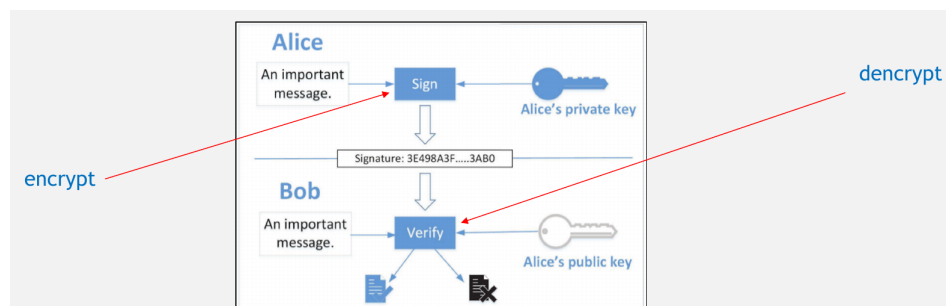
Inoltre si usa anche per il software distribution. Quando scarichiamo una distribuzione di un software (ad esempio una distro linux) dobbiamo avere la garanzia che sia quella che è stata generata dall'autore, quindi posso controllarla passandola in una funzione di hash.



8.4.4 Firma digitale più efficiente

L'hash si usa anche nel contesto della firma digitale, si calcola l'hash e si firma quello.

Prendo il documento da firmare, faccio l'hash e lo cifro con la mia chiave privata. Questo consente di velocizzare significativamente il processo di firma digitale.

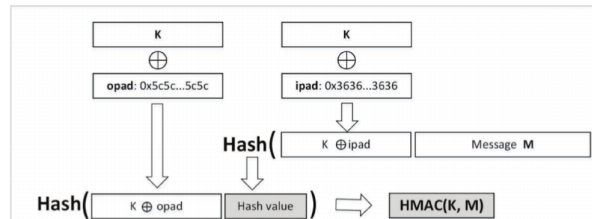


8.4.5 Funzioni hash famose

- MD5: che non si usa più, perché veniva meno la proprietà di collision resistance. Da un output di 128 bits.
- SHA1, da in output 160 bits
- SHA2, da in outputs 224, 256, 384 e 512 bits, non si sono ancora riscontrati problemi di sicurezza con questa funzione

8.4.6 Funzione di hash con chiave (HMAC)

HMAC e' la procedura che viene attuata su ogni pacchetto che esce dalla macchina nel web. C'e' una chiave condivisa tra mittente e destinatario, vengono fatte due passate, prima lo XOR tra la chiave e un i_pad e calcoliamo l'hash di questo. Dopo di che prendiamo la chiave messa in XOR con una stringa che si chiama o_pad che mettiamo insieme all'hash e poi spediamo. Ed e' fatto per evitare che il man in the middle interferisca con le operazioni.



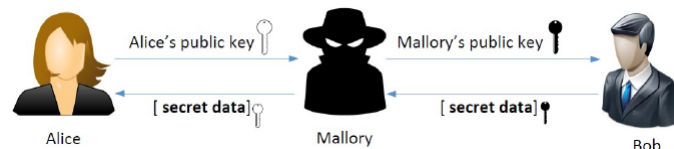
Non tutte le comunicazioni in rete sono sicure.

Usando la crittografia siamo in grado di risolvere i problemi di confidenzialita' e integrita'.

8.5 Certification authority

8.5.1 Man in the middle attack

Dobbiamo evitare di ricevere una chiave pubblica che e' di qualcun altro.

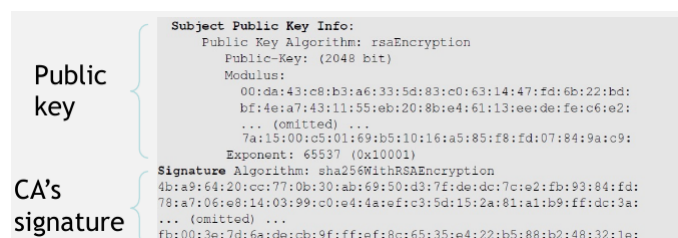


L'unica soluzione trovata per risolvere questo problema e' quella di avere un ente superiore che rilascia un certificato di validita' che attesti la validita' della chiave che riceviamo. Le certification authority, sono degli enti che rilasciano dei certificati digitali che attestano l'appartenenza di una chiave pubblica ad una certa entita', hanno un formato standard x509.

8.5.2 x509 and PKI (publik key infrastructure)

Una certification authority e' una parte fidata il cui scopo principale e' verificare l'identita' di un soggetto ed associare l'identita' del soggetto ad una chiave pubblica. Esistono una gerarchia di certification authority, e l'insieme delle infrastrutture che gestiscono la vita dei certificati sono dette public infrastructure.

Il certificato digitale è il documento che certifica che la chiave pubblica appartiene ad un determinato soggetto, è importante che questo certificato non deve poter essere modificato.



Abbiamo anche la possibilità di vedere nel browser i certificati che abbiamo.

8.6 GNU Privacy Guard

Esiste anche un altro standard per la PKI (public key infrastructure) che è stata sviluppata con lo scopo di non necessitare un'autorità centrale che garantisce la certificazione delle chiavi, ma si basa sulla relazione tra le "persone normali".

8.6.1 Web of trust

Il livello di veridicità di una chiave pubblica lo decidiamo noi in base a quante persone l'hanno verificata, in base a quante firme hanno. Quello che succede è che non si distingue tra persone ed autorità, ma ognuno può firmare la chiave di una altra persona. Garantiamo quindi l'identità di una persona firmando la sua chiave.

Chapter 9

Laboratorio GPG

Useremo GPG e' una permutazione di OpenPGP ed e' di GNU. GPG molti casi viene usato in automatico perche' ogni volta che installiamo un pacchetto vengono controllate le chiavi. Un client di posta puo' essere configurato in automatico per firmare automaticamente le mail.

Per generare una chiave usiamo il comando `gpg --generate-key` in cui mettiamo nome utente, mail ed una password.

con `gpg --list-keys` ci da un po' di informazioni interessanti come ad esempio l'algoritmo usato per cifrare la chiave. In uid tra parentesi abbiamo la validity della chiave e dato che l'abbiamo generata noi siamo abbastanza sicuri che sia valida. Tra PUD e UID c'e' una finger print che e' un identificatore univoco della chiave, e' un modo per verificare che se siamo in contatto con qualcuno la chiave che stiamo ricevendo e' la stessa che abbiamo importato.

Possiamo fare `gpg --edit-key <UID>`, da questo prompt di comandi possiamo ad esempio scrivendo `trust` possiamo settare la trust di una chiave.

Un altro processo fondamentale del web of trust e' firmare la chiave, lo possiamo farlo sign dopo il comando `edit-key`, possiamo anche revocare le firme sulla chiave con `revsign`.

Ci manca come prendere una chiave da qualche parte, ci sono due modi: l'import e l'export delle chiavi. Importare una chiave l'aggiunge al keyring che e' il database delle file. Import nome file ed aggiungiamo la file. Per esportare la chiave possiamo farlo facendo `gpg --export`. Se facciamo `gpg --output jnomeFile;`.

Possiamo mandare le nostre chiavi ad un keyserver (keyserver.ubuntu.com) accediamo ad una serie di operazioni che possiamo fare con il server. Prendere direttamente una chiave da un keyserver non e' intelligente senza conoscere la persone perche' chiunque puo' mandare una chiave a nostro nome.

Se vogliamo firmare una chiave di qualcuno per validarla dobbiamo prima firmarla e poi inviarla al keyserver.

9.1 Encrypt Data

Possiamo usare le chiavi per cifrare un file. Possiamo specificare con `-r` la chiave pubblica della persona con cui firmare.

Per decifrare possiamo fare `decrypt` ed attenzione ad utilizzare la chiave giusta specificando `--local-user` per decifrare il messaggio che abbiamo ricevuto.

Analogamente c'e' il `gpg --sign`.

9.2 Revocare una chaive

Se dobbiamo revocare una chiave, ad esempio se perdiamo il computer e non abbiamo dischi criptati qualcuno puo' avere le nostre chiavi private e puo' impersonificarci.

Possiamo creare un `revoke certificate` che quando viene imporato nel keyring una chiave che revoca quello che c'e'. Quindi quello che ci serve per revocare una chiave e' il certificato di revoca e la nostra chiave pubblica.

Chapter 10

Identificazione ed autenticazione

Vanno trovati dei meccanismi automatici per il riconoscimento delle persone. Nella fase di autenticazione l'utente dichiara chi e', nella fase di autenticazione dimostra di essere davvero chi a dichiarato di essere.

10.1 Identita'

E' una stringa scelta dall'utente. Solitamente la login id e' usato per l'identificazione del sistema, che devono essere univoche all'interno del sistema. Ovviamente non e' sufficiente per riconoscere un utente, di conseguenza il riconoscimento all'interno di un sistema non e' ristretto solo alle persone, ma anche ai calcolatori (server).

10.2 Autenticazione

E' il processo adottato per verificare che l'utente non stia mentendo quando dichiara la sua identita'. Ci sono tre paradigmi:

- What you know: un segreto condiviso tra l'utente ed il sistema
- What you have: Un oggetto che il sistema sa appartenere ad un determinato utente
- What you are: una caratteristica dell'utente

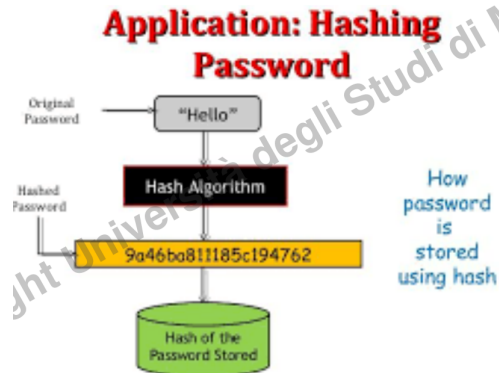
10.2.1 What you know

All'utente viene richiesto di condividere un segreto con il calcolatore, la password.

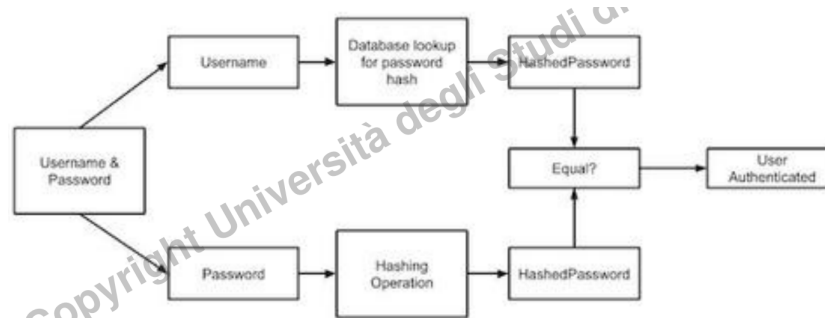
Il problema della password e' che viene definita dall'utente, viene poi conservata dal sistema operativo in un file che e' il file delle password. Questo file e' solitamente protetto in lettura per evitare che altri utenti possano acquisire il valore della password e quindi effettuare un attacco di impersonificazione. Come viene protetto:

- Cryptographic
- Accesso control del OS

Nei sistemi viene memorizzato l'hash della password.



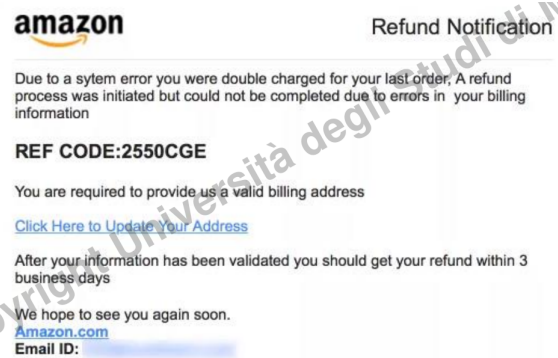
Quando dobbiamo fare l'accesso quindi il sistema fa l'hash della password che inseriamo e va a verificare che questo hash corrisponde all'hash salvato nel file delle password corrispondente all'utente.



Ovviamente solo utenti con privilegi possono scrivere sul file delle password, esistono attacchi che cambiano tutto il file delle password.

10.2.2 Vulnerabilit  delle password

Il problema   che gli utenti scelgono password facili da indovinare e spesso le condividono. Quindi non   il meccanismo delle password scorretto, ma l'applicazione del meccanismo. Ci sono diversi meccanismi per ottenere le password, si va dal social engineering oppure si sbirciano (letteralmente) o si cerca di indovinarle.



Se non si riesce con queste forme di attacco elementari ci sono degli attacchi pi  robusti, chiamati high tech:

- brute force attack
- dictionary attack
- rainbow attack

Notiamo che tutti questi metodi implicano che l'attaccante possieda il file delle password.

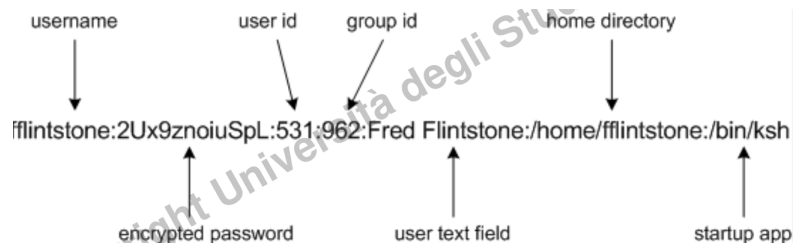


Figure 10.1: Vecchio file delle password in UNIX

Le password cifrate si trovano nel file shadow:

vivek:\$1\$fnfffc\$P\$GteyHdicpGOfffXX4ow#5:13064:0:99999:7:::

Brute force attack

Si fa un programma e si prova una password alla volta, provando tutte le combinazioni di numeri, lettere e caratteri speciali. Ma se la password e' lunga e' lunghissimo trovarla. Esistono delle tecniche per raffinare questa tecnica perche' le persone usano password abbastanza facili.

```
import hashlib
import itertools

# possible characters in user password
ALPHABET = "abcdefghijklmnopqrstuvwxyzABCDEFGHIJKLMNOPQRSTUVWXYZ1234567890_-.;#@#"

# password length
LENGTH = 6

def md5hash(char_sequence):
    string = ''.join(char_sequence)
    hash_object = hashlib.md5(string.encode())
    return hash_object.hexdigest()

# bruteforce
for word in itertools.product(ALPHABET, repeat=LENGTH):
    generated_hash = md5hash(word)
    if generated_hash in data:
        print('The password of user', data[generated_hash], 'is:', word)
```

Case-Insensitive Passwords		
Number of characters	Odds of cracking: 1 in	Estimated time to crack
1	68	0.000009 second
2	4624	0.0006 second
3	314,432	0.04 second
4	21,381,376	2.7 seconds
5	1,453,933,568	3 minutes, 2 seconds
6	98,867,482,624	3 hours, 26 minutes
7	6,722,988,818,432	9 days, 17 hours, 26 minutes
8	457,163,239,653,376	1 year, 10 months, 1 day
9	31,087,100,296,429,600	124 years, 11 months, 5 days
10	2,113,922,820,157,210,000	8495 years, 4 months, 17 days

Dictionary attack

Sono stati creati dei dizionari in cui ci sono parole piu' o meno note e si provano queste. Ci sono dei programmi che li fanno, hanno in input il file delle password cifrate ed il dizionario e cercano se all'interno delle password ci sono parole del dizionario. Statisticamente indovnano il 20% delle password presenti nel file delle password.

10.3 Something you are: biometria

L'idea e' di usare delle caratteristiche biometriche di una persona per riconoscerla. Generalmente sistemi di riconoscimento biometrico incorporano dei sensori o scanner per leggere le informazioni.



I problemi:

- Intrusivo
- Costoso
- Single point of failure
- Falsi negativi
- Falsi positivi
- Lentezza

Tutti i sistemi biometrici usano degli esempi e stabiliscono un threshold per capire se accettare o no il dato in base a quanto matcha con gli esempi, un algoritmo ottimo ha pochi falsi positivi e tanti veri positivi

Spoofing

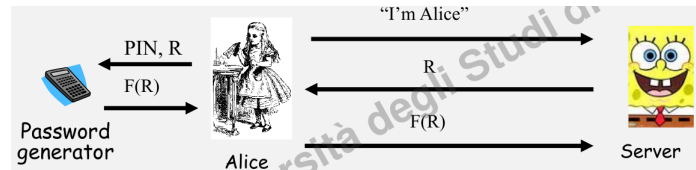
E' un attacco di impersonificazione, vengo ricreati dei tratti biometrici dell'utente per poterli utilizzare al suo posto (falsa iride, dito)

10.3.1 Something you have

L'utente deve fornire dei token, ad esempio la carta di credito, il possesso della carta e' in qualche modo il fatto che siamo noi le persone che trasportano la carta. In generale distinguiamo tra token attivi e passivi. I primi creano un'altra chiave per potersi identificare mentre i secondi fungono da storage per la chiave di identificazione.

I token passivi oramai non si usano quasi piu' e sono proprio dei device che non fanno nessun tipo di elaborazione. I token attivi fanno qualche tipo di operazione. Ad esempio gli OTP (one time password generator) servono perche' quando mandiamo una richiesta al server allegiamo anche la password generata ed il server capisce che noi possediamo il generatore di password.

Le smart card (bancomat) incorporano un circuito integrato (ed eventualmente un microprocessore) che tiene la chiave, quindi garantisce un'autenticazione sicura. I token sono vulnerabili all'attacco di SKIMMING che consiste nel copiare il token di accesso.

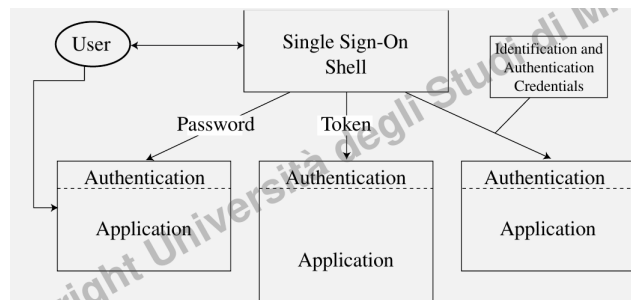


10.4 Strong authentication

Esiste anche l'autenticazione a multifattore. Due forme di autenticazione sono presumibilmente meglio di una.

10.5 SSO (single sign one)

Quello che succede è che quando un utente si registra all'interno di un dominio dell'organizzazione, la soluzione SSO gli permette di fare il login ad altre applicazioni senza dover reinserire le sue credenziali.



10.5.1 OpenID

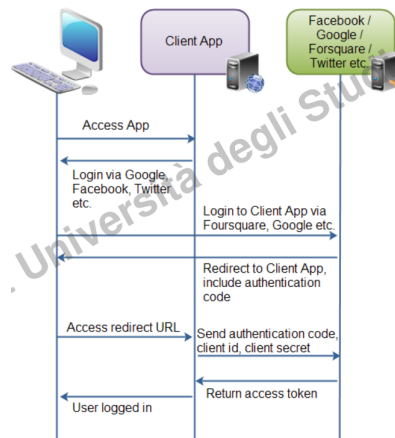
E' uno standard che permette agli utenti di autenticarsi in siti che cooperano tramite un servizio di terze parti senza la necessità di avere identità separate e password diverse per ogni sito. L'utente crea un account selezionando un OpenId identity provider e usa quell'account per registrarsi all'interno dei siti che accettano OpenId authentication.

10.5.2 OAuth

E' uno standard per la delega degli accessi, comunemente usato per accedere a siti che prendono le informazioni di accesso da altri siti, senza che l'utente debba ripetere il login. (amazon, google, facebook...).

OAuth2 steps:

1. Una web app abilita il servizio OAuth-enabled app di una particolare compagnia (come facebook o github) ed ottiene un secret e un ID
2. Un utente vuole registrarsi su questa app, può utilizzare il login tramite OAuth
3. L'utente viene reindirizzato sull'app che garantisce il servizio e deve decidere se condividere le informazioni con la web app in cui si vuole registrare
4. Se decide di condividere viene reindirizzato alla web app in cui voleva registrarsi con un Authorization Code
5. La web app passa l'Authorization Code con il suo Secret all'app che garantisce il servizio OAuth, la quale restituisce il Security Token



Chapter 11

Controllo degli accessi

Vogliamo evitare che degli intrusi accedano ad informazioni sui nostri calcolatori o server. Abbiamo già visto una prima barriera nei meccanismi di autenticazione, servono per far accedere alle risorse del sistema solo le persone autorizzate, lo facciamo assegnando alle persone dei token (password e' semplice). Una volta individuato chi entra nel sistema dobbiamo decidere cos'e' autorizzato a fare questa persona, quindi non tutti gli utenti sono uguali nel contesto della sicurezza.

Possiamo introdurre una serie di strumenti:

- Politiche di sicurezza
- Controllo accesso
- Audit

Tutto questo fa riferimento a Lampson che intorno agli anni 70 dice che ci sono 3 meccanismi di base per implementare la sicurezza

- Autenticazione
- Autorizzazione
- Audit

Autorizzazione si tratta di rispondere a "chi puo fare cosa?". Non e' una cosa particolarmente complessa perche' noi la facciamo regolarmente sui social e risorse. E' un processo, dati una serie di utenti e risorse chi puo' vedere cosa.

Decidere chi puo' vedere un nostro post equivale a fare il controllo degli accessi. O ad esempio un'applicazione ci chiede gli accessi a varie componenti del telefono. Ogni volta che dobbiamo fare un'applicazione o sito dobbiamo porci il problema del controllo degli accessi, quindi abbiamo bisogno di strumenti per fare questa cosa. Ricordiamo che e' un operazione di base che sta sotto qualunque applicativo. Diamo della terminologia:

- Soggetti: sono tutte le entita' che possono svolgere delle azioni (che sono attive all'interno di un sistema).
- Oggetti: sono risorse che contengono informazioni che possono essere condivise (ad esempio un file, un post, una stampante condivisa ...)
- Operazioni di accesso (diritti): operazioni che i soggetti possono compiere sugli oggetti

11.1 Policy

Come facciamo a creare il controllo degli accessi? L'elemento alla base di tutto e' la policy, la politica di sicurezza e' un documento (nelle risorse facebook ce lo abbiamo in testa, questo amico puo' accedere a questi documenti etc). Sono i documenti che elencano per ogni utente quali sono le operazioni che puo' fare, dopo di che questo documento va dato al system administrator che provvede a fare la configurazione del sistema.

Determina chi puo' fare cosa all'interno del sistema, e il sistema viene violato in termini di sicurezza quando le regole nella policy non vengono piu' rispettate. Quindi la sicurezza non e' un valore assoluto ma dipende dalla politica di sicurezza. (universita' pubblica le ricerche, le industrie sono segrete).

11.2 Access Control

Data la policy possiamo procedere al controllo degli accessi. Quindi il controllo degli accessi e' la prevenzione di un accesso non autorizzato ad una risorsa inoltre deve includere la prevenzione ad un uso non autorizzato alla risorsa (ad esempio se abbiamo concesso l'accesso in lettura deve rimanere lettura).

11.3 Chi definisce la security policy

Ci sono tre approcci per il controllo degli accessi:

- L'accesso discrezionale (DAC): in questo caso e' il proprietario della risorsa che decide chi puo' accedere o meno alle sue risorse, e' quello che stiamo usando su Facebook, e' anche il criterio di accesso presente sui file system dei sistemi operativi mainstream.
- Mandatory access contro (mandatorio MAC): in questo caso le risorse vengono governate da un entita' superiore che decide per noi cosa gli altri possono fare con le risorse, come se noi generiamo un post ma e' facebook chi decide per noi chi puo' accedere a vedere o no. E' tipico degli ambienti militari, in cui i documenti vengono classificati in funzione del contenuto.
- politica legata sui ruoli (RBAC role based access control): possiamo assegnare dei ruoli a degli utenti ed il ruolo implica le operazioni che gli utenti possono fare.

In pratica e' quella componente che regola gli accessi alle risorse del computer. Lo stesso discorso vale ovviamente anche per i programmi che vanno in esecuzione e per fare questo deve avere le giuste autorizzazioni, ed e' questo meccanismo che chi attacca un computer deve scavalcare.

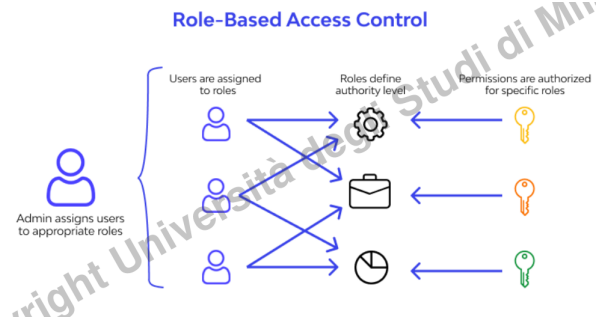
11.4 Definire il controllo degli accessi

Come facciamo a definire chi puo' fare cosa all'interno di un calcolatore? Equivale ad una matrice in cui abbiamo gli utenti e le risorse sulle righe, all'incrocio c'e' l'operazione che l'utente puo' fare sulla risorsa. Dobbiamo in qualche modo comunicare al calcolatore qual'e' la nostra politica, quindi abbiamo bisogno di trasferire questa informazione all'interno del calcolatore in modo che lui faccia i controlli.

	BIBLIOG	TEMP	F	HELPTXT	C_COMP	LINKER	SYS_CLOCK	PRINTER
USER A	ORW	ORW	ORW	R	X	X	R	W
USER B	R	-	-	R	X	X	R	W
USER S	RW	-	R	R	X	X	R	W
USER T	-	-	-	R	X	X	R	W
SYS_MGR	-	-	-	RW	OX	OX	ORW	O
USER_SVCS	-	-	-	O	X	X	R	W

Adesso il nostro problema e' come facciamo a caricare all'interno del calcolatore questo tipo di informazione? Ovviamente la matrice non puo' essere caricata, perche' la matrice e' gigante (ad esempio per un'organizzazione con 50000 dipendenti e 300 file la matrice avrebbe 15 milioni di righe), quindi dal punto di vista implementativo si pone il problema di come facciamo a fare stare questa matrice all'interno del calcolatore. Si parte dalla considerazione che questa e' una matrice fortemente sparsa (la maggioranza degli elementi sono vuoti), quindi si usano alcune strategie:

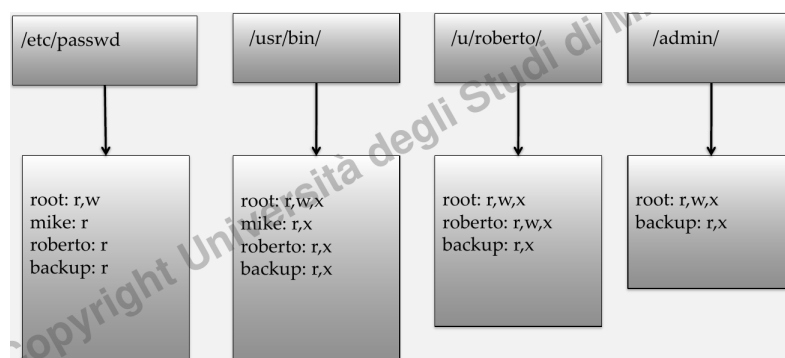
- Accorpate gli utenti (gruppo): permette di ridurre il numero di righe
- Dare dei ruoli e quindi trasformare il controllo degli accessi in RBAC (role based)



	Admin	Editor	Moderator	Advertiser	Analyst
Manage Page roles and settings	✓				
Edit the Page and add apps	✓	✓			
Create and delete posts as the Page	✓	✓			
Send messages as the Page	✓	✓	✓		
Respond to and delete comments and posts to the Page	✓	✓	✓		
Remove and ban people from the Page	✓	✓	✓		
Create ads, promotions or boosted posts	✓	✓	✓	✓	
View insights	✓	✓	✓	✓	✓
View Page Quality tab	✓	✓	✓	✓	✓
See who published as the Page	✓	✓	✓	✓	✓
Publish and manage jobs	✓	✓			
Turn on job features for a post	✓	✓			

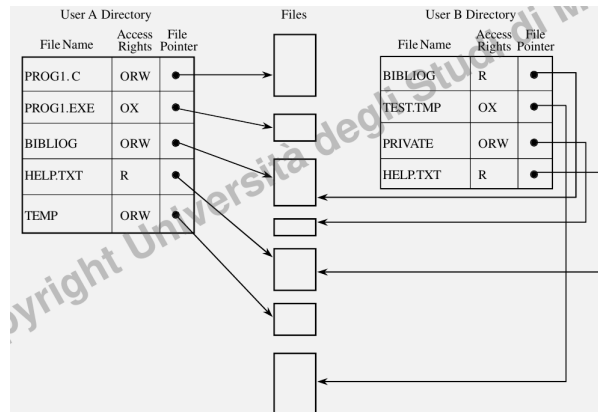
11.5 Access Control List

I sistemi operativi non usano ancora il RBAC, siamo rimasti al mondo in cui ci sono gli utenti o i gruppi che accedono alle risorse (a differenza di quello che succede nei social network). In questo caso, dato che l'access control matrix non può stare in memoria, vengono memorizzate le sue colonne, quindi quando creo un file ad ogni file associo l'access control list. Quindi ogni risorsa all'interno di un sistema ha all'interno dei metadati al cui interno ci mettiamo l'access control list. Quindi quando chiediamo l'accesso il OS va a vedere nell'access control list e vede se l'utente è presente o meno. Quindi atomizziamo la matrice di controllo degli accessi per colonne ed ogni elemento della colonna lo mettiamo nei metadati del file.



Viene implementata fortemente dai file system (r è l'accesso in lettura, w in scrittura ed

x di esecuzione).



11.6 Capability

Sono un altro modo per fare il controllo degli accessi e sistemi come windows le usano per fare il controllo alle risorse tipo memoria o stampante. E' una stringa particolare firmata digitalmente (token) che descrive le operazione che un processo od un utente puo' fare nel sistema. A livello intuitivo un biglietto del cinema è una capability per guardare il film, così come la chiave è una capability per entrare in casa, Quando ci logghiamo se la password e' corretta il sistema genera una stringa, la quale viene presentata dal processo ogni volta che deve richiedere delle risorse, quindi il token e' in qualche modo riconducibile alla chiave di casa, per poter entrare dobbiamo mostrare la nostra capability (la chiave). La capability è messa nel kernel (process data structure) in modo che l'utente non possa modificarla. Il token potrebbe anche essere usato per l'accesso ai file, ma non lo si fa perche' e' troppo dispendioso.

Ci sono i pro ed i contro dell'ACL vs Capability: Abbiamo Alice che dispone di 3 cassette di sicurezza e vuole che degli amici ci accedano al posto suo, c'e' quindi da fare il controllo degli accessi. Ci sono due approcci:

- La banca tiene un elenco delle persone che possono accedere alle cassette di sicurezza, ACL
- La banca da ad Alice delle chiavi per aprire le cassette di sicurezza

Nel caso dell'ACL sulla banca scarichiamo il problema dell'autorizzazione che deve autenticare, deve conservare la lista degli autorizzati in modo che non sia verificata, e' necessario che Alice porti la lista personalmente, se un amico non puo' andare l'operazione non si fa (la delega non puo' essere fatta), se ad un certo punto Alice perde fiducia in un amico per revocargli l'accesso deve andare in banca a revocare l'accesso.

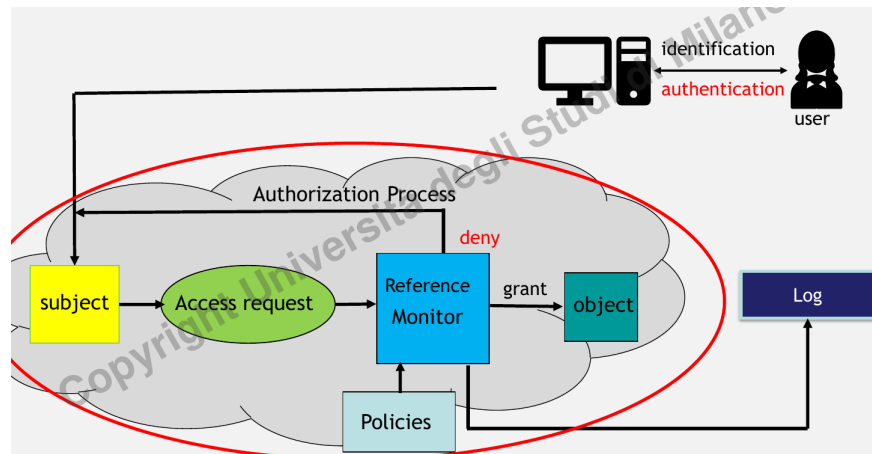
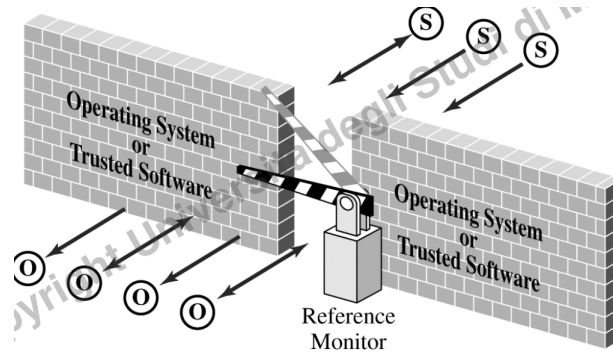
Nel caso della capability e' un problema di Alice a chi da le chiavi, la banca non deve controllare l'operazione che viene svolta, la banca deve fare in modo che la chiave non possa essere duplicata (token non duplicabile), se si deve aggiungere una nuova persona non e' un problema perche' Alice gli da la chiave, se un amico deve delegare qualcun'altro gli passa la chiave, lo stesso vale per la revoca.

Le capability sono piu' flessibili delle ACL ma sono difficili da implementare.

11.7 REFERENCE MONITOR

Qual'e' la componente del calcolatore che verifica la ACL? Ci sono piu' componenti che lo fanno, l'insieme di tutti questi moduli che concorrono al controllo degli accessi REFERENCE

MONITOR, e' quindi la componente di sistema che si fa carico di implementare il controllo degli accessi secondo le politiche definite dal sistema o dagli utenti (nel caso di accesso condizionale). Deve NON ESSERE FACILMENTE ATTACCABILE.



11.8 Auditing

Contemporaneamente il Reference Monitor fa la fase di logging (la terza fase di auditing). L'auditing e' l'attivit  di controllo, si parte dal presupposto che non si riesca a progettare un sistema di protezione perfetto e qualcosa vada storto, ci si mette quindi nella condizione di risalire alla cosa che e' andata storta, e' necessario che quindi tutte le operazioni fatte dal Reference Monitor vengano registrate, genera quindi un record di log. Teoricamente il Reference Monitor e' in grado di memorizzare tutte le operazioni che vengono svolte nel sistema, quindi quando si verifica qualcosa che va male e' possibile andare a ritroso scorrendo il file di log per individuare i motivi dell'operazione che e' andata male.

Quindi il log assumono una rilevanza importante nel contesto della sicurezza, perche' gli attacchi implicano il superamento delle barriere imposte dal meccanismo del controllo degli accessi e per capire quale barriera e' stata superata dobbiamo avere una memoria degli eventi, quello che fanno quelli che attaccano prima di andarsene e' cancellare i file di log.

Quindi l'Audit e' una valutazione dell'infrastruttura di un'organizzazione, gli obbiettivi dell'audit sono valutare i sistemi e processi, l'audit puo' essere fatto come controllo: nelle banche esiste un ufficio dedicato all'internal audit che e' un ufficio che controlla che le filiali operino secondo le politiche dettate dalla banca centrale. Quindi i file di log servono anche come controllo postumo per vedere se non sono stati fatti errori nell'implementazione delle politiche.

I file di log sono file estremamente grossi, abbiamo due fasi principali:

- Raccolta dei dati
- Analisi dei dati: veniva fatta 10 anni fa da degli esperti adesso sono stati realizzati dei sistemi di analisi automatica dei file di log (log analyzer). Attualmente esistono piattaforme dedicate all'analisi dei log che sono in grado di analizzare file di log che arrivano da dispositivi diversi.

Sotto Linux i log si vedono sotto `ls -R etc/var/log`.

Teniamo conto che ogni os ed apparato ha un formato di file di log diverso.

11.8.1 Log management system

Una volta che il log sono stati normalizzati tramite un motore si va a vedere i dati che sono stai analizzati. Esistono varie interfacce più o meno user friendly.

11.9 Unix file system

Per unix qualsiasi periferica e' un file, quindi fare il controllo degli accessi corrisponde a fare il controllo degli accessi sul file. Se scriviamo `ls -la` abbiamo una lista degli accessi per ogni file. Tutti i soggetti devono avere una entry in un file che si chiama `/etc/passwd` e vediamo tutti gli utenti. Tra tutti gli utenti c'e' un super user che si chiama root dopo la x nel root c'e' il user id che e' il numero che il sistema associa all'utente al momento dell'accesso.

11.9.1 Superuser

L'utente con UID 0 e' l'utente piu' potente nel sistema ed e' quello che puo' fare tutto quello che vuole nel sistema. L'unica cosa che non puo' fare e' conosce la password degli utenti, perche' e' memorizzata cifrata.

11.9.2 Groups

Se facciamo `cat /etc/group` avremo i gruppi che fanno parte della nostra macchina. Ogni utente ha un primary group di appartenenza, anche i gruppi hanno un numero, group ID.

11.9.3 I soggetti

I soggetti sono gli utenti, o meglio sono tutti i processi che sono generati dagli utenti, che sono distinti dal process ID. Ricordiamo che un nuovo processo viene generato con la fork. Ogni processo ha assegnato:

- Real UID: ereditato dal processo genitore, tipicamente è l'UID dell'utente registrato che ha generato il processo
- Effective UID: ereditato dal processo genitore o dal file che viene eseguito.

11.9.4 Oggetti

Gli oggetti sono tutte le risorse del computer (sono tutti file in UNIX).

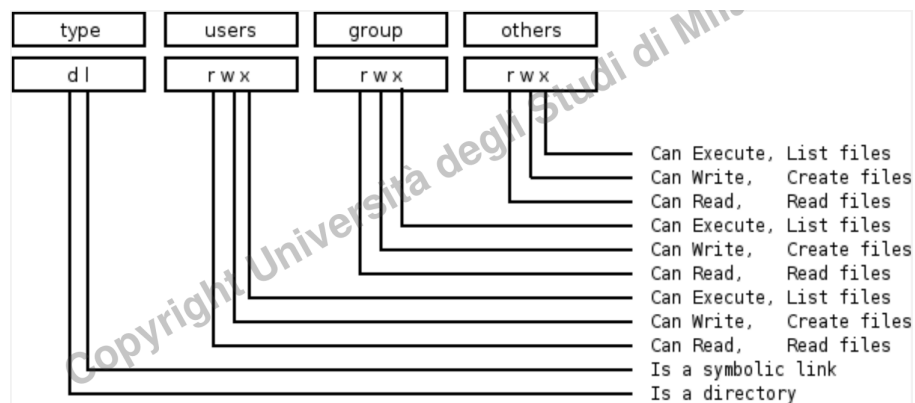
11.9.5 Unix ACLs

Le operazioni consentite da UNIX sono read, write o execute che possono fare gli utenti sul file, quindi per decidere le operazioni di fare su un oggetto abbiamo bisogno di 3 bit.

L'ACL di Unix prevede solo 3 utenti nell'access control matrix :

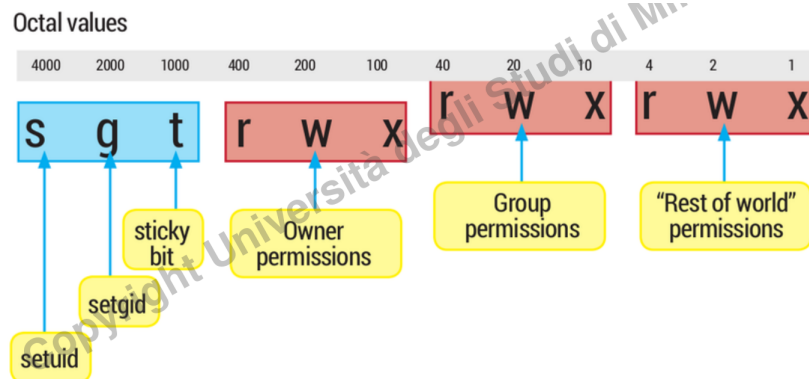
- L'owner della risorsa
- I componenti del gruppo dell owner
- Il resto del mondo

Quindi il controllo degli accessi e' esercitato su questi componenti. Per ognuno di questi soggetti sul file puo' leggere scrivere ed eseguire. Quindi per rappresentare un ACL in questo contesto ho bisogno di 9 bit, ogni ACL di Unix e' composto da 9 bit che e' cosi' formata: il primo campo dice se e' un file normale (l) o una directory (d), poi abbiamo i primi 3 bit che dicono cosa puo' fare il proprietario della risorsa, i secondi 3 dicono quello che puo' fare ogni componente del gruppo appartenente alla risorsa e poi gli ultimi tre il resto del mondo.



L'owner dei file puo' cambiare i permessi usando gli opportuni comandi e la notazione ottale. Per la rappresentazione ottale, ogni gruppo di tre bits puo' essere rappresentato da un numero in rappresentazione ottale, ad esempio:

- rw-r-- è uguale a 644 Owner read/write, Group, Any: read.



11.9.6 CHMOD

e' il comando per cambiare l'accesso al file. ect/shadow ha come permessi 640 e noi se ci entriamo come resto del mondo non possiamo vederlo e modificarlo, e' il file dove Unix tiene le password cifrate degli utenti.

11.9.7 SetUID

Quando scriviamo un programma che fa una write su disco non la scriviamo noi, la fa il sistema operativo, lo si fa con le system call tramite le quali ci è concesso di eseguire pezzi di sistema operativo che è rigidamente controllata dall'os stesso.

Anche nell'accesso ai file è possibile accedere a file di cui non si ha l'autorizzazione per fare operazioni particolari, viene introdotto il meccanismo di set-UID. Si tra le operazioni vuol dire che il file è setUIDato. Quando un programma va in esecuzione in realtà al programma l'os assegna due diversi UID, uno lo va a prendere dal file `etc/passwd` e questo è il real UID, poi fa partire il processo e l'effective UID lo mette uguale al real UID, a questo punto l'UID viene usato per fare il controllo degli accessi. Per i file che sono setUIDati, quando lanciamo un programma l'effective UID associato al programma non è il nostro ma è associato al file del programma che lanciamo. In pratica stiamo eseguendo il file come se fossimo i creatori del file stesso.

Ricordiamo che quando un programma viene eseguito normalmente il RUID è uguale all'EUID, che sono entrambi uguali all'ID dell'utente che sta lanciando il programma. Mentre quando il programma lanciato è setuiddato sono diversi. Perché il RUID è uguale all'ID dell'utente loggato, mentre il EUID è uguale all'ID del creatore (proprietario) del programma.

11.10 UNIX authorization mechanism

Quando l'utente fa il log in viene riconosciuto e gli viene assegnato un ID, l'UID viene assegnato al programma che l'utente manda in esecuzione, in particolare `effectiveUID = realUID`. A questo punto quando un processo fa una richiesta di risorse il reference monitor va a controllare l'effectiveUID del processo, se coincide con l'effectiveUID dell'owner o del gruppo ed infine gli ultimi 3 bit del resto del mondo, per capire quali privilegi concedere all'utente.

Ha la sua deroga nel momento in cui il programma che mandiamo in esecuzione è setUIDato in quanto l'effectiveUID del programma in quel caso sarebbe quello dell'owner.

Chapter 12

Computer Attacks

Abbiamo un utente (alice) ed un attaccante, in mezzo un sistema informatico, l'utente è una persona onesta. L'attaccante è interessato ad acquisire illecitamente informazioni, e quello che può riuscire a fare è compromettere il funzionamento del sistema o intercettare informazioni riservate.

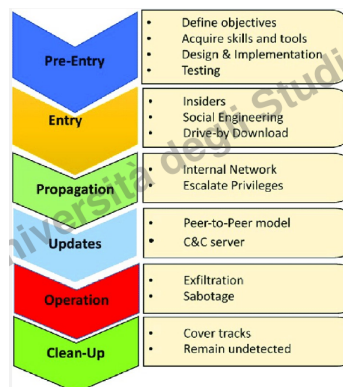
Nell'ambito della sicurezza informatica distinguiamo diversi contesti:

- **network security:** stiamo parlando di un'attaccante che opera esclusivamente sulle componenti di rete. Quindi questa sicurezza si occupa di contrastare tutte le componenti di attacco che si occupano di intercettare il traffico. Assume un ruolo prevalente la web security che è una sua sottobranca, che si concentra sul mondo web. Quindi l'attaccante della web security lavora solo nel mondo web (siti finti, intercettare informazioni sul web, circuire gli utenti attraverso il web) in questo caso l'attaccante non ha accesso al network (i dispositivi di rete).
- **Operating system security:** l'attaccante opera sul sistema operativo, cercando di manomettere il buon funzionamento della macchina.

Più in generale l'obiettivo di chi fa sicurezza è che l'attaccante non riesca ad avere le informazioni segrete e non sia in grado di corrompere il buon funzionamento del sistema.

12.1 Attack Life Cycle

Un attacco viene fatto in più fasi, generalmente viene preparata (pre entry) in cui si studia il contesto che si vuole attaccare, si individua il target e si studia. Studiare l'obiettivo vuol dire capire quali sono le macchine da attaccare, quali sono gli OS che le macchine hanno, quali sono i servizi di rete che le macchine esportano più eventuali altre informazioni. L'obiettivo finale della fase iniziale è individuare i punti deboli, cercando di capire quali sono i punti dove il sistema può essere attaccato. A questo punto viene fatta la prima fase dell'attacco, in cui si cerca di inserire all'interno del sistema che si vuole attaccare un programma, che poi verrà usato per effettuare l'attacco. Una volta che nel sistema c'è un programma che controllo io comincio a guardarmi in giro, ad esempio cerco di diventare amministratore di sistema (privilege escalation), vado a vedere se all'interno della rete ci sono degli host che hanno delle criticità da sfruttare. Si installa solitamente un programma di controllo che acquisisce delle informazioni (server di attacco). Poi inizia l'operazione che può essere di acquisizione di dati o di compromissione del sistema. Quando si è raggiunto l'obiettivo si ripuliscono le tracce o si tenta di nascondersi.



E' composto da più parti, ci sono più componenti software che vengono utilizzate, se l'attacco mira ad acquisire informazioni è il classico di spionaggio ed in questo caso l'attacco e l'attaccante restano nel sistema per parecchio tempo (Advanced Persistence Treat) 2/3 anni.

Per ognuna di queste fasi esistono decine di tecniche in funzione di tutta una serie di parametri.

Una delle tecniche più utilizzate per depositare un software maligno nel sistema è quello di convincere l'utente a sua insaputa di installarlo. Si usa il social engineering.

12.2 Ingegneria sociale

E' una disciplina che studia le tecniche per la manipolazione delle persone, indurre le persone a fare delle azioni che altrimenti non farebbero. Le azioni che interessano a noi:

- Acquisizione di informazioni riservate
- Truffa
- Accesso sistema informatico

Ha delle robuste basi sulla psicologia umana, in particolare interviene in quelli che sono le euristiche decisionali. Che sono dei meccanismi che abbiamo acquisito nella nostra vita, sono delle reazioni istintive che vengono utilizzate quando dobbiamo prendere delle decisioni in situazioni di emergenza. Sono delle scorciatoie mentali che quindi scavalcano il processo razionale di decisione, funzionano bene nella maggior parte delle circostanze ma non sempre.

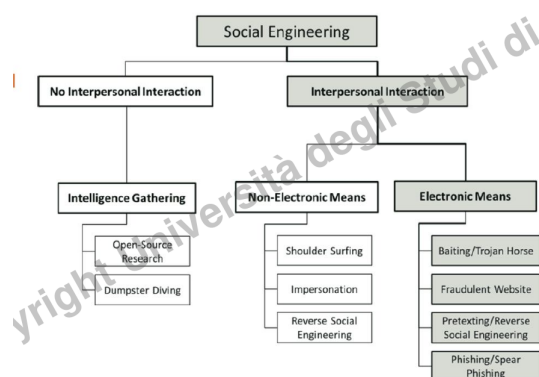
Esempi:

- Ancoraggio: le persone cercano di fare affidamento su esperienze pregresse
- Affetto: si decide in base all'affetto
- Razionalità limitata: la bontà delle decisioni prese è in funzione delle quantità di tempo di cui disponiamo per prenderle
- Affaticamento decisionale: le attività decisionali ripetitive prosciugano le risorse mentali.

Quindi si fa una pressione sull'utente, nel momento in cui l'utente è sotto stress scatta il meccanismo dell'euristica e l'utente potrebbe commettere degli errori non ragionando.

12.2.1 Tecniche

La SE serve sia per indurre un utente a scaricare dei programmi che poi provvedono ad effettuare l'attacco e serve anche in una fase iniziale di acquisizione delle informazioni. Una non chiede interazioni interpersonali, l'altra sì. Il phishing è attualmente il più utilizzato.



12.2.2 Intercettazioni

Servono per predisporre l'attacco, shoulder surfing letteralmente spiare dalle spalle della vittima per ottenere informazioni. Il dumpster diving è meno noto ma si fa, guardare nella spazzatura è una fonte di informazioni riservate ma abbastanza utili.

12.2.3 Phishing

È la forma di SE più utilizzata per attaccare un sistema. L'obiettivo è convincere l'utente a fare click sul link, imbrogliare l'utente e fare in modo che l'utente abbocchi.

Può avere due tipi di finalità:

- Acquisire informazioni: carta di credito, banca, personali
- Utilizzato per indurre l'utente a scaricare dei file

Le informazioni rubate servono per costruire le identità digitali ed accedere agli account dell'utente.

Queste informazioni vengono raccolte da campagne di phishing e poi vengono vendute. Perché sono cose che scottano.

Esistono vari tipi di phishing:

- Mass Phishing: una mail che raggiunge più persone, sono messaggi di massa che vengono mandati per vedere chi abbocca
- Spear Phishing: è un attacco mirato, costruisco dei messaggi particolari per delle persone specifiche
- Whaling: è un tipo particolare di spear phishing ma dove l'utente è una balena, una persona molto importante
- Clone Phishing: copia falsificata di un'email legittima e consegnata in precedenza, con allegati originali o collegamenti ipertestuali sostituiti con versioni dannose, che viene inviata da un indirizzo e-mail contraffatto in modo che sembra provenire dal mittente originale
- Advance fee scam: richiede all'obiettivo di inviare denaro o informazioni sul conto bancario

Esempio della mail covid in cui veniva installato un software per la gestione remota della macchina.

12.3 Intelligenza artificiale

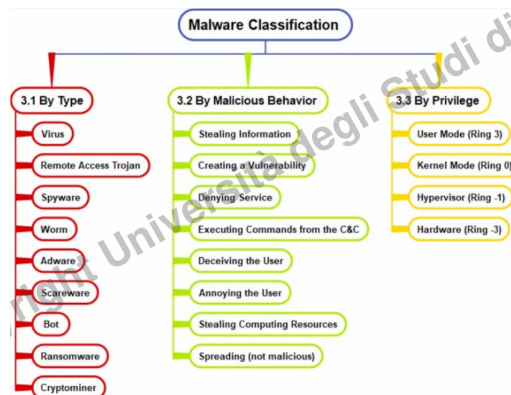
Il phishing va ad attaccare l'utente, sono stati organizzati dei sistemi che scremano molti messaggi di phishing, ma molti attacchi che sono stati fatti partono dal phishing. Che diventano sempre più sofisticati grazie all'intelligenza artificiale, per costruire dei testi sempre più accattivanti per le persone (dividendo le persone in categorie).

Un'altra frontiera è quella del deep fake, che grazie all'intelligenza artificiale permette di fare dei grandi imbrogli.

Notiamo anche che l'avvento dell'intelligenza artificiale ha cambiato l'approccio alla SE, in quanto si possono usare tecniche di intelligenza artificiale, sintesi vocale ed Advance Natural Language Processing per impersonificare qualsiasi persona (esempio Obama).

12.4 Malware

Malicious software, sono programmi pensati specificatamente per distruggere o compromettere il comportamento di un calcolatore. (esempio del codice che genera all'infinito processi figli). Camuffare il malware è la parte principale della SE, è l'utente stesso che lo carica sulla macchina e lo manda in esecuzione. Una volta che il malware viene eseguito diventa un processo, quindi prende i diritti dell'utente che lo ha generato.



Ci sono diverse forme di malware, in funzione dei parametri che si usano per classificarlo. In base ai meccanismi che usa per propagarsi, per nascondersi.

Propagazione:

- Virus: assistenza umana nella propagazione
- Worm: propagazione automatica

Congelamento:

- Rootkit: modifica il sistema operativo per nascondersi
- Trojan: nasconde nei log le funzioni malevole

12.4.1 Logic Bomb

E' un programma che genera delle azioni negative al verificarsi di certe condizioni logiche. Un classico esempio è il crash di un programma in una certa data.

12.4.2 Computer Virus

Prende il nome ed il modo di propagarsi da quelli che sono i virus biologici, che hanno bisogno di un corpo da infettare per potersi replicare, i virus informatici modificano alcuni file e si inseriscono all'interno dei file. Quindi il computer virus non viaggia da solo, per prendere un virus dobbiamo installare un file che contiene il computer virus, quindi infetta un agente ed una volta che viene caricato su un sistema cerca altri file all'interno del sistema da infettare, una volta che si è sufficientemente propagato attacca.

Fasi:

- Fase dormiente: solitamente il virus se ne sta tranquillo per un pò di tempo
- Fase di propagazione: Incomincia a propagarsi infettando nuovi file
- Triggering phase: solitamente il virus parte al verificarsi di alcune condizioni, un virus famoso era michelangelo (che si attivava solo quando era nato michelangelo)
- Action phase: in questa fase il virus fa le azioni negative per cui è stato progettato

Si distinguono in due grosse classi:

- Resident Virus: Risiedono in memoria e quindi restano sempre in esecuzione, in pratica vanno a modificare le system call
- Non residenti, che vengono eseguiti solo quando viene eseguito il file

Su quali principi si basano gli antivirus, signature base, i virus sono dei programmi che sono delle stringhe di zeri e di uno, gli antivirus sono in grado ad individuare delle sottosequenze di zeri e di uno che li contraddistinguono, questa sottosequenza è chiamata signature. Gli antivirus dispongono di un database di signature, che sono tutte le sequenze binarie dei virus che esistono, prima di eseguire un programma l'antivirus controlla la sottostringa e se la trova lo blocca.

I costruttori di virus per evitare questa cosa hanno inventato diverse strategie:

- Encrypted virus: il virus era composto da una routine di encryption decryption ed il virus, veniva cifrato ogni volta con una chiave diversa, quindi ogni volta che il virus si replicava cambiava la chiave di cifratura e quindi il corpo del virus si replicava. Questo rendeva più difficile l'individuazione del virus, ma comunque la componente di encryption decryption doveva rimanere in chiaro, quindi il focus degli antivirus era quella (trovare la chiave).
- Polymorphic virus: erano in grado di cambiare anche la routine di decryption ed encryption. A questo punto salta il meccanismo di detection basato sulle stringhe, perchè non c'è più una sottostringa che individua una classe di bit. In questi casi la detection si fa eseguendo il codice, gli antivirus hanno al loro interno una macchina virtuale in cui eseguono il codice nuovo e vedono che non faccia azioni non autorizzate.
- Metamorphic virus: nei primi due il corpo rimane lo stesso e viene cifrato con chiavi diverse, ora viene anche modificato. Se ne conoscono solo due, la loro realizzazione è particolarmente complessa da realizzare e quindi non è considerata una minaccia.

12.4.3 Computer worm

Ricordiamo che i virus si attaccano ad un programma, quando viene mandato in esecuzione viene eseguito anche il virus. Il computer worm è un virus che non ha bisogno di un agente trasportatore, è in grado di diffondersi senza infettare nessun altro programma. Contrariamente rispetto al virus, il worm non ha bisogno dell'utente che lo mandi in esecuzione, ma attacca autonomamente. I worm sono molto peggio dei virus, perchè l'utente è inconsapevole dell'esecuzione di questi oggetti.

Parte da una macchina e si sposta da una macchina all'altra cercando di infettarle. Alla fine di questa propagazione il worm è presente in un numero abbastanza consistente di macchine.

12.4.4 Trojan Horse

Il trojan il malware viene mascherato da un programma di utilità generale.

12.4.5 Rootkit

Il rootkit è un tipo di malware che serve per nascondersi, va a modificare una serie di applicazioni di sistema, per fare in modo di nascondere i processi del malware.

12.4.6 Bomba logica

E' un programma che esegue qualcosa di maligno al verificarsi di una certa condizione, si fa anche nella vita vera, se prendiamo un software a pagamento e non lo rinnoviamo il programma smette di funzionare, lo fanno mettendo una bomba logica all'interno del programma.

12.4.7 Botnet

Sono dei worm che riescono ad attaccare la macchina ed installano all'interno della macchina un server che riceve comandi da chi ha realizzato un worm, sono di fatto delle reti di calcolatori che ricevono comandi da un server. I programmi di botnet sono difficili da rilevare, hanno dimensioni di 300/400 k, chi controlla la botnet tipicamente vende i servizi, tipicamente vengono affittate a 2k dollari all'ora.

12.4.8 Stuxnet

E' un virus del 2010 il cui obiettivo era controllare, monitorare e sbarellare le centrifughe di arricchimento di uranio delle centrali nucleari Iraniane. Doveva boicottare il funzionamento degli impianti di arricchimento dell'uranio che l'Iran stava allestendo, pare fosse stato realizzato dai servizi segreti americani ed è stato installato tramite una penna USB e durante 2 anni di attività ha messo fuori uso 2000 centrifughe ed ha ritardato il processo di armamento dell'Iran di 2 ann. Usa 4 zero day vulnerabilità.

All'inizio ha installato un rootkit per nascondersi da chi monitorava.

12.4.9 Wannacry

E' uno dei primi ransomware. Ha usato una vulnerabilità famosa chiamata eternal blue, quando si installava questo software la prima cosa che faceva era cifrare una serie di file e poi chiedeva il riscatto. Ha infettato circa 230000 macchine ed hanno guadagnato 150000 dollari di riscatto.

12.5 Antivirus

Sono tendenzialmente di due tipi:

- Signature Base: tengono in un DB le stringhe che caratterizzano un virus
- Execution emulation: provano ad eseguire il programma in una macchina virtuale

Hanno al loro interno una lista di siti di cui fidarsi o di cui non fidarsi.

Il problema di questi antivirus è che per risalire alla signature dobbiamo conoscere il virus, se il virus è zero day non possiamo conoscerlo

12.5.1 Virus total

E' un antivirus online, se prendiamo il file e lo sottoponiamo a virus total e ci fa l'analisi in tempo reale del contenuto.

12.6 Program flaws (bug)

Dobbiamo capire come un programma può essere forzato a fare delle cose per cui non era stato programmato. Questo accade perché i programmi in genere contengono degli errori:

- Istruzione sbagliata
- Definizione dati sbagliata

Questo errore può avere conseguenze dall'insignificante al catastrofico. Un errore può condurre ad una vulnerabilità, che se opportunamente sfruttata può consentire lo svolgimento di operazioni che non sono mai state programmate.

Viene chiamato exploit le procedure che riescono ad avvantaggiarsi di queste vulnerabilità. Le vulnerabilità fanno riferimento agli zero day, che sono delle vulnerabilità all'interno

dei programmi non ancora note, o per lo meno per le quali non esiste una patch correttiva. Trovare exploit zero day è un'attività remunerativa.

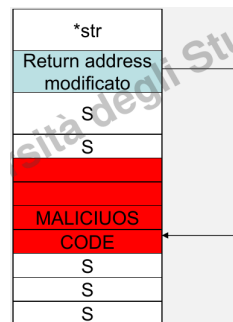
Ma com'è possibile che un errore di un programmatore possa tradursi in un attacco informatico? Vediamo un esempio

12.6.1 Buffer Overflow

E' stata la tecnica più utilizzata fino all'inizio degli anni 2000, ma si usa ancora oggi.

Su molti programmi C è possibile corrompere lo stack scrivendo oltre il limite di un array, il codice che fa questa operazione fa smashing the stack e forza il ritorno della routine ad un indirizzo casuale. Ma noi di un segmentation fault non ci interessa niente, vorremmo sfruttare questa cosa per mandare in esecuzione del codice nostro (vogliamo modificare il return address, tramite il buffer overflow, un indirizzo che faccia mandare in esecuzione il codice che voglio io).

La strategia è caricare il codice che voglio mandare in esecuzione in una zona di memoria particolare, con il buffer overflow mettiamo nel return address l'indirizzo di questa zona di memoria, mandando in esecuzione il programma quando ritornerà salterà all'indirizzo che vogliamo noi.



Tipicamente il codice che metto è l'esecuzione della shell, faccio in modo che quando un programma va in buffer overflow io attaccante mi ritrovi con una shell aperta. Ricordiamo che il programma in C va scritto direttamente in linguaggio macchina (si fa tramite il compilatore).

Tipicamente lo shell code lo si inietta direttamente in un programma che fa input, viene quindi passato come dato di input al programma ed una volta dato in input va a finire sullo stack ed una volta che è lì si tratta solo di indovinare l'indirizzo.

Il programmatore non controlla le dimensioni dei buffer anche varie funzioni del C non lo fanno, e possono quindi essere usate per fare attacchi del tipo buffer overflow. Questa cosa ovviamente si può fare con i codici open source, altrimenti si fa un'operazione di reversing engineering per trovare il sorgente dell'eseguibile. Oppure si sparano dentro valori casuali e se trovo un segmentation fault allora siamo sulla strada giusta.

Quindi sostanzialmente un worm individua dei servizi che sono vulnerabili, gli sparano contro degli input opportuni e compromettono il servizio ed una volta che abbiamo la shell aperta possiamo fargli eseguire qualsiasi programma.

12.6.2 Contromisure

Sono state individuate una serie di contromisure:

- Insegnare ai programmatori di programmare senza errori
- Introdotti a livello di OS dei meccanismi di controllo
- Controllo al compilatore
- Controllo a livello hardware

12.6.3 Randomizzazione

Sostanzialmente fa sì che un programma quando viene caricato in memoria non parte mai dalla stessa locazione, quindi questo rende difficile individuare dove parte lo stack. Per risolvere questo problema fanno uno spary attack, ovvero caricano il codice maligno in più parti possibili sperando di beccare la posizione giusta.

12.6.4 Stack guard

L'idea è di mettere una "guardia" prima del return address. Se a questo punto sbufferiamo per modificare l'indirizzo del return address dobbiamo passare dalla guardia e cambiarne il valore, quindi prima di ritornare controlliamo che sia sempre uguale, se è cambiata allora ho un problema.

E' un meccanismo che va oltre il programmatore, è il compilatore che gestisce la guardia autonomamente.

12.6.5 Non-executable stack

Rendo la zona stack della memoria centrale non eseguibile, quindi concedo solo i diritti di lettura e scrittura ma non di esecuzione. A questo punto la strategia di smashing the stack non funziona più, perchè se ovviamente carico il codice maligno nello stack ma lo stack non è eseguibile il codice non funziona più.

Questa contromisura viene messa in discussione dall'attacco read to lib c, in cui l'attaccante modifica il return address modificato ma ci mette l'indirizzo di un pezzo sistema operativo, quindi prende tutte le istruzioni di sistema e le compone per portare a termine l'attacco.

12.6.6 Data execution prevent

L'hardware marca delle pagine di memoria come non eseguibili. Questo si chiama DEP.

Ormai fare questi tipi di attacchi è molto difficile, la maggior parte degli attacchi è fatta sul web adesso. Comunque la strategia è sempre quella di convincere un utente a scaricare un malware sulla macchina.

Chapter 13

Web Security

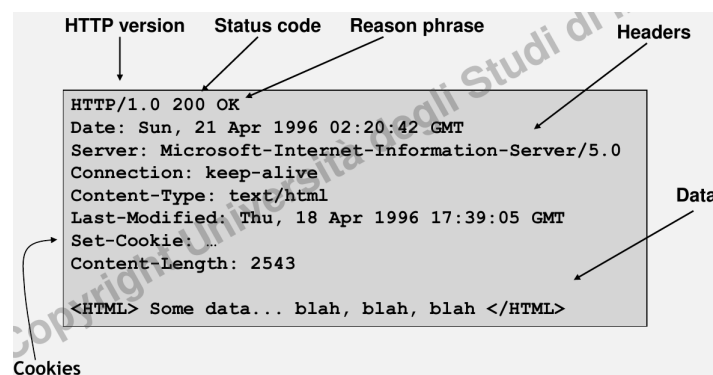
Ovviamente il web è lo strumento usato per la maggior parte delle attività, è uno strato di software che si pone sopra al sistema operativo. Di fatto è un sistema operativo dentro un sistema operativo. Il mondo web è composto da due tipologie di elementi:

- Web site/server: contengono pagine, immagini e informazioni di varia natura
- Web browser: sono in grado di accedere ai contenuti contenuti nel server. Il web browser utilizza il Domain Name System (DNS) per determinare l'indirizzo IP del web server.

L'architettura è client-server, il client accede al servizio e scarica le informazioni. In tutto questo è importante il DNS (domain name system) che serve ad individuare gli indirizzi IP a cui risiedono i vari indirizzi. Quando due entità devono comunicare è importante che stabiliscano un protocollo di comunicazione HTTP (porta 80), che definisce le modalità di comunicazione tra client e server, opera sopra al protocollo TCP, che è il protocollo canonico per la trasmissione in Internet.

13.1 HTTP

Tramite richieste POST o GET mandiamo informazioni marcate tramite HTML. Nell'esempio abbiamo una GET con varie informazioni, ad esempio il tipo di browser, tutte queste cose stanno nell'header. Il contenuto è all'interno della POST. A fronte di questa richiesta manda i dati richiesti nel pacchetto (payload).



HTML consente la definizione di pagine statiche, è in grado di contenere dei link ad altre pagine in altri server, consente all'utente di digitare dei dati di input che vengono mandati attraverso delle form, è un protocollo che non prevede encryption. Successivamente all'HTML sono state aggiunte delle caratteristiche, che servono ad esempio a visualizzare file in un formato diverso dall'HTML. Inoltre tramite JavaScript possiamo rendere dinamiche le

pagine, mettere del codice all'interno di un server o client da la possibilità di far scaricare codice maligno.

Un'altra possibilità data all'utente è di inviare tramite delle form dei dati in input.

13.2 HTTPS

E' una versione di HTTP costruita su un protocollo di crittografia chiamato TLS, quindi il traffico generato sopra HTTPS è cifrato.

13.3 Contenuto dinamico

Per avere contenuto dinamico si usano i linguaggi di script:

- Server side: che vengono interpretati dal server, sono porzioni di codice che vengono interpretati dal server. PHP
- Client side: viene interpretata dal browser. JavaScript

Il codice mobile è codice eseguibile che viene inviato tramite la rete ed eseguito alla destinazione. L'utente manda in esecuzione sulla sua macchina un codice che non ha mai visto, dal punto di vista della sicurezza è un casino, perchè non abbiamo il controllo di quello che succede sulla nostra macchina.

13.4 JavaScript

E' potente perchè consente anche di attivare funzioni al verificarsi di eventi. Il modello dal punto di vista della sicurezza è terribile, perchè appunto scarichiamo codice di terze parti e lo mandiamo in esecuzione, senza possibilità di interferire con questa cosa. Quindi si è corsi ai ripari cogliendo la criticità cercando di restringere le operazioni che un codice JS può fare quando viene scaricato sul calcolatore. Per fare questo ci si è rifatti al modello di sicurezza di Java, quando eseguiamo un codice JS questo non ha accesso alla macchina, ma può solo operare all'interno della pagina HTML (come Java opera nella java virtual machine). Quindi è come se il codice fosse blindato ad operare esclusivamente nel contesto in cui si trova (sandbox). Questa politica di sicurezza fatta in JS viene chiamata anche Same-Origin-Policy, che fa in modo che uno script scaricato da un sito web non possa accedere ad informazioni critiche.

URL of Target Window	Result of Same Origin Check with www.example.com	Reason
http://www.example.com/index.html	Passes	Same domain and protocol
http://www.example.com/other1/other2/index.html	Passes	Same domain and protocol
http://www.example.com:8080/dir/page.html	Does not pass	Different port
http://www2.example.com/dir/page.html	Does not pass	Different server
http://otherdomain.com/	Does not pass	Different domain
ftp://www.example.com/	Does not pass	Different protocol

13.5 Web 1.0

Ogni volta che facciamo un accesso dobbiamo stabilire un canali di comunicazione con il server della pagina a cui accediamo. Questo per dire che il protocollo è STATELESS. Questa è una criticità per chi ad esempio fa commercio elettronico.

13.6 Cookie

Se li sono inventati per aggiungere stato ad HTTP. Sono un meccanismo di autenticazione che fa sì che il server ci riconosca. Il server ha un db in cui le chiavi sono i cookie che mandano all'utente per tenere traccia di quello che aveva fatto l'utente.

Le informazioni che sta all'interno dei cookie è customizzata da server web a server web. Ogni server può caricare sul cookie l'informazione che desidera. Noi facciamo la GET e visitiamo per la prima volta un sito, il quale ci risponde e mette all'interno del messaggio di risposta il comando set-Cookie, che viene preso dal browser e messo nel DB del browser, ogni volta che ci collegheremo al sito web aggiungeremo il cookie che ci hanno mandato all'header HTTP.



Ovviamente possedere un cookie di una persona consente una profilazione dell'utente (perchè capiamo che siti visita l'utente). Nell'arco degli anni i cookie erano usati per tracciare gli utenti, ad esempio ci vengono mandati i cookie di terze parti (ovvero i cookie che non avevamo richiesto ma ci venivano mandati) ora sono stati vietati, o meglio viene chiesto agli utenti se vogliono accettarli (obbligo tramite GDPR). Esistono molte applicazioni che ci dicono quali cookie abbiamo all'interno del browser.

Esistono anche le sessioni per mantenere le informazioni di sessione in HTTP. Il server usa una session ID, che è un identificatore univoco che corrisponde alla sessione di un utente.

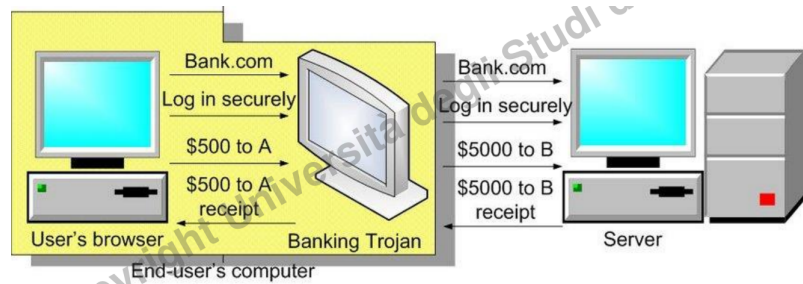
13.7 Attacchi al browser

Le estensioni del browser vengono attaccate, la comunicazione tra client e server ed il codice JS.

13.7.1 Man in the browser

L'attacco più pericoloso è l'attacco man in the browser, è una forma di malware che è in grado di intercettare le comunicazioni all'interno di un browser e modificarle, intercetta il traffico in uscita ed in entrata e lo modifica a suo piacimento. Ci sono dei software da comprare che fanno questi attacchi, il più famoso è Zeus, è un programma che fa malware automaticamente.

E' cattivo perchè è in grado di scavalcare le parti di protezione, tutta la parte di sicurezza (password, impronta digitale, OTP) non serve a niente, perchè il malware sta nel browser, interviene dopo la parte di riconoscimento. Bisogna avere qualcosa che sia esterno al sistema infettato, il PIN mandato sul cellulare.



13.7.2 Click-Jacking

Consiste nel dirottare in qualche modo la pressione del tasto del mouse, verso lo svolgimento di altre attività, si cambia l'azione onMouseUp dell'href cambiando la pagina

13.7.3 IE Image Crash

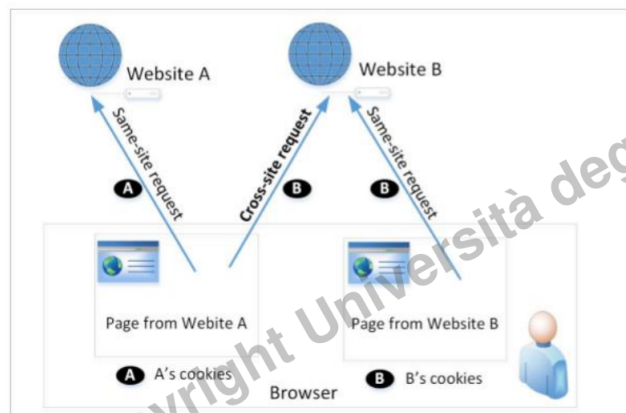
E' un denie of service, fa crashare il browser, gli chiediamo di visualizzare un immagine che non può stare sul nostro video, mentendo width ed height grandissimi.

13.7.4 Vulnerabilità

- SQL Injection: è l'attacco più diffuso sui siti web, il browser manda input malevolo al server, come delle query SQL malevole.
- CSRF - Cross-site request forgery: un sito malevoo manda al browser una request ad un sito normale utilizzando credenziali di una vittima
- XSS - Cross-site scripting: un sito web malevolo manda alla vittima uno script che gli ruba informazioni relative alle sue credenziali su altri siti (cookies)

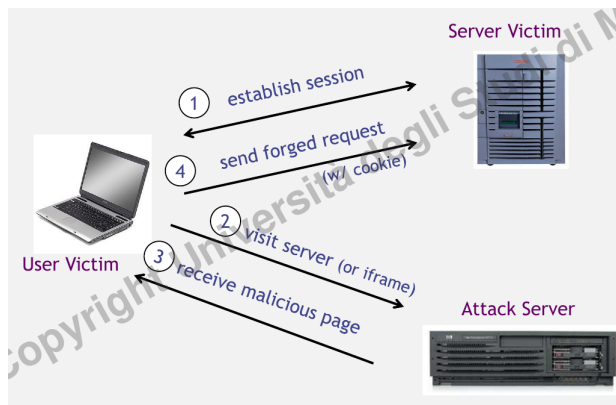
13.7.5 CSRF, Cross Site Requests Forgery

All'interno di una pagina possiamo avere dei riferimenti a siti esterni, questi riferimenti sono cross site, notiamo che quando scarichiamo la pagina da A ed accediamo a B, se già ci eravamo acceduti il browser manda anche il cookie di B. Il server del sito B non riesce a capire se noi arriviamo da un'altro sito o dal computer.



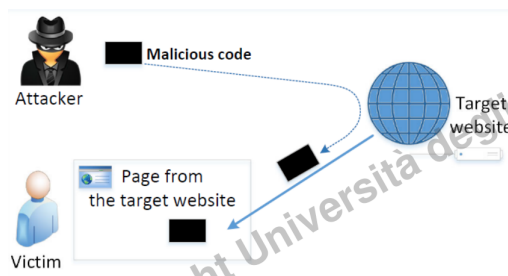
Ci colleghiamo alla nostra banca quindi gli mandiamo il nostro cookie, a questo punto chiediamo di trasferire 500 roiz dal nostro conto, contemporaneamente andiamo a visitare un altro sito, questo sito ci fa scarica l'homepage che contiene uno script JS che dice 'vai a

visitare il sito della banca trasferisci dei soldi sul mio conto' (tipicamente si fa nei tag img, perchè possono mandare richieste GET ad un URL specificato nell'attributo src), dato che avevamo una sessione aperta con la banca la richiesta viene mandata tramite HTTP con il nostro cookie, quindi la banca la accetta. E' abbastanza difficile da fare perchè implica che abbiamo una sessione aperta e contemporaneamente visitiamo un sito maligno.



13.7.6 Cross-Site Scripting

In questo caso un attaccante è in grado di iniettare del codice JS utilizzando un altro sito di appoggio. Non è che si riescono a fare molte cose, la cosa più grave è rubare i cookie di un utente.



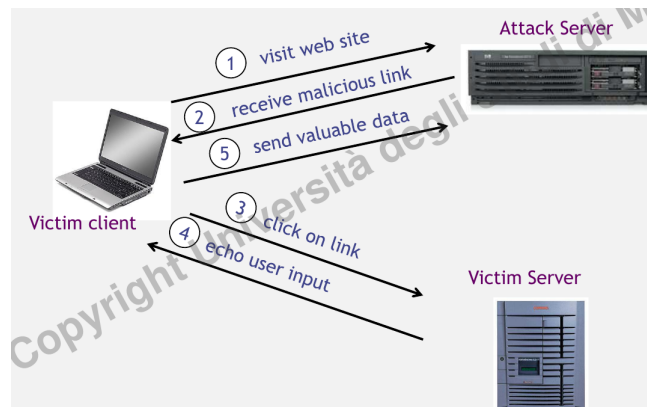
Esistono due tipologie:

- **Stored (persistent):** quando il codice dell'attaccante è memorizzato permanentemente in una pagina web.
- **Reflected:** il codice Js che eseguiamo viene inserito di volta in volta in alcuni campi di input.

Reflected

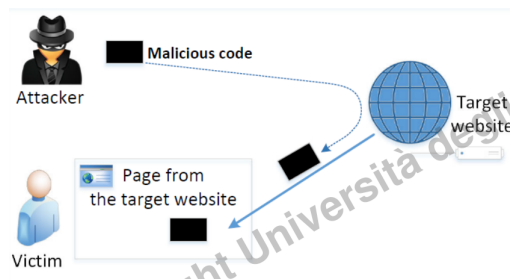
Quello che succede è che se il sito permette di inserire un input possiamo provare a metterci dentro del codice JS, in questo modo quando un'utente visita quella pagina possiamo rubare i suoi cookie. Esempio della modifica della GET, si parla di sanificazione dell'input, non devo tenere buono qualsiasi valore di input, non devo tenere per buono qualsiasi codice che mi arriva dal browser. Ricordiamoci quindi quando scriviamo codice lato server sanificare i dati di input. Esistono dei siti che ci sfidano a fare cross site scripting.

L'utente visita il sito web, riceve il link maligno a questo punto clicca sul link, manda il link malformato al server vittima che restituisce.

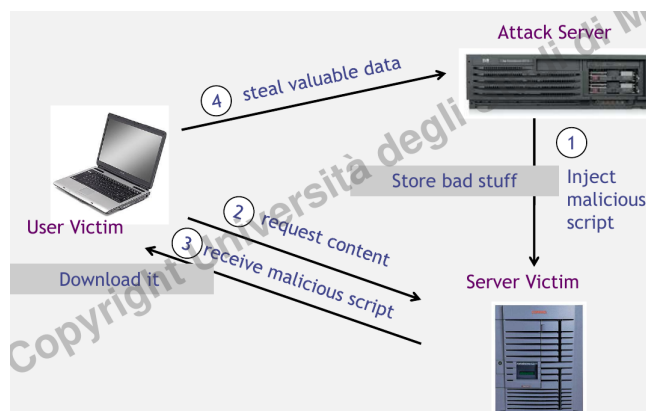


Persistent

Se a livello di programmazione non è stata prevista una sanificazione dell'input capita. L'attaccante manda direttamente lo script ad un taghet (sito) che fa lo storage dei dati in modo persistente, se il sito successivamente manderà i dati ad altri utenti creerà un canale tra gli utenti e l'attaccante.



C'è un sito di profili, ad esempio linkedin, potremmo mettere all'interno del profilo del codice Js che quando qualcuno scarica va in esecuzione.



Per evitarlo ci sono dei dispositivi per fare analisi del traffico, inoltre è necessario sanificare l'input quando mettiamo una form. Possiamo anche rendere i cookie usabili solamente nelle richieste HTTP e non tramite JavaScript.

13.8 Laboratorio

Tool:

- HTTP Header Live: per tracciare il traffico HTTP (estensione fireFox)
- Burpsuite: strumento potente
- Request Parsers (hookbin, requestbin): genera un URL
- XSSStrike: fuzzer, serve per trova la vulnerabilità di un sito

Per capire dove possiamo infiltrarci proviamo a mettere vari tag di script nel form per capire dove possiamo estrapolare i cookie. Per esfiltrare i cookie vogliamo creare una richiesta da qualche parte per esfiltrare i cookie, con hookbin ci crea un endpoint ed abbiamo il nostro URL da utilizzare per fare arrivare i dati, a questo punto dobbiamo creare una richiesta e metterci i dati dell'utente che visita. Per farlo mettiamo un'immagine con il link del endpoint. Una volta che abbiamo il cookie di sessione di un utente e modifichiamo il nostro cookie sullo strumento sviluppatore mettendo quello dell'utente che abbiamo preso possiamo impossessarci dell'account. Possiamo monitorare le richieste che vengono fatte dal browser al server, il primo modo è andare sotto la tabella network del development tool di firefox.

Chapter 14

Network Security

La rete introduce nuovi problemi legati alla sicurezza e nuove forme di attacco.

14.1 Cos'è una rete

Una rete di calcolatori è un insieme di calcolatori tra loro connessi. Gli host di questa rete comunicano scambiando messaggi che viaggiano tramite canali fisici che collegano un host all'altro. Per poter comunicare gli host devono stabilire dei protocolli di comunicazione. Una rete ha:

- Host
- Apparati attivi: smistamento messaggi
- Canali

Reti:

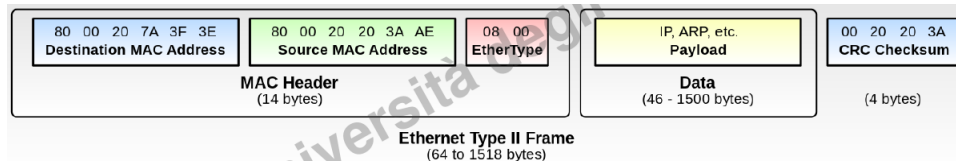
- Lab
- wan
- rete con apparati attivi

Gli host che ci interessano sono switch (punto punto) e Hub (broadcast) che riceve un pacchetto dall'host e lo inoltra a tutti (pacchetti duplicati). Nel caso dello switch è lui che fa la selezione su chi mandare il pacchetto (lo manda solo al destinatario). Servono per connettere i vari device in una LAN.

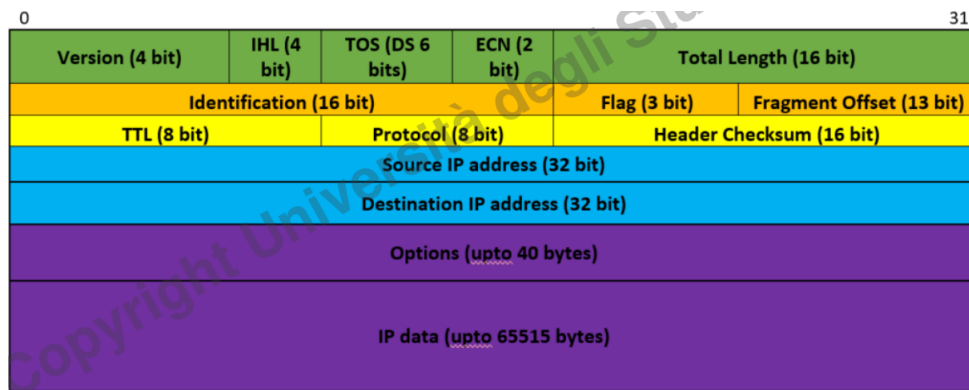
Per poter inviare un pacchetto ad un host è necessario conoscere il suo indirizzo (pacchetti hanno indirizzo mittente e destinatario). Gli indirizzi:

- mac address: indirizzo fisico, viene cablato sulla scheda di rete, di 48 bit
- IP: indirizzo logico, è di 32 bit per la versione IPV4, si sta migrando verso la versione IPV6 che prevede che l'indirizzo IP degli host sia 128 bit. Anche perchè in realtà abbiamo sulla rete più host che indirizzi disponibili, si è quindi esaurito lo spazio per IPV4
- Possiamo trovare anche indirizzi IP con l'indirizzo dell'host e la porta (le prime 1024, ad esempio nella 80 abbiamo HTTP)
- Indirizzi simbolici (domain name) usati dagli umani per accedere ai vari host

Per comunicare all'interno di una lan si usa il protocollo Ethernet, per comunicare all'interno di una lan si usa l'indirizzo mac, gli indirizzi ed il payload (contenuto del pacchetto).

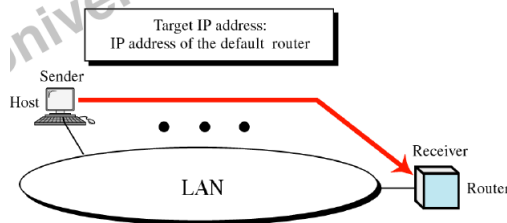
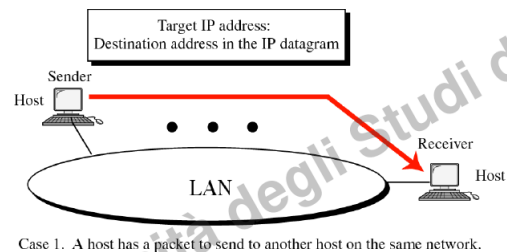


Per comunicare all'interno del protocollo della rete Internet (fuori dalla LAN) dobbiamo usare il protocollo TCP/IP, che usa l'indirizzo IP. La parte alta viene chiamata header del pacchetto, che contiene le info necessarie per il routing del pacchetto, mentre in viola abbiamo il payload.

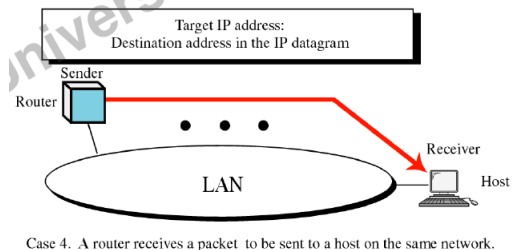
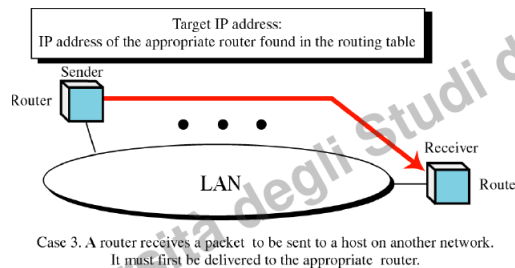


La rete Internet è una rete di reti locali (local area network), dobbiamo pensarla come un insieme di tante reti collegate tra di loro, la più piccola è la rete domestica, è quindi fatta da tante isole. Quando comunichiamo all'interno della nostra rete locale lo facciamo attraverso il protocollo ethernet (utilizzando il mac address), quando dobbiamo comunicare fuori dalla rete locale usiamo il protocollo TCP/IP (utilizzando l'IP address).

Se dobbiamo comunicare con un calcolatore attestato nella LAN mandiamo il pacchetto a quell'host.



Se invece dobbiamo comunicare all'esterno il pacchetto che dobbiamo spedire viene intercettato dal router (uno per lan) che prende il pacchetto e lo manda all'esterno.



Il pacchetto viene generato dall'applicazione che poi viene intercettato dal protocollo TCP, il quale al contenuto iniziale aggiunge un TCP header (imbusta il messaggio in una busta TCP, mette l'indirizzo della porta a cui inviare il pacchetto), quando ha finito passa il pacchetto al programma IP che a sua volta aggiunge una busta IP (viene messo l'indirizzo IP del destinatario ed il nostro) passato al layer 2 che aggiunge il suo pacchetto che poi passato al livello rete viene messo in rete.

Dal punto di vista della sicurezza rispetto al caso singolo host, un ambiente di networking introduce ulteriori elementi di criticità, il particolare esistono quindi dei nuovi elementi che possono essere utilizzati per effettuare degli attacchi:

- Canale di comunicazione
- Dispositivi di routing
- Protocolli di comunicazione

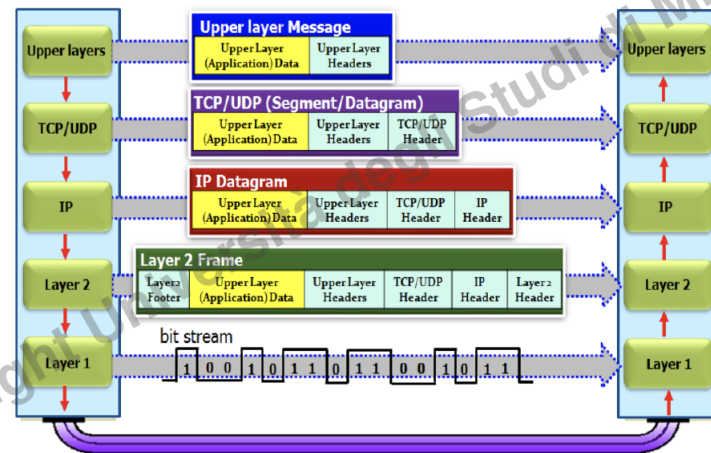


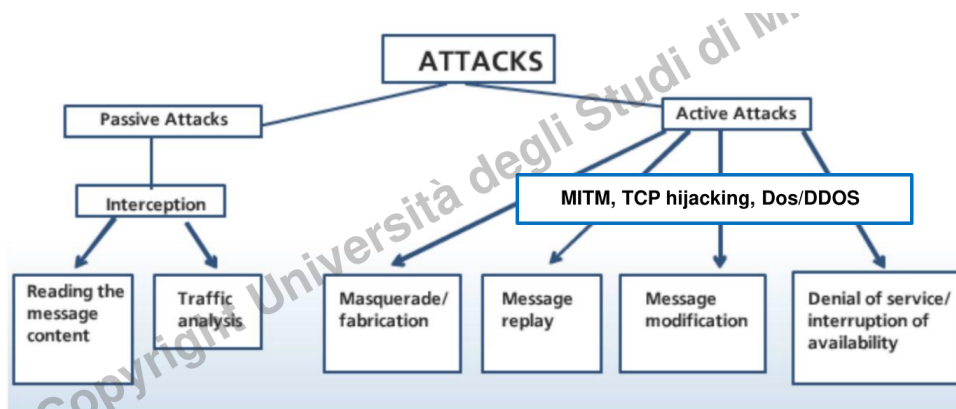
Figure 2. Encapsulation and Decapsulation of TCP/IP Protocol

Accanto a questi nuovi elementi abbiamo il fatto che la rete può essere utilizzata per distribuire contenuto malevolo.

14.2 Network attack

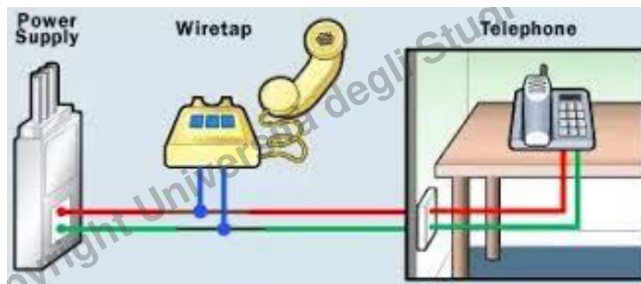
Sulla rete abbiamo diverse forme di attacco. Le distinguiamo in:

- Attacco passivo: non viene coinvolto direttamente nessun dispositivo appartenente all'utente
 - Intercettazione (sniffing), che consente a chi effettua l'attacco di leggere il contenuto dei messaggi che viaggiano sulla rete.
- Attacchi attivi: consentono di leggere i pacchetti e di modificarne il contenuto:
 - TCP hijacking
 - Denie of service
 - MITM

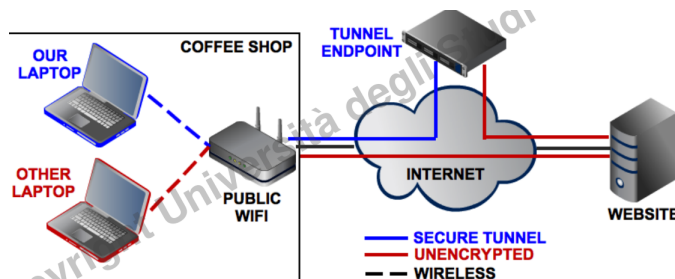


14.3 Attacco di intercettazione

L'intercettazione su cavo avviene attaccando un ricevitore ai fili della comunicazione che portano all'oggetto che viene intercettato e si tira su tutto il traffico di rete (questa cosa qua la possono fare nei provider).



L'intercettazione wifi sfrutta il fatto che usa l'etere come mezzo di comunicazione quindi basta avere un mezzo con un antenna ed essere vicini ad un hotspot si può intercettare tutto il traffico che viene generato.



E' possibile nel caso di sistemi di rete effettuare l'attacco di intercettazione senza avere accesso fisico al dispositivo di comunicazione. E' sufficiente che si comprometta un dispositivo attivo in cui passa il traffico per intercettarlo, oppure faccio una tecnica di man in the middle in cui riesco a camuffare l'indirizzo IP o internet del device che devo compromettere. Per fare l'intercettazione si usa un software che si chiama *packet sniffer*, il quale legge le informazioni che arrivano ad una scheda di rete (può essere anche usato in modo legittimo per filtrare il traffico etc). Un attacco che si può fare è installare un *packet sniffer* sulla macchina che si vuole controllare per intercettare il traffico. Gli sniffer si limitano a raccogliere i dati e solitamente sono molto difficili da rilevare. Il più famoso molto diffuso è *WIRESHARK*, tipicamente nasce come strumento di system management come monitoraggio della rete ed individuazione di criticità. Per evitare l'attacco di packet sniffing viene annullato usando la cifratura del traffico.

14.3.1 Spoofing

Un altro attacco a livello di rete è lo spoofing, che consiste nella modifica dell'indirizzo sorgente (mittente) all'interno del pacchetto. L'idea è che mando un pacchetto dalla mia macchina ma metto l'indirizzo di un'altra macchina. Questo si fa quando vogliamo attaccare una macchina per cambiare il nostro indirizzo IP per mandare i pacchetti con cui la vogliamo attaccare. E' un attacco che si può fare perchè il protocollo IP non prevede alcun meccanismo di autenticazione (nessun controllo sui campi source address). Si può fare a diversi livelli:

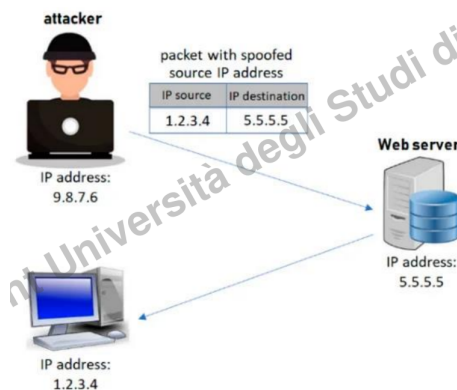
- Ip
- Email: programmi per mandare email modificando il mittente
- website spoofing

E' un attacco usato nei contesti in cui non viene fatta autenticazione. Troviamo in rete programmi che consentono di fare questo tipo di attività.



IP spoofing

L'attaccante manda in uscita un pacchetto cambiando l'indirizzo dell'host, ma a questo punto il web server manda la risposta all'host che ha messo nell'indirizzo. Quindi ricordiamo che quando facciamo IP spoofing mandiamo i pacchetti ma non riceviamo le risposte.

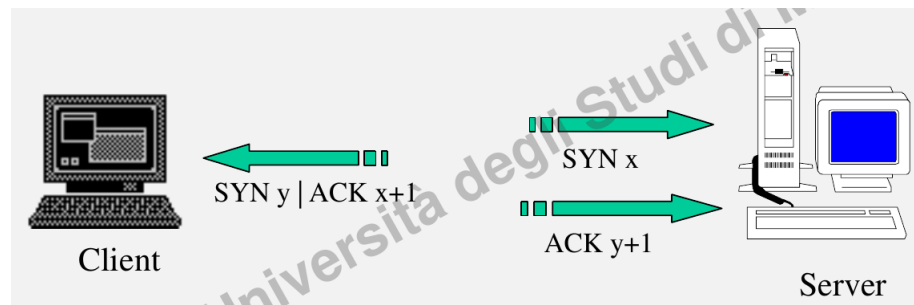


14.4 Attacchi all'integrità

Il TCP hijacking. Il protocollo TCP, all'inizio c'è una fase di stretta di mano, chi vuole connettersi al server manda una richiesta di connessione con un numero x (generato dal client), dall'altra parte il server che riceve il SYN x rimanda un SYN y ed un ACK $x+1$, il client a sua volta risponde con un ACK $y+1$. L'idea è che il server sa a che client risponde perchè gli ha ritornato l' $y+1$, quindi risponde a lui. Il punto debole di questo protocollo è che si indovina l' y e si risponde al server con $y+1$ il server crede che io sia il client. Quindi la capacità di indovinare l' y consente di effettuare un attacco di impersonificazione.

14.4.1 Esempio

(Mitnick VS Shumomura per rubare dal computer di shumomura i file) L'attacco è stato effettuato in questo modo, finger era un comando che veniva fatto mandando un indirizzo internet e restituiva delle informazioni, dopo di che veniva mandato un altro comando che consisteva nel chiedere quali erano gli host (showmount -e) che erano fidati (un host fidato



era un host che si poteva collegare senza richieste di autenticazione), dopo di che venivano inviati 20 pacchetti di SYN che servivano per capire qual'è l'algoritmo che la macchina usava per generare i numeri casuali dell'ACK. A questo punto fa un attacco sulla macchina fidata di syn flood (denie of service) per impedire che venga usata. Dopo di che manda un pacchetto di syn spoofato dicendo che lui è il server trusted t , la macchina attaccata ricevendo la richiesta di syn spoofata da t manda il syn ack a T , ma essendo sotto attacco non può rispondere, l'attaccante risponde con un ack con un numero che ha provato ad indovinare, se ha indovinato $y+1$ viene riconosciuto dal server come la macchina T di cui si fidava. A questo punto manda un comando in cui dice di aggiungere all'elenco di host fidati tutti gli host che sono sulla rete internet.

Attualmente non si possono più fare perchè all'epoca la generazione dei numeri y e x era molto prevedibile, ad oggi è praticamente impossibile indovinare questi numeri.

In questo attacco sono stati fatti attacchi di denial of service, ip spoofing e un sequence number guessing.

14.5 DoS-DDoS

E' un'altra forma di attacco diffusa ed è un attacco alla disponibilità dei sistemi (denie of service). Mira che utenti legittimati all'uso di un servizio non possano accedervi, si fa esaurendo la connettività o la banda, un'altra risorsa che può essere esaurita è la CPU. Si possono ottenere modificando in maniera errata dei file di configurazione o mettendo una bomba in un centro di calcolo.

Tipi:

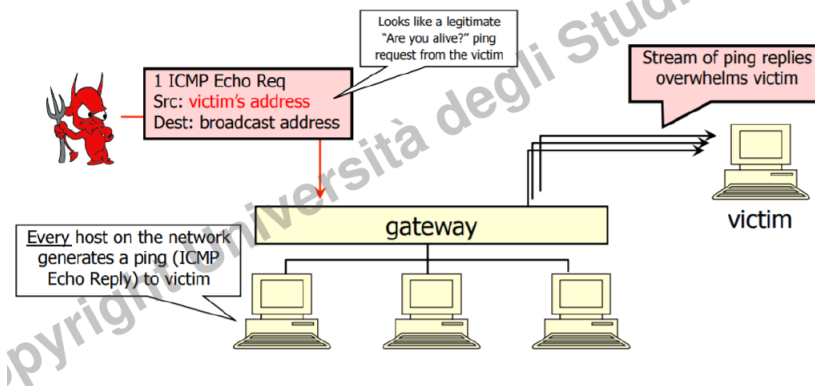
- Localmente, creando il crash di processi attraverso il `while true fork`. Oppure generando dei file molto grossi. Questi sono attacchi che possono essere fatti solo localmente alle risorse.
- Remotamente, fatti inviando dei pacchetti opportuni di rete

14.5.1 Smurf Attack

Consisteva da parte di un attaccante di generare un pacchetto ICMP (il comando PING genera un pacchetto ICMP di echo request), si generava un PING finto mettendo come indirizzo sorgente l'indirizzo della macchina che si voleva attaccare e come destinatario tutti gli host sulla rete, quindi l'effetto di questo attacco è che tutti gli host all'interno della rete rispondono alla vittima che si vede intasata da tutti gli echo reply che gli arrivano. Se invece di un pacchetto solo ne mandiamo qualche milione l'effetto viene logicamente aumentato.

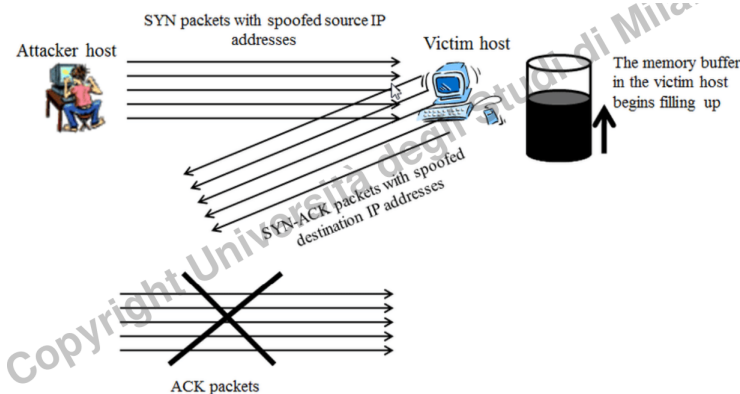
14.5.2 Syn Flood

Usa il tree way and shake (stretta di mano): mando il syn all'host con cui mi voglio collegare, il quale risponde con il syn ack. Quando l'host riceve una richiesta di connessione da un

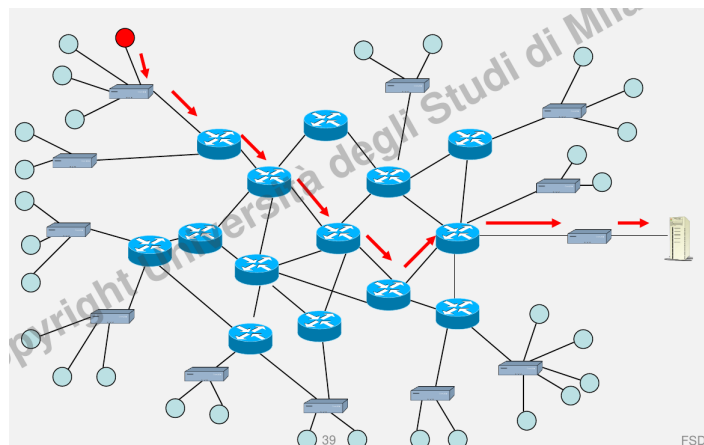


Solution: reject external packets to broadcast addresses at router

altro host memorizza questa richiesta in una coda come connessione pendente in attesa che arrivi il syn ack. Questo attacco consiste nel mandare una serie di pacchetti di richiesta di connessione tutti spoofati, l'host riceve le richieste di connessione, le impila tutte e manda i syn ack, ovviamente vengono mandati a macchine che non hanno richiesto niente e quindi vengono ignorate, quindi la coda delle connessioni si riempie e si inchioda tutto.

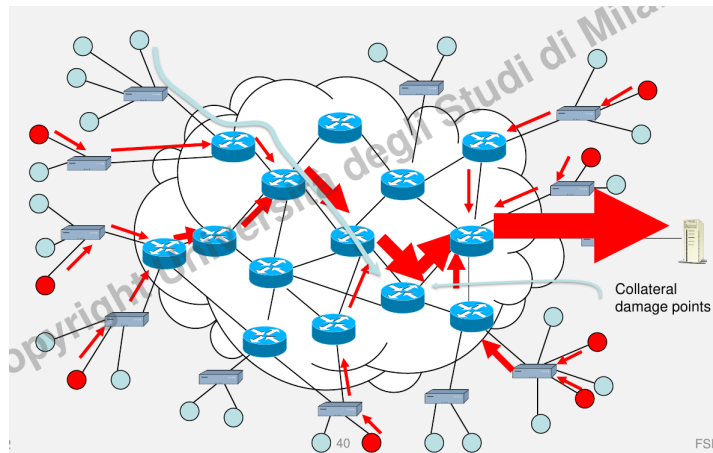


Come si può fare a generare questa mole di pacchetti che esauriscono le risorse di un PC. Il dos può avere una singola sorgente, c'è un unico attaccante che prova ad intasare un server.

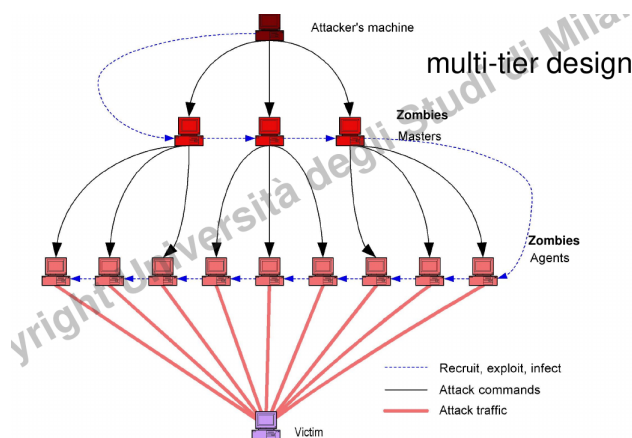


Oramai non c'è più un attaccante unico che riesce ad intasare un server, si usa quindi

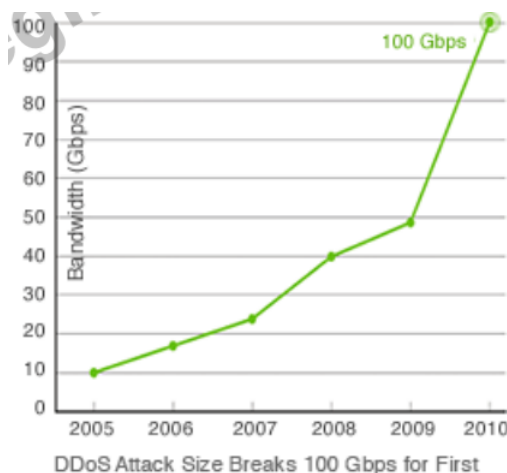
un distributed denie of service, dove ci sono più punti che attaccano contemporaneamente il bersaglio.



Per fare DDOS si usano le botnet, quindi un attaccante infetta attraverso un malware di bot una serie di macchine zombie, dopo di che una volta che ha la sua botnet a disposizione le istruisce e fa partire l'attacco DDOS.



Gli effetti dell'attacco sono tutt'altro che trascurabili. Quando può arrivare un attacco DDOS, si è arrivati nel 2010 un attacco che ha raggiunto i 100 Gb al secondo (tantissima banda), se arriva un attacco di questo tipo l'unica cosa da fare è aspettare che passi.



14.6 Mitigare gli attacchi alla confidenzialità

Si tratta di adottare dei protocolli crittografici che permettono di inviare il dato in maniera cifrata, quindi se intercettato a livello rete non può succedere niente. Abbiamo tre grosse tipologie di crittografia:

- A livello applicativo: end to end, che viene messa a disposizione da whatsapp, vuol dire che il dato viene cifrato dall'applicazione e resta cifrato fino alla destinazione, viene decifrato solo dal browser che riceve il messaggio.
- A livello trasporto
- A livello TPC: in questo caso il pacchetto viene cifrato poco prima di lasciare l'host e viene decifrato esattamente a destinazione (appena arriva viene decifrato e depositato sul'hard disk in chiaro).

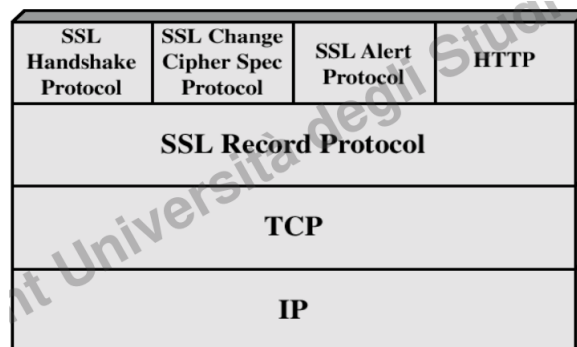
GPG fornisce crittografia end to end (come whatsapp), in qualche modo prevede il coinvolgimento dell'utente, è possibile farla a livelli più bassi evitando il coinvolgimento dell'utente (IP o TCP), a livello IP viene fatta dal protocollo IP SEC, a livello TCP dal protocollo TLS.

14.6.1 IP SEC

E' una suit di protocolli fatta dalla IETF, standard internazionale e provvede a cifrare automaticamente il traffico che esce dalla nostra macchina (va attivato in fase di configurazione). Il traffico viene cifrato da indirizzo IP ad indirizzo IP quando arriva a destinazione viene decifrato per essere conservato su disco.

14.6.2 TCP TLS

Il protocollo TLS (standard di riferimento) è il protocollo su cui è costruito HTTPS. Il funzionamento di TLS è quello che succede ogni volta che ci colleghiamo ad un sito web. Con autenticazione server only significa che prima di collegarci ad un server ne verifica l'autenticità.



Algoritmi:

- X509: usa certificati x509 per l'autenticazione

Gli algoritmi di firma e crittografia asimmetrica sono:

- RSA
- DH
- DSS
- Fortezza

Nel momento in cui ci colleghiamo ad un serve web avviene un SSL handshake, il client invia il tempo, un numero casuale ed un byte che comunica al server gli algoritmi di crittografia che vogliamo usare. Il server ricevuta sta roba risponde con un numero casuale, la session id e la chiper suit, ci manda poi la sua chiave pubblica, la fine della conversazione.

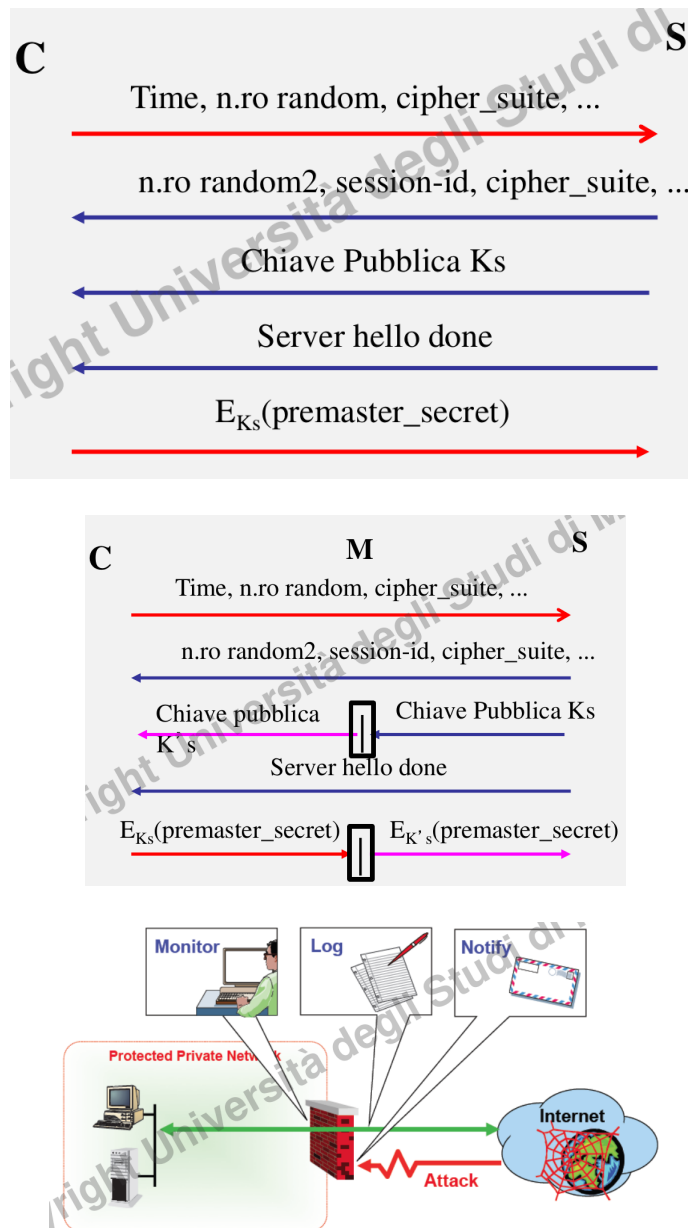
La cyper suit ci dice la modalità con cui vogliamo cifrare i dati.

Il problema di questa modalità è che non sappiamo se la chiave pubblica che ci viene inviata è veramente quella del server che vogliamo (potremmo avere un man in the middle).

Il problema viene risolto mandando anche un certificato x509 del server, quindi tutti i server devono procurarsi un certificato x509 dedicato ai web server che ne autentica l'identità.

14.7 Firewall

Un dispositivo famoso per intercettare ed analizzare il traffico di rete, sono degli strumenti che fanno traffick inspection e decidono cosa fare. Vanno configurati, la configurazione consiste nello specificare ai device con li traffico che ispezionano. Tipicamente va posizionato prima dell'ingresso ad una rete aziendale, consente l'accesso alla rete di un organizzazione al traffico che corrisponde a certe caratteristiche.

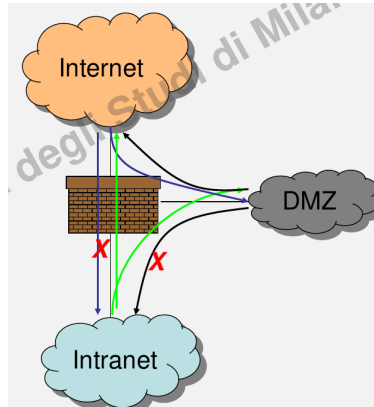


Dovrebbe analizzare il traffico, quello maligno respingerlo e quello buono farlo passare. Accanto a questa azione è in grado di generare una serie di file di log in base alla tipologia di file che vede ed inviare delle notifiche.

Il firewall analizza pacchetti TCP/IP, qui c'è tutta l'informazione di comunicazione tra due host, in funzione alle info che vengono analizzate distinguiamo tipi di firewall. Ovviamente più informazioni analizza più rallenta il traffico. La prima tipologia di firewall sono i packet filter, controllano solo i dati nell'header dei pacchetti TCP/IP. Sul pacchetto abilitano al traffico, lo buttano via, lo modificano e loggano le informazioni. Sono noti una serie di host che generano dati di spam, gli indirizzi IP di questi host vengono messi nel firewall che butta via i pacchetti che arrivano da quegli host.

La tipica configurazione di un firewall è metterlo tra la intranet (rete aziendale) e internet. Il traffico internet può accedere solo ai servizi all'interno della DMZ, quindi è tutto dirottato lì. All'interno della DMZ esistono dei meccanismi per decidere se dirottare il traffico o meno. E' consentito il traffico tra la intranet e la DMZ. La DMZ è l'unica componente della rete

aziendale che può accedere al traffico internet, nella DMZ mettiamo il web server, il DNS etc.



Ci sono firewall di più alto livello che controllano il contenuto dei pacchetti.

14.7.1 IDS

Il problema è che ci possono essere delle forme di attacco che non sono facilmente rilevabili da un firewall, ma solo dopo che tutti i pacchetti di una sessione sono stati ricostruiti possono essere individuati. Per risolvere questi problemi sono stati inventati gli intrusion detection system, che sono delle componenti hardware e software che sono dedicati a rilevare in tempo reale l'intrusione in un sistema. Due tipologie:

- Host Base: lavora sugli host
- Network base: sono installati su router o firewall e verificano se nel traffico di rete è presente uno schema di attacco

Contrariamente al firewall gli IDS non fanno azioni, si limitano a fare alert. Gli IDS per individuare gli attacchi in corso usano due strategie:

- Misuse Detection: hanno delle sequenze di azioni che individuano delle forme di attacco note. Queste signature sono specifiche per ogni tipologia di attacco, basta cambiare due byte dell'attacco che questa signature non è più valida.
- Anomaly Detection: hanno dei profili di comportamento della rete standard, se ad un certo punto arrivano troppe richieste HTTP rilevano un comportamento anomalo.

Le info che usa uno host base:

- System call
- Sequenza di comandi
- Processi
- Accessi a file e device

Quando c'è qualcosa che va contro le abitudini dell'utente viene mandato un alert di anomalia.

Per quanto riguarda i Network Based il dato di input è il traffico e la forma del traffico. Il tipo di traffico che riceviamo, la quantità di traffico che riceviamo, ricostruiamo la nostra traffic shake standard, quando c'è qualcosa che devia da questi standard scatta l'alert.

Il problema grosso di questi sistemi è la possibilità di sbagliare, falso positivo (quando un'attività neutra viene segnalata come attività pericolosa, tipico degli anomaly based), falso negativo (nel caso in cui viene fatto un attacco e non viene rilevato). Il problema grosso sono i falsi positivi, perchè mettiamo in moto una catena di indagine che porta via tempo nonostante non sia successo niente. Ci sono realtà in cui possono esserci veramente tanti falsi positivi.

14.7.2 Intrusion Prevention System IPS

Sono IDS forniti di licenza di uccidere, sono sistemi che vengono programmati per svolgere una serie di azioni (sta arrivando traffico anomalo, chiudi la porta).

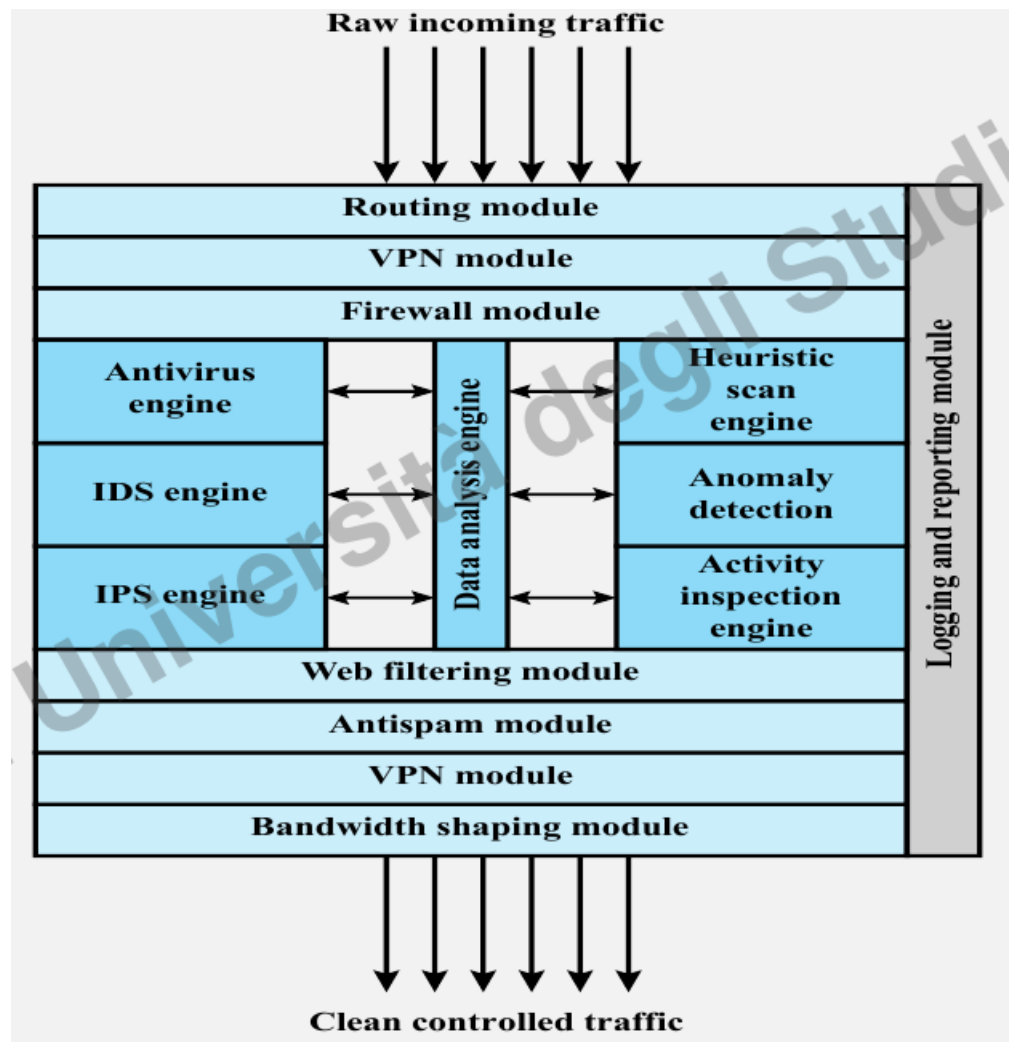
14.7.3 Unified Threat Management Product

Contengono tutti gli strumenti che abbiamo visto:

- Firewall
- VPN
- IDS

- IPS
- Antivirus
- Web filtering

O next generation firewall, che non sono più firewall ma che nella stessa componente fanno firewalling, intrusion detection, intrusion prevention.



Chapter 15

Privacy

La privacy nasce nel 1890 da due avvocati che lavoravano ad una causa in cui una persona famosa era stata fotografata e pubblicata senza aver dato l'autorizzazione. A fronte dell'analisi di questo caso introducono il diritto di essere lasciati soli, la privacy diventa a partire da loro un elemento importante.

Il termine privacy nel corso degli anni si sposta e viene a coincidere con il concetto di riservatezza delle informazioni, in particolare agli informatici il diritto di privacy interessa perchè è il diritto di individui, gruppi ed istituzioni di determinare come l'informazione che li riguarda venga comunicata ad altri. L'abuso di queste informazioni è legato a garantire la vita sociale delle persone, questo aspetto viene bene sottolineato da alcuni contributi fatti anche a livello italiano. Garantire la privacy vuol dire evitare di impicciarsi della vita privata di una persona, questo ha degli impatti negativi per altre attività utili a livello sociale:

- Prevenzione del crimine
- Lotta al terrorismo
- Diffusione di notizie false e tendenziose

La privacy si presenta come elemento fondamentale della società dell'eguaglianza. Il problema non è la raccolta di informazioni private, ma come queste vengono usate (armi di ricatto).

La prima cosa che le persone devono fare è proteggere la loro sfera personale e per farlo devono proteggere la loro informazione personale. Esiste un filone di privacy protection legato alla cybersecurity, le informazioni vengono divise in categorie:

- Personal identifiable information: informazioni che permettono di identificare subito una persona
- NPII: libri letti, musica, film... che non sono sufficienti ad identificare una persona, ma possono contribuire a profilare il carattere
- Location Data: dati relativi ai luoghi che una persona frequenta
- Info relative ai device tecnologici che una persona usa

Si è assistito ad un incremento delle informazioni raccolte e memorizzate nei sistemi. E' stato coniato il termine di società della sorveglianza, caratterizzate dalla collezione di dati relativi a gruppi di individui ed alla loro vita, info raccolte nei modi più disparati (ad esempio i programmi di fedeltà nei supermercati, in cambio a qualche sconto ogni tanto è in grado di sapere cosa mangiamo nell'arco della nostra vita etc), così come in realtà la rete stessa, fruendo di servizi di ricerca che sono gratuiti, ma ovviamente non sono gratuiti perchè paghiamo dando le nostre informazioni. C'è attualmente la ricerca di info che identificano le persone, l'obiettivo è rivendere queste informazioni per fare pubblicità mirata (il business dei prossimi 10 anni). Il problema è che con questo tipo di informazioni si può arrivare ad influenzare il parere di una persona. Il problema è che le banche dati in cui ci sono i nostri dati vanno protette.

15.1 Data Breach

Si parla di data breach quando si accede ad informazione legata a persona senza la dovuta autorizzazione. Alcuni strumenti di malware (o no) che possono essere usati per raccogliere informazioni relativamente alle informazioni. Il più grande è stato quello di yahoo! in cui sono stati rubati più di 3 miliardi di dati, che vengono usati per creare dei profili falsi ma veri, impersonificando queste persone sui social (e non solo).

15.2 Il futuro

Bisogna mettere dei meccanismi che arginino la raccolta di informazioni che riguardano la vita privata delle persone. Recentemente sono apparsi dei siti che raccoglievano il DNA delle persone, il problema è che questi dati vengono raccolti su basi di dati e la sicurezza di queste basi di dati non è garantito, quindi mettiamo che venga hackerata da una compagnia di assicurazione che scopre che abbiamo una predisposizione ad una certa malattia e quindi aumenta la polizza.

15.3 GDPR

E' una regolamentazione europea che cerca di mitigare la raccolta forsennata di dati personali. E' stato realizzato con il focus sui social media ma controlla tutte le attività riguardante i dati personali. Prevede alcuni diritti fondamentali che devono essere rispettati ogni persona ha il :

- Diritto di sapere quali sono i dati che vengono raccolti da un qualunque ente, accesso
- Diritto ad essere dimenticato
- Diritto alla data portability, vogliamo portare tutti i dati da una piattaforma all'altra
- Diritto ad essere informati, sapere quali sono le attività che vengono fatte
- Diritto intervenire sul processo sui nostri dati
- Diritto a non essere d'accordo su cosa viene fatto
- Diritto ad essere notificati quando dati che ci riguardano vengono memorizzati

15.3.1 Dato personale

Non sono solo i dati PII ma anche gli online identifier (IP address e gli identificatori dei cookies).

15.3.2 Informazione e consenso

Processo di anonimizzazione dopo ad un certo periodo. Il diritto ad essere dimenticato dev'essere esercitato, è molto complicato perchè nessuno sa se qualcuno ha fatto delle copie dei nostri dati senza il consenso.